

IT-Recht — Rechtsrahmen IT-Sicherheit und Datenschutz (WDS224 · DEF)

Quelle: WDS224 - IT-Recht (DEF).zip **Offizieller Titel:** Grundlagen IT-Sicherheit und Datenschutz — juristischer Teil **Dozent:** Dr. Florian Deusch, Rechtsanwalt, **Fachanwalt für IT-Recht**, Anwaltskanzlei Dr. Gretter, Eisenbahnstraße 41, 88212 Ravensburg **Modul:** W4DSKI_207 · Studiengang **Data Science und Künstliche Intelligenz** · Sommersemester 2026



Aufbau des Gesamtmoduls

„Die DHBW bietet die Vorlesung »Grundlagen IT-Sicherheit und Datenschutz« mit 55 Unterrichtseinheiten (UE) zu je 45 Minuten an. Die Vorlesung besteht aus einem INFORMATIK-Teil und einem JURISTISCHEN Teil:“

Teil	Dozent	UE
Informatik-Teil	Prof. Dr. Aykan Inan	35 UE
Juristischer Teil	RA Dr. Florian Deusch	25 UE

(→ Der Informatik-Teil ist in 11_IT-Security.md dokumentiert!)



KLAUSUR — die Hilfsmittelregel (SEHR WICHTIG!)

„Prüfung in Form einer Klausur.“

★★★★ ZUGELASSENE HILFSMITTEL im Klausurteil Datenschutz:

- ✓ AUSSCHLIESSLICH GEDRUCKTE GESETZESTEXTE
- ✓ Im gedruckten Gesetzestext dürfen Sie PRO SEITE bis zu 5 UNTERSTREICHUNGEN vornehmen und bis zu 3 WÖRTER dazuschreiben.
- ✓ Zugelassen ist es außerdem, in Gesetzessammlungen PRO GESETZ EIN „POST-IT“ zu verwenden, damit man das betreffende Gesetz schneller findet.
- ⚠ „ALLE WEITEREN EINTRAGUNGEN IM GEDRUCKTEN GESETZESTEXT WERDEN ALS »SPICKZETTEL« GEWERTET.“
- ✗ KEINE digitalen Hilfsmittel (auch keine digitalen Abrufe von Gesetzestexten)
- ✗ KEIN Skriptum, KEIN Lehrbuch!

Empfohlene Gesetzessammlung: ★ beck-dtv-Ausgabe 5562 „IT- und Computerrecht“ (CompR)
— die Ordnungsnummern werden im Skript durchgehend zitiert!

Arbeitsmaterial

Material	Beschreibung
(a) Gesetzes texte	★ „Bitte LESEN Sie alle Rechtsnormen, die wir in der Vorlesung behandeln und die im Skriptum genannt sind, SELBST durch, am besten (im ungestörten Raum) LAUT.“
— EU- Recht	https://eur-lex.europa.eu/homepage.html?locale=de
— Bundesr echt	https://www.gesetze-im-internet.de/
— Landesre cht BW	https://www.landesrecht-bw.de/bsbw/search
(b) Lehrmat erial	Dieses Skriptum (alle Teile) + ★ Deusch/Eggendorfer: „Beauftragte für Informationssicherheit und IT-Sicherheit“ (2024, ISBN 978-3-8005-1873-9) — „Sie müssen das Buch NICHT KAUFEN (aber LESEN!), es ist als eBook in der Hochschulbibliothek verfügbar!“

Der Vorlesungsplan (25 UE)

Teil	Thema	UE
1	Erste Schritte in der Jura-Welt	2
2	Rechtsquellen der IT-Sicherheit und des Datenschutzes	4
3	Ausgewählte Rechtsgrundlagen zur IT-Sicherheit und zum Datenschutz	16
3.1	Datenschutz-Grundverordnung und weitere Datenschutz-Gesetze	4
3.2	Compliance-Pflichten zur IT-Sicherheit und zum Datenschutz in Unternehmen und Behörden	2
3.3	IT-Sicherheit gemäß BSIG für besonders wichtige/wichtige Einrichtungen, Betreiber kritischer Anlagen	2
3.4	Produktbezogene Rechtsgrundlagen: Cyber Resilience Act, KI-VO, Produktsicherheit und -haftung	4
3.5	Rechtsrahmen der IT-Sicherheitsforschung, insbesondere Straf- und Urheberrecht	2
3.6	Haftung im Internet, insbesondere nach dem Digital Services Act	2
4	Rechtsdurchsetzung durch Behörden und vor Gerichten	2

Das Leitmotiv des Skriptums (Vorwort)

„Gesetze werden von Juristen in der Gesetzgebung geschrieben, von Juristen in den Gerichten (und Anwaltskanzleien) ausgelegt und angewendet und von Juristen in der Verwaltung vollzogen. UMZUSETZEN sind die Gesetze aber von den MENSCHEN, DIE IN DEN GEREGLTEN BEREICHEN ARBEITEN UND LEBEN. Sie sind meist KEINE Juristen.“

„Die Studierenden werden SCHLÜSSELSTELLEN im Lebens- und Wirtschaftsbereich »Datenverarbeitung« besetzen. Sie werden Entscheidungen treffen, OB und vor allem WIE elektronische Daten verarbeitet werden.“

📖 Zitat Philipp Heck (1858–1943): „Wir arbeiten nicht, um das Prädikat »Wissenschaft« zu erhalten, sondern um DEM LEBEN ZU DIENEN.“ (→ **Interessenjurisprudenz**: „Der Ursprung jeder Rechtsnorm ist begründet in konkurrierenden Wertvorstellungen (»Interessen«) gesellschaftlicher Gruppen. Deshalb ist bei der Auslegung jeder Rechtsnorm das zugrundeliegende Interesse zu berücksichtigen.“)

TEIL 1 — ERSTE SCHRITTE IN DER JURA-WELT

1. ★★ Was ist „Recht und Gesetz“?

Ausgangspunkt: Art. 20 Absatz (3) GG (2. Halbsatz): „(...) die vollziehende Gewalt und die Rechtsprechung sind an GESETZ UND RECHT gebunden.“ ★ „Das Grundgesetz unterscheidet somit zwischen »RECHT« und »GESETZ«.“

1.1 ★★ Positives Recht vs. Naturrecht (KLAUSURTHEMA!)

	POSITIVES RECHT	NATURRECHT
Definition	„Recht ist, was die nach der Verfassung dafür ZUSTÄNDIGEN ORGANE als Recht GESETZT haben.“	„Das »Recht« ist abgeleitet aus der NATUR, dem WESEN DES MENSCHEN. Recht ist danach nur, was MORALISCH, ETHISCH oder THEOLOGISCH GERECHT (»richtig«) ist — auch dann, wenn die Anwendung existierender Gesetze zu einem anderen Ergebnis führen würde.“
Legitimation	„In einem demokratischen Staat ist dieses »positive« Recht durch die MEHRHEITSENTSCHEIDUNG moralisch legitimiert: Was alle (oder die Mehrheiten) wollen, kann nicht Unrecht sein.“	
Stärke	„Das positive Recht schafft SICHERHEIT, weil sich die Rechtssubjekte an das bestehende Recht halten können und sollen.“	
Schwäche	⚠ „In Extremsituationen kann es an seine Grenzen kommen: Die Richter in der NS-Zeit und die DDR-Grenzsoldaten hielten sich an geltendes, »positives« Recht, als sie Todesurteile verhängten und (DDR-)Flüchtlinge beim »Sprung über die Grenze« erschossen.“	⚠ „PROBLEMATISCH: je nach der zugrundeliegenden Wertvorstellung kann »aus der Natur der Sache« heraus NAHEZU JEDES ERGEBNIS BEGRÜNDET werden.“

⚠ Die historische Warnung des Skriptums

„So wurde den Jura-Studenten in der NS-Zeit z.B. gelehrt: »Die Regel schafft nicht die Ordnung; sie hat vielmehr nur auf dem Boden der geltenden (NS-)Ordnung eine gewisse regulierende Funktion mit einem relativ kleinen Maß.« Mit anderen Worten: DAS GESETZ GILT NUR, SOWEIT ES DER NS-WELTANSCHAUUNG ENTSPRICHT, auch wenn diese nicht kodifiziert ist.“ (C. Schmitt)

1.2 ★★★★★ Die RADBRUCH'SCHE FORMEL (KLAUSURDEFINITION!)

„Aufgrund der Erfahrungen aus der NS-Zeit finden sich im Grundgesetz **BEIDE ANSÄTZE**: In Art. 20 bekennt sich das Grundgesetz zu »Gesetz und Recht«. Als Element des Naturrechts verweist das »Recht« auf **FUNDAMENTALE GERECHTIGKEITSVORSTELLUNGEN**. In einer Demokratie ist aber grundsätzlich **DAS GEWÄHLTE PARLAMENT** (der Bundestag) legitimiert zu entscheiden, was »gerecht« ist.“

★★★★ „NUR IN AUSNAHMEFÄLLEN sind die Gerichte befugt und verpflichtet, sich über das positive Recht hinwegzusetzen: **WENN EIN OFFENSICHTLICHER, UNERTRÄGLICHER VERSTOSS GEGEN ELEMENTARE GEBOTE DER GERECHTIGKEIT UND GEGEN VÖLKERRECHTLICH GESCHÜTZTE MENSCHENRECHTE VORLIEGT**, der so schwer wiegt, dass er die allen Völkern gemeinsamen, auf **WERT UND WÜRDE DES MENSCHEN** bezogenen Rechtsüberzeugungen verletzt (»RADBRUCH'SCHE FORMEL«).“

Anwendungsfälle: Die deutsche Justiz hat die „**DDR-Mauerschützen**“ strafrechtlich verurteilt und verfolgt noch immer die **Täter der NS-Zeit**.

Die naturrechtliche Frage im Datenschutz

„Unterstellt, die Datenerhebung durch die NSA ist durch (US-)Gesetze (»positives Recht«) gedeckt. War die **INFORMATION DER ÖFFENTLICHKEIT DURCH EDWARD SNOWDEN** kraft **ÜBERGESETZLICHEM RECHT** berechtigt (naturrechtliche Würde der betroffenen Menschen)?“

1.3 ★★★★★ Kennzeichen und Funktionen des Rechts

#	Kennzeichen/Funktion	Erläuterung
1	Rechtsnormen sind STAATLICH GESETZT oder vom Staat ANERKANNT .	Staatlich GESETZT : Gesetze · Staatlich ANERKANNT : Tarifverträge (von Arbeitgeberverbänden und Gewerkschaften gesetzt), Satzungen (Normen, die eine juristische Person zur Regelung ihrer eigenen Angelegenheiten setzen darf — z.B. Satzungen einer Hochschule oder eines Vereins)
2	★ „Das Recht ist mit der BEFUGNIS ZU ZWINGEN verbunden.“ (I. Kant)	Beispiel : Eine Zahlungspflicht kann vollstreckt werden, indem der Gerichtsvollzieher dem Schuldner bewegliche Sachen wegnimmt, diese versteigert und den Erlös dem Gläubiger auszahlt (§§ 809, 814 ZPO) · R. v. Jhering: „Recht ohne Zwang ist wie ein Feuer, das nicht brennt, ein Licht, das nicht leuchtet“
3	ORDNUNGSFUNKTION : Recht verhindert Chaos	Beispiel: Straßenverkehr
4	Recht GESTALTET UND STEUERT die Gesellschaft	Beispiel: staatliche Förderung erneuerbarer Energien
5	BEFRIEDUNGSFUNKTION : Konflikte werden in GEREGELTEN VERFAHREN ausgetragen	
6	Recht KONSERVIERT die jeweilige Staats- und Gesellschaftsordnung	
7	Recht schafft SICHERHEIT UND VERTRAUEN	„Wer sich nicht darauf verlassen kann, dass ein Vertrag umgesetzt wird (notfalls zwangsweise), wird KEINE VERTRÄGE MEHR ABSCHLIESSEN . Dann wäre z.B. ein verlässliches Wirtschaften nicht mehr möglich.“

2. ★★★★★ Rechtsnorm, materielles und formelles Gesetz

„Das Recht setzt sich zusammen aus RECHTSNORMEN. Die Rechtsnormen sind die »ELEMENTARTEILCHEN« der Rechtsordnung.“

Die Wortherkunft „norma“

„Der Begriff »Rechtsnorm« geht zurück auf das lateinische »NORMA«. »Norma« war ursprünglich ein »WINKELMASS« für Handwerker zur Herstellung maßgerechter Werkstücke. Römische Juristen verwendeten das Wort im übertragenen Sinn für »MASSSTAB, REGEL, VORSCHRIFT«. Die »norma« wurde zum INSTRUMENT ZUR PRÜFUNG UND STEUERUNG MENSCHLICHEN VERHALTENS.“

Begriff	Definition
GESETZ IM MATERIELLEN SINN (= Rechtsnorm)	„Rechtsnormen sind ALLGEMEIN-VERBINDLICHE REGELN DES RECHTS. Sie definieren GENERELL-ABSTRAKT Rechte und Pflichten.“
GESETZ IM FORMELLEN SINN	★ „Eine TEILMENGE der materiellen Gesetze. Dies sind Rechtsnormen, die IN DEM VON DER VERFASSUNG VORGESEHENEN VERFAHREN ZUSTANDE GEKOMMEN sind.“ In Deutschland: vom BUNDESTAG oder den LANDTAGEN verabschiedet.

★★★★★ Beispiele (KLAUSURFALLE!)

Beispiel	Einordnung
BGB	FORMELLES Gesetz — vom Deutschen Bundestag beschlossen
⚠★★★★ DSGVO	„! ACHTUNG ! Lassen Sie sich von der BEZEICHNUNG der Rechtsnorm nicht täuschen: Die Datenschutz-Grundverordnung ist nach dem Verfahren der EU-Verträge durch das EUROPÄISCHE PARLAMENT und den RAT DER EU beschlossen worden und gilt unmittelbar in allen EU-Mitgliedsstaaten. Insofern ist die DSGVO TROTZ DER BEZEICHNUNG »VERORDNUNG« EIN FORMELLES GESETZ.“
StVO (Straßenverkehrsordnung)	MATERIELLES Gesetz — „Sie ist NICHT vom Bundestag beschlossen, sondern vom BUNDESVERKEHRSMINISTERIUM erlassen worden“ (gemäß Art. 80 GG kann der Bundestag Exekutivorgane zum Erlass von Rechtsverordnungen ermächtigen)

3. ★★★★★ DIE 4 MERKMALE EINES GESETZES (Klausurfrage!)

- ① GENERELL - ABSTRAKT
 - ② BEDINGT (Tatbestand)
 - ③ SOLLENSANORDNUNG
 - ④ RECHTSFOLGENANORDNUNG

① GENERELL-ABSTRAKT

„Sie richten sich an einen **UNBEGRENZTEN ADRESSATENKREIS** und gelten für **UNBEGRENZT HÄUFIGES AUFTRETEN** der von ihnen beschriebenen Situationen.“

 **Beispiele:** a) „Das Verletzen eines Menschen ist gemäß § 223 StGB für **ALLE Menschen in Deutschland** verboten. Die Norm »Verletze keinen Menschen!« ist generell-abstrakt.“ b)  „Im Datenschutzrecht gilt: Die Verarbeitung personenbezogener Daten ist nur zulässig, wenn mindestens eine der (Erlaubnis-)Bedingungen in Art. 6 DSGVO erfüllt ist. Damit ist eines der **GRUNDPRINZIPIEN** des Datenschutzrechts geregelt: die Verarbeitung personenbezogener Daten ist — generell-abstrakt — **VERBOTEN**, außer, es gibt dafür eine gesetzlich anerkannte Rechtfertigung.“ → 

VERARBEITUNGSVERBOT MIT ERLAUBNISVORBEHALT (gleich mal merken!) c) **Gegenbeispiel:** „Eine **BAUGENEHMIGUNG** gilt nur für das jeweilige Bauvorhaben des Antragstellers. Sie wirkt nicht abstrakt, sondern **KONKRET**.“

② BEDINGT (Tatbestand)

„Gesetze definieren in einem **TATBESTAND**, für welche Fälle sie gelten sollen.“

 § 223 Absatz (1) StGB — *Tatbestand fett:* „**Wer eine andere Person körperlich misshandelt oder an der Gesundheit schädigt**, wird mit Freiheitsstrafe bis zu fünf Jahren oder mit Geldstrafe bestraft.“

 Art. 6 Absatz (1) DSGVO — *Tatbestand fett:* „Die Verarbeitung ist nur rechtmäßig, **wenn mindestens eine der nachstehenden Bedingungen erfüllt ist:** a) **Die betroffene Person hat ihre Einwilligung zu der Verarbeitung ... gegeben.**“

③ SOLLENSANORDNUNG

 „Die **SOLLENSANORDNUNG** ist der **INHALT** der Norm, der **TEXT** des Gesetzes ist der **RECHTSSATZ** = **TRÄGER** der Rechtsnorm. Die Sollensanordnung kann ein **HANDLUNGSGEBOT**, ein **VERBOT** oder eine **ERLAUBNIS** sein.“

Norm	Sollensanordnung
§ 223 StGB	„ Verletze keinen Menschen! “
Art. 6 Abs. (1) DSGVO	„ Verarbeite keine personenbezogenen Daten, außer, Du hast einen gesetzlich anerkannten Grund, der dies rechtfertigt (= VERBOT). “

④ RECHTSFOLGENANORDNUNG

„**JEDE Rechtsnorm enthält eine Rechtsfolgenanordnung.**“

Norm	Rechtsfolge
§ 223 StGB	„ wird mit FREIHEITSSTRAFE bis zu fünf Jahren oder mit GELDSTRAFE bestraft “
Art. 6 Abs. (1) S. 1 lit. a) DSGVO	„ Die Verarbeitung IST RECHTMÄSSIG (also erlaubt), wenn ihr eine Einwilligung zugrunde liegt.“

4. ★★ Gesetze mit „versteckten“ Sollensanordnungen

„Die MEISTEN Rechtsnormen sind nach dem »WENN-DANN-SCHEMA« aufgebaut. Einige Gesetzestexte sind aber so formuliert, dass die darin enthaltenen Gebote erst aus ihnen »HERAUSGELESEN« werden müssen.“

 **Beispiel Art. 1 Absatz (1) Satz 1 GG:** „Die Würde des Menschen ist unantastbar.“ → Übersetzt in die Sprache von Ge- und Verboten: „JEDERMANN, VOR ALLEM STAATLICHEN INSTANZEN, IST ES VERBOTEN, DIE MENSCHENWÜRDE ANZUTASTEN!“

5. ★★★ Vollständige und unvollständige Rechtssätze

	Definition
VOLLSTÄNDIGER Rechtssatz	„Ein Rechtssatz, der ALLE VIER Merkmale einer Rechtsnorm enthält.“ (z.B. § 223 StGB)
UNVOLLSTÄNDIGER Rechtssatz	„Gesetzliche Regelungen, die ÜBERHAUPT KEINE RECHTSFOLGE anordnen, auch nicht »versteckt«. Dies sind HILFSREGELUNGEN, die andere Rechtssätze ERGÄNZEN oder PRÄZISIEREN.“

 ★ **Das Bild des Skriptums:** „WIE EINE ZULIEFERFIRMA liefern sie einzelne Merkmale bzw. Bestandteile, aus denen der Hersteller das ENDPRODUKT fertigt — hier: die VOLLSTÄNDIGE RECHTSNORM.“

★★★ Definitionsnormen

„Wichtige Hilfsregelungen sind zum Beispiel sogenannte »DEFINITIONSNORMEN«. Sie sind im DATENSCHUTZRECHT BESONDERS VERBREITET.“ — „Definitionsnormen ziehen wichtige Definitionen in einem Gesetz »VOR DIE KLAMMER«.“

Das Zusammenspiel von Art. 6 und Art. 4 DSGVO:

Art. 6 DSGVO:

„Die VERARBEITUNG ist nur rechtmäßig, wenn mindestens eine der nachstehenden Bedingungen erfüllt ist: (...)“

|

▼ Was ist „Verarbeitung“?

Art. 4 Nr. 2 DSGVO:

„Im Sinne dieser Verordnung bezeichnet der Ausdruck VERARBEITUNG jeden mit oder ohne Hilfe automatisierter Verfahren ausgeführten Vorgang (...) im Zusammenhang mit personenbezogenen Daten.“

★★ Die praktische Tragweite der Definition „Verarbeitung“:

- **Art. 12 DSGVO (Information von Betroffenen):** „Wer keine Daten verarbeitet, muss auch nicht informieren.“
- **Art. 28 DSGVO (Auftragsverarbeitung):** „Wenn keine Verarbeitung vorliegt, muss auch keine Vereinbarung zur Auftragsverarbeitung abgeschlossen werden.“
- **Art. 37 DSGVO (Datenschutzbeauftragter):** „Wer keine Daten verarbeitet, muss auch keinen betrieblichen Datenschutzbeauftragten bestellen.“

6. ★★ Aufbau, Gliederung und Zitieren von Gesetzen

6.1 Allgemeiner und Besonderer Teil

StGB: „Der ALLGEMEINE TEIL zieht Regelungen »VOR DIE KLAMMER«, die für ALLE Straftatbestände gelten" (z.B. „keine Strafe ohne Gesetz", „zeitliche Geltung"). „Im BESONDEREN TEIL sind einzelne Straftatbestände enthalten" (z.B. Hochverrat § 81 StGB, Körperverletzung § 223 StGB).

DSGVO — vergleichbar aufgebaut: „Im Kapitel 1 sind »ALLGEMEINE BESTIMMUNGEN« enthalten, die für ALLE Regelungen in der DSGVO gelten, zum Beispiel die BEGRIFFSBESTIMMUNGEN (Definitionen) in Art. 4 DSGVO."

6.2 ★★★ Die ERWÄGUNGSGRÜNDE der DSGVO

„Eine BESONDERHEIT der DSGVO ist, dass dem Gesetz 173 (!) ERWÄGUNGSGRÜNDE VORANGESTELLT sind." ★★ „Die Erwägungsgründe enthalten KEINE RECHTSFOLGEN und KEINE »SOLLENSANORDNUNGEN«; der Gesetzgeber hat sie dennoch formuliert, DAMIT SIE FÜR DIE AUSLEGUNG der einzelnen Rechtsnormen der DSGVO BEACHTET werden. Sie sind z.B. relevant, wenn bei der Beurteilung der Zulässigkeit einer (Daten-)Verarbeitung EINZELNE INTERESSEN GEGENEINANDER ABGEWOGEN werden müssen."

6.3 ★★ Zitierweise (Klausur-Handwerkszeug!)

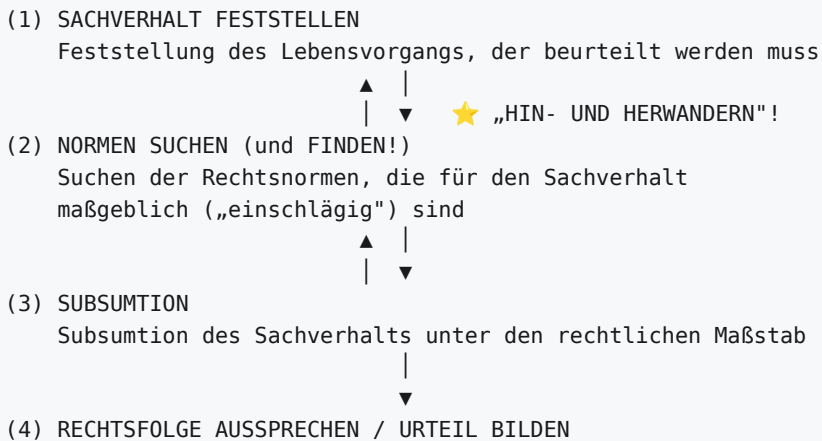
„Die einzelnen Vorschriften in den Gesetzen sind meist als PARAGRAFEN (§) oder ARTIKEL (»Art.«) bezeichnet. Diese sind wiederum unterteilt in ABSÄTZE, SÄTZE und teilweise SATZTEILE."

Zitierweise	Beispiel
Ausführlich	„Art. 2 Absatz (2) lit. a) DSGVO" · „Art. 2 Absatz (3) Satz 1 DSGVO"
Kurzschreibweise (<i>Absätze römisch, Sätze arabisch</i>)	„Art. 2 III S. 1 DSGVO" · noch kürzer: „Art. 2 III 1 DSGVO"

TEIL 1B — WIE „FUNKTIONIERT" EIN GESETZ? (Die Subsumtion)

7. ★★★ DIE 4 ARBEITSSCHRITTE DER RECHTSANWENDUNG (auswendig!)

„Juristische Arbeit ist immer dann gefragt, wenn es darum geht, einen KONKRETEN LEBENSVORGANG RECHTLICH ZU BEWERTEN. Um zu dieser Bewertung (»Urteil«) zu kommen, unternehmen die Juristen IMMER DIESELBEN SCHRITTE:"



★ „JEDER Arbeitsschritt ist GESONDERT auszuführen; gleichwohl kann bzw. MUSS zwischen den einzelnen Schritten »HIN- UND HERGEWANDERT« werden.“ (Engisch)

8. 📝★★★★ BEISPIEL 1: Die Körperverletzung („mechanische Unterhaltung“)

Sachverhalt: „A kommt zur Polizeidienststelle und krümmt sich den Magen. Er hat eine **gelbe Hose** an, **grüne Turnschuhe**, trägt einen **Bart** und **blutet äußerlich am Bauch**. Er berichtet dem Polizeimeister P, B habe ihn in den Magen geschlagen.“ **Frage:** Welche Umstände sind für die Frage relevant, ob P ein Strafverfahren gegen B einleiten muss?

✅ Schritt 1: Sachverhalt feststellen

Die IRRELEVANTEN Umstände werden gestrichen: ~~gelbe Hose~~ · ~~grüne Turnschuhe~~ · ~~Bart~~
RELEVANT: A krümmt sich den Magen · blutet am Bauch · B habe ihn in den Magen geschlagen

✅ Schritt 2: Normen suchen

💡 „Bei der NORMENSUCHE hilft oft ein Blick in das INHALTSVERZEICHNIS des Gesetzes!“

- § 223 StGB (Körperverletzung) — einschlägig
- § 224 StGB (gefährliche Körperverletzung) — „liegt vor, wenn die Körperverletzung mittels einer WAFFE oder einem anderen GEFÄHRLICHEN WERKZEUG begangen wurde“ ⚠️ „A blutet aus dem Bauch. Ein einfacher Faustschlag in die Magengrube ruft KEINE ÄUSSERLICHEN BLUTUNGEN hervor. Es drängt sich also die Frage auf, ob B ein gefährliches Werkzeug verwendet hat.“

✓ ZURÜCK zu Schritt 1 (das „Hin- und Herwandern“!)

„P fragt A, ob B mit der bloßen Faust oder einem Werkzeug zugeschlagen hat.“ **Antwort:** „B habe NUR MIT DER FAUST geschlagen. Die offene Wunde am Bauch habe A sich wie folgt zugezogen: B betreibt ein Gasthaus mit einem UMZÄUNTEN BIERGARTEN. Nachdem B den A geschlagen habe, wollte A sich rächen und gehen, ohne zu bezahlen. Dabei BLIEB A AM ZAUN HÄNGEN, was die offene Wunde am Bauch verursacht habe.“

✓ WIEDER zu Schritt 2

„§ 224 StGB ist NICHT einschlägig, weil B den Schlag mit der Faust ausgeführt und kein gefährliches Werkzeug verwendet hat. ES BLEIBT BEI § 223 StGB.“

✓ Schritt 3 + 4

Subsumtion: Ein Schlag in die Magengrube ist eine „körperliche Misshandlung“ und somit eine Körperverletzung. **Urteil:** „Wenn der Sachverhalt zutrifft, liegt eine Körperverletzung vor und B ist gemäß § 223 Abs. (1) StGB mit Freiheitsstrafe oder Geldstrafe zu bestrafen.“ ⚠ „Sofern A dies BEANTRAGT (die Körperverletzung gemäß § 223 StGB ist NUR AUF ANTRAG des Verletzten zu verfolgen, siehe § 230 StGB), muss P ein strafrechtliches Ermittlungsverfahren einleiten.“

9. 📝★★★★ BEISPIEL 2: Die datenschutzgerechte Datenverarbeitung

Sachverhalt: „Sie betreiben ein Softwareunternehmen und haben verschiedenen Kunden zu verschiedenen Preisen angeboten, Computerprogramme zu schreiben.“ **Frage:** „Dürfen Sie Ihre Angebote auf Ihrem IT-System SPEICHERN, ohne dass es hierfür eine Rechtfertigung nach der DSGVO gibt?“

✓ Schritt 2: Normensuche

- **Art. 2 Absatz (1) DSGVO:** Die DSGVO ist nur anwendbar für die Verarbeitung „personenbezogener Daten“
- **Art. 4 Nr. 1 DSGVO:** Definition „personenbezogene Daten“
- **Art. 4 Nr. 2 DSGVO:** Definition „Verarbeitung“
- **Art. 6 DSGVO:** Verbot der Datenverarbeitung mit Erlaubnisvorbehalt

✓ Die Prüfkette

Art. 6 DSGVO gilt nur, wenn eine „Verarbeitung“ vorliegt

↓

Art. 4 Nr. 2 DSGVO nennt die SPEICHERUNG ausdrücklich als Verarbeitung ✓

↓

ABER: „Verarbeitung“ geht immer um PERSONENBEZOGENE DATEN

↓

Art. 4 Nr. 1 DSGVO: „alle Informationen, die sich auf NATÜRLICHE PERSONEN beziehen“

★★ **DIE MERKFORMEL DES SKRIPTUMS:** „NATÜRLICHE PERSONEN sind LEBENDE Personen. Man kann sie ANFASSEN. Sie bestehen quasi »AUS FLEISCH UND BLUT«. NICHT ERFASST sind die Daten JURISTISCHER Personen (GmbH, Aktiengesellschaften, eingetragene Vereine, die kraft Gesetzes selbst Träger von Rechten und Pflichten sein können).“

✓ Zurück zu Schritt 1 → Schritt 3 → Schritt 4

Annahme: Es sind nur Daten von **GmbHs** enthalten. **Subsumtion:** „Gemäß Art. 2 Abs. (1) DSGVO gilt die DSGVO nur für die Verarbeitung personenbezogener Daten. In den Angeboten sind nur Daten zu GmbHs enthalten. Dies sind KEINE personenbezogenen Daten.“ ✓ **Ergebnis:** „Folglich ist die DSGVO NICHT ANWENDBAR. Es ist KEINE Rechtfertigung nach der DSGVO zur Speicherung der Angebote notwendig.“

10. ★★★ Tatbestand und Tatbestandsmerkmale (TBM)

„Unter der SUBSUMTION verstehen die Juristen die PRÜFUNG, OB EIN FESTGESTELLTER SACHVERHALT DIE VORAUSSETZUNGEN BZW. BEDINGUNGEN EINES RECHTSSATZES ERFÜLLT. Diese Voraussetzungen bzw. Bedingungen nennt man »TATBESTAND«.“ ★ „Die Tatbestände der meisten Gesetze bestehen NICHT NUR AUS EINER BEDINGUNG, sondern setzen MEHRERE Bedingungen voraus. In diesem Fall besteht der Tatbestand eines Gesetzes aus mehreren TATBESTANDSMERKMALEN (kurz: TBM).“

! ★★★ DIE GOLDENE REGEL

„OHNE FESTSTELLUNG DES SACHVERHALTS KEINE RECHTSANWENDUNG! URTEILEN SIE NICHT, BEVOR SIE DEN SACHVERHALT NICHT KENNEN!“

✎ TBM-Analyse a) § 223 Absatz (1) StGB

„Wer eine andere Person körperlich misshandelt oder an der Gesundheit schädigt, wird mit Freiheitsstrafe bis zu fünf Jahren oder mit Geldstrafe bestraft.“

TBM	Text	Bedeutung
TBM 1	„Wer“	Es muss ein TÄTER gehandelt haben.
TBM 2	„eine andere Person“	Tatobjekt bzw. Geschädigter kann nur EIN ANDERER MENSCH sein.
TBM 3	„körperlich misshandelt ODER an der Gesundheit schädigt“	★ »ODER-VERKNÜPFUNG« — es muss nur ENTWEDER eine »körperliche Misshandlung« ODER eine »Gesundheitsschädigung« vorliegen (TBM 3.1 / TBM 3.2).
TBM 4	KAUSALITÄT	„Bei sogenannten »ERFOLGSDELIKTEN« gilt: Es muss eine HANDLUNG des Täters festgestellt worden sein, mit der er die Körperverletzung SCHULDHAFT VERURSACHT hat.“

TBM-Analyse b) Art. 7 Absatz (1) DSGVO

„**Beruh** die **Verarbeitung** auf einer **Einwilligung**, muss der Verantwortliche nachweisen können, dass die betroffene Person in die Verarbeitung ihrer personenbezogenen Daten eingewilligt hat.“

TBM	Text	Bedeutung
TBM 1	„die Verarbeitung“	Es muss eine Verarbeitung personenbezogener Daten vorliegen.
TBM 2	„Einwilligung“	Es gibt eine Einwilligung des Betroffenen, die die Verarbeitung rechtfertigen könnte.
TBM 3	„Beruh“	Der Verantwortliche BERUFT SICH auf die Einwilligung zur Rechtfertigung der Datenverarbeitung.

Rechtsfolge: „Der Verantwortliche muss die Einwilligung **NACHWEISEN** können.“

11. ★★★★★ DIE METHODE DES SUBSUMIERENS: Obersatz — Untersatz — Schlusssatz

„Die Subsumtion besteht aus **DREI TEIL-SCHRITTEN**:“

- ① **OBERSATZ** (Teil-Schritt 1) → die abstrakte Rechtsregel
- ② **UNTERSATZ** (Teil-Schritt 2) → der konkrete Sachverhalt
- ③ **SCHLUSSSATZ** / „CONCLUSIO“ (Teil-Schritt 3) → das Ergebnis

★ „Für **JEDES EINZELNE** Tatbestandsmerkmal muss geprüft werden, ob der festgestellte Sachverhalt das Merkmal erfüllt.“

★★★★ Die vollständige Musterlösung zu § 223 StGB (AUSWENDIG!)

GESAMT-OBERSATZ:

- B ist strafbar gemäß § 223 StGB, wenn
- er als Täter (TBM 1)
 - eine andere Person (TBM 2)
 - körperlich misshandelt hat (TBM 3).

Die einzelnen TBM sind sodann wie folgt zu prüfen:

- TBM 1: „Wer“
 - Obersatz: Ein Täter muss gehandelt haben.
 - Untersatz: B hat gehandelt, indem er A in den Magen geschlagen hat.
 - Schlusssatz: B ist der Täter, dessen Handlung strafrechtlich geprüft werden muss.
- TBM 2: „eine andere Person“
 - Obersatz: Die Körperverletzung ist nur strafbar, wenn „eine andere Person“ geschädigt ist, das heißt, ein Mensch.
 - Untersatz: A ist eine andere Person.
 - Schlusssatz: A ist Opfer einer möglichen Körperverletzung.
- TBM 3: „körperlich misshandelt“
 - Obersatz: Eine körperliche Misshandlung ist JEDE ÜBLE, UNANGEMESSENE BEHANDLUNG, DIE DAS KÖRPERLICHE WOHLBEFINDEN MEHR ALS NUR UNERHEBLICH BEEINTRÄCHTIGT. (BGH NJW 1995, 2643)
 - Untersatz: Der Schlag in die Magengrube beeinträchtigt das körperliche Wohlbefinden des A erheblich.
 - Schlusssatz: Es liegt eine körperliche Misshandlung des A vor.

GESAMT-SCHLUSSSATZ:

B ist gemäß § 223 Absatz (1) StGB mit einer Freiheits- oder Geldstrafe zu bestrafen.

★★★★ **Die Verschachtelung:** „Für die GESAMT-Prüfung stellen die roten Texte den OBER- bzw. SCHLUSSSATZ dar; die blauen Texte bilden in Bezug auf die Gesamtprüfung den UNTERSATZ.“

12. ★★★★ Subsumtion in der Sprache der Informatik (die Lieblingsfolie des Skripts!)

```

if (Täter hat gehandelt) and
  (eine andere Person) and
  ( (körperlich misshandelt) or
    (an der Gesundheit schädigt)
  )
then
{
  Geld_oder_Freiheitsstrafe(Täter);
}
  
```

Oder, noch „informatischer“:

```

if ( exists Täter ) && ( exists Opfer ) &&
  ( Täter.is_human ) && ( Opfer.is_human ) &&
  ( Täter != Opfer ) &&
  ( Täter == Handelnder ) &&
  ( koerperlich_misshandelt(Opfer,Tat) || gesundheit_geschädigt(Opfer,Tat) )
then
  { punish(Täter, Geld_oder_Freiheit);
  }

```

Dabei wären `koerperlich_misshandelt`, `gesundheit_geschädigt`, `punish` und `is_human` jeweils „FUNKTIONEN“. Die ersten beiden liefern „wahr“ zurück, wenn das Opfer durch die Tat den entsprechenden Schaden hat, und `punish` bestimmt dann die Strafe für den Täter. `is_human` liefert wahr, wenn das als Parameter übergebene Objekt ein Mensch ist.

TEIL 1C — RECHTSQUELLEN UND RANGFOLGE

13. ★★ Begriff der Rechtsquelle

Begriff	Definition
RECHTSNORM	bestimmt den INHALT einer Regelung
RECHTSQUELLE	★ „die FORM, in der die Rechtsnorm ENTSTANDEN ist (»Quelle«) und IN ERSCHEINUNG TRITT“

 **Beispiele:** a) Die Norm „Du sollst keine andere Person verletzen!“ → **Rechtsquelle ist das StGB als FORMELLES Gesetz** b) Die Norm „maximal 50 km/h innerhalb geschlossener Ortschaften“ (§ 3 Abs. (3) Nr. 1 StVO) → **Rechtsquelle ist die StVO (Rechtsverordnung)**

Aufgabe der Rechtsquellenlehre: „die verschiedenen Rechtsquellen zu ORDNEN und zu SYSTEMATISIEREN. Durch die Systematisierung wurde eine RANGORDNUNG herausgearbeitet.“

★ Das Praxisbeispiel Vorratsdatenspeicherung

„§ 176 Telekommunikationsgesetz verpflichtet die Telekommunikationsanbieter, die Verbindungsdaten der Kommunikationsteilnehmer »AUF VORRAT« zu speichern. Diese Regelung VERLETZT nach Auffassung des BUNDESVERWALTUNGSGERICHTS die GRUNDRECHTE der Betroffenen. Deshalb hat die BUNDESNETZAGENTUR die Anwendung der Regelung AUSGESETZT. Denn DIE GRUNDRECHTE GEHEN DEM TELEKOMMUNIKATIONSGESETZ VOR.“
(BVerwG, Urteil vom 14.08.2023 – 6 C 6/22)

14. ★★☆☆ DIE RANGFOLGE DER RECHTSQUELLEN: „OBER STICHT UNTER“

Die Rangfolge ergibt sich aus:

1. dem „ANWENDUNGSVORRANG“ von EU-Recht vor dem nationalen Recht
2. der Regelung in Art. 31 GG: „BUNDESRECHT BRICHT LANDESRECHT“
3. dem allgemeinen Grundsatz, dass das Recht des HÖHEREN Ranges das Recht des UNTEREN Ranges VERDRÄNGT

🔑 „KURZ GESAGT, GILT FÜR DIE RANGFOLGE DER RECHTSNORMEN: »OBER STICHT UNTER«.“

1. EU-RECHT
2. GRUNDGESETZ
3. Allgemeine Regeln des VÖLKERRECHTS (Art. 25 GG)
4. BUNDESGESETZE (vom Bundestag beschlossen, ggf. mit Bundesrat)
5. Rechtsverordnungen und Satzungen von Körperschaften des Bundes
6. VERFASSUNGEN DER BUNDESLÄNDER
7. LANDESGESETZE (von den Landtagen beschlossen)
8. Rechtsverordnungen der Länder und Satzungen von Körperschaften der Länder
9. Kollektive Normen des ARBEITSRECHTS

TEIL 2A — RECHTSQUELLEN DES DATENSCHUTZES

„Die Rechtsquellen des Datenschutzes werden entsprechend ihrer Rangfolge (»von oben nach unten«) vorgestellt:" ① Unionsgrundrechte · ② Verordnungen und Richtlinien im EU-Sekundärrecht · ③ Grundrechte nach dem deutschen GG · ④ Bundesdatenschutzgesetz · ⑤ Spezialgesetze in Deutschland; Landesdatenschutzgesetze

15. ★★★★★ Was sind Grundrechte? — Die 4 zentralen Merkmale

„Bislang gibt es KEINE ALLGEMEINGÜLTIGE DEFINITION von Grundrechten. Jedenfalls werden ihnen folgende zentrale Merkmale zugeordnet:“

#	Merkmal	Erläuterung
1	FUNDAMENTAL	Grundrechte sind (grundlegende) RECHTSPOSITIONEN.
2	INDIVIDUELL	Sie gelten zugunsten EINZELNER PERSONEN.
3	VERFASSUNGSMÄSSIG (mindestens)	Sie sind entweder auf der HÖCHSTEN INNERSTAATLICHEN NORMSTUFE verbürgt (der Verfassung) oder gelten kraft INTERNATIONALEM RECHT (EMRK, EUV, EU-Grundrechtecharta oder Grundgesetz).
4	BINDEND FÜR DIE STAATLICHE GEWALT	„Grundrechte verpflichten IN ERSTER LINIE DEN STAAT. Ohne verfassungsmäßige Rechtfertigung dürfen sie nicht beeinträchtigt werden.“

Historisch: „Konkrete Ausformungen haben die Grundrechte in den NORDAMERIKANISCHEN UND FRANZÖSISCHEN REVOLUTIONEN erfahren: Recht auf Freiheit und Gleichheit, Schutz des Eigentums, Religions- und Meinungsfreiheit.“

16. ★★★★★ Unmittelbare vs. mittelbare Grundrechtsbindung

	STAAT	PRIVATE
Wirkung	UNMITTELBARE Wirkung der Grundrechte	★ „MITTELBARE DRITTWIRKUNG“ — „indem sie bei der ANWENDUNG UND AUSLEGUNG NACHRANGIGER RECHTSNORMEN zu beachten sind“
Rechtsgrundlage	Art. 51 GRC (Unionsgrundrechte) · Art. 1 Abs. (3) GG	

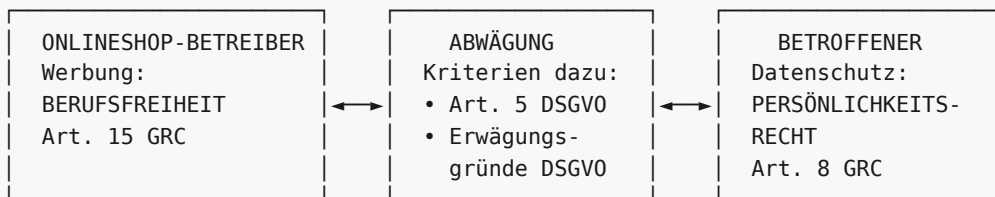
 **Beispiel a) — unmittelbar:** „Ein Polizist kontrolliert die Identität einer Person anhand ihres Ausweises. Der Polizist ist dabei gemäß Art. 1 Abs. (3) GG UNMITTELBAR an das Grundrecht der kontrollierten Person gebunden und muss für diesen Eingriff eine Rechtfertigung haben, die der Verfassung standhält.“

 **Beispiel b) — mittelbar (Parabolantenne):** „Der Mieter darf gegen den Willen des Vermieters keine Parabolantenne anbringen. Hier stehen sich das EIGENTUMSRECHT des Vermieters (Art. 14 GG) und die INFORMATIONSFREIHEIT des Mieters (Art. 5 GG) gegenüber. Das Gericht hat ein solches Recht ABGELEHNT, weil der Mieter mithilfe des INTERNETS andere Informationsquellen nutzen kann, die im Gegensatz zur Antenne KEINE BOHRLÖCHER im Dach hinterlassen.“ (AG Frankfurt a.M., 15.09.2015 – 33 C 482/15)

★★★★ Die Anwendung im Datenschutz

- **Staat (Behörden) verarbeitet Daten** ⇒ UNMITTELBAR grundrechtsgebunden
- **Nicht-staatliche Stellen (Unternehmen)** ⇒ MITTELBAR — „Im Anwendungsbereich der DSGVO gibt es viele Vorschriften, die ABWÄGUNGEN der betroffenen Interessen erfordern, zum Beispiel Art. 6 DSGVO. In diese Abwägung sind die WIDERSTREITENDEN GRUNDRECHTLICHEN POSITIONEN einzubeziehen.“

★★★★★ Musterschaubild: Interessenabwägung bei Werbung (Art. 6 Abs. (1) S. 1 lit. f) DSGVO)



★★★★★ **DIE ABWÄGUNGSREGEL:** „JE TRANSPARENTER die Verarbeitung für die Betroffenen ist und JE MEHR ENTSCHEIDUNGS- UND EINFLUSSMÖGLICHKEITEN diese haben, UM SO SCHWERER WIEGT DAS RECHT DES SHOP-BETREIBERS. JE UNDURCHSICHTIGER die Datenverarbeitung ist und je weniger Entscheidungsmöglichkeiten sie dem Betroffenen lässt, DESTO EHER ÜBERWIEGT DAS PERSÖNLICHKEITSRECHT DER BETROFFENEN.“

⚠ „Die Datenschutzbehörden halten es deshalb für UNZULÄSSIG, im Rahmen eines BEHAVIORAL TARGETING personenbezogene Daten insbesondere in großer Zahl und aus verschiedenen Quellen zu einer PROFILBILDUNG (PROFILING) heranzuziehen, um ein mögliches Kaufinteresse des Betroffenen vorauszusagen bzw. durch zielgerichtete Werbung zu wecken.“
(Kurzpapier Nr. 13 der Deutschen Datenschutzkonferenz)

17. ★★★★★ Was haben Grundrechte mit Datenschutz zu tun?

„Der Schutz personenbezogener Daten ist KEIN SELBSTZWECK. Es besteht ein Zusammenhang zwischen dem Recht, »eine eigenständige Persönlichkeit zu entwerfen, zu leben und weiterzuentwickeln — kurz: EINE PERSÖNLICHKEIT ZU SEIN« (dem sogenannten »PERSÖNLICHKEITSRECHT«) und dem Umstand, WER WELCHE INFORMATIONEN zu dieser Persönlichkeit verfügt und darüber bestimmen kann.“

🔑★★★★★ DER KERNSATZ

„WER ÜBER MEINE DATEN VERFÜGT, VERFÜGT ÜBER MEINE PERSÖNLICHKEIT (zumindest teil- bzw. bereichsweise).“

★★★★ DAS VOLKSZÄHLUNGURTEIL (BVerfGE 65, 1 — 15.12.1983)

Der Fall: „Das Gericht hatte zu prüfen, ob Daten aus der (MANUELLEN!) Volkszählung — OHNE NAMEN — zum Zwecke der Regionalplanung, des Vermessungswesens, der gemeindlichen Planung und des Umweltschutzes an die Gemeinden weitergegeben werden dürfen. Das Urteil stellte darin einen VERSTOSS GEGEN DAS PERSÖNLICHKEITSRECHT fest.“

★★★★ **DER ORIGINALWORTLAUT (KLAUSURZITAT!):** „Freie Entfaltung der Persönlichkeit setzt unter den modernen Bedingungen der Datenverarbeitung den Schutz des Einzelnen gegen unbegrenzte Erhebung, Speicherung, Verwendung und Weitergabe seiner persönlichen Daten voraus. Dieser Schutz ist daher von dem Grundrecht des Art. 2 Abs. 1 in Verbindung mit Art. 1 Abs. 1 GG umfaßt. Das Grundrecht gewährleistet insoweit **DIE BEFUGNIS DES EINZELNEN, GRUNDSÄTZLICH SELBST ÜBER DIE PREISGABE UND VERWENDUNG SEINER PERSÖNLICHEN DATEN ZU BESTIMMEN.**“

! MERKE

„Das Grundrecht auf die freie Entfaltung seiner Persönlichkeit gewährleistet die **BEFUGNIS DES EINZELNEN, GRUNDSÄTZLICH SELBST ÜBER DIE PREISGABE UND VERWENDUNG SEINER PERSÖNLICHEN DATEN ZU BESTIMMEN (RECHT AUF INFORMATIONELLE SELBSTBESTIMMUNG, Art. 2 Absatz (1) i.V.m. Art. 1 Absatz (1) GG).**“

★★ Die wegweisenden BVerfG-Entscheidungen von Hans-Jürgen Papier

Entscheidung	Datum	Inhalt
Vorratsdatenspeicherung	02.03. 2010	„Die ANLASSLOSE Speicherung von Verkehrsdaten (§ 96 TKG a.F.: Anschlussnummer, Beginn und Ende der Verbindung) VERSTÖSST GEGEN DIE GRUNDRECHTE und ist UNZULÄSSIG.“
★★★★ „IT-GRUNDRECHT“	27.02. 2008	„Der IT-Nutzer hat ein RECHT AUF VERTRAULICHKEIT UND INTEGRITÄT SEINER INFORMATIONSTECHNISCHEN SYSTEME.“ (BVerfGE 120, 274)

18. ★★★★★ DIE 3-SCHRITT-PRÜFUNG VON GRUNDRECHTSVERLETZUNGEN

„Ob die Grundrechte beim Erlass oder der Ausführung von Gesetzen im konkreten Fall gewahrt oder verletzt wurden, wird durch die folgenden **DREI FRAGEN** geprüft:“

- (1) SCHUTZBEREICH: Ist der zu beurteilende Lebenssachverhalt vom SCHUTZBEREICH des Grundrechts erfasst?
- (2) EINGRIFF: Liegt ein EINGRIFF in den Schutzbereich vor?
- (3) RECHTFERTIGUNG: Liegt eine VERFASSUNGSMÄSSIGE RECHTFERTIGUNG für den Eingriff vor?

★ „Diese 3 Prüfungsschritte gelten **GRUNDSÄTZLICH FÜR ALLE FREIHEITSGRUNDRECHTE** und unabhängig davon, ob diese in der UN-MENSCHENRECHTSCHARTA, der EMRK, den VERTRÄGEN DER EU oder dem GRUNDGESETZ geregelt sind.“ ⚠ „...wobei JEDE EINZELNE FRAGE durch die METHODE DER SUBSUMTION zu beantworten ist.“

★★★★ Die Prüfpunkte der verfassungsmäßigen Rechtfertigung

- ① Gibt es ein GESETZ, das den Eingriff durch seinen Wortlaut rechtfertigt?
 - NEIN: Der Eingriff ist GRUNDRECHTSWIDRIG. Die Prüfung ist zu Ende.
 - JA: Ist das Gesetz selbst grundrechtskonform? Weiter mit ②
- ② Lässt der Text der Verfassung für das Grundrecht AUSDRÜCKLICH einen Eingriff zu („EINFACHER oder QUALIFIZIERTER GESETZESVORBEHALT“)? Oder (falls nein) greift das Gesetz UM ANDERER GRUNDRECHTE ODER VERFASSUNGSGÜTER WILLEN ein?
- ③ VERHÄLTNISSMÄSSIGKEITSPRÜFUNG:
 - Verfolgt das Gesetz einen LEGITIMEN ZWECK und ist es GEEIGNET · ERFORDERLICH · ANGEMESSEN, um diesen Zweck zu erreichen?

19. 📝★★★★ MUSTERFALL: EuGH „Volker und Markus Schecke“ (C-92/09, C-93/09)

Sachverhalt: „Volker Schecke und Markus Schecke erhalten für ihren landwirtschaftlichen Betrieb EU-SUBVENTIONEN. Aufgrund einer EU-Verordnung wird zur TRANSPARENZ der EU-Agrarförderung IM INTERNET veröffentlicht, in welchen Zeiträumen welche Empfänger welche Arten von Subventionen in welcher Höhe erhalten haben. Volker und Markus Schecke fühlen sich in ihren Grundrechten verletzt, da die Subventionen einen bzw. den wesentlichen Teil ihres Gesamteinkommens bilden und sich aufgrund der Veröffentlichung JEDERMANN EIN GENAUES BILD darüber verschaffen kann.“

✓ (1) SCHUTZBEREICH des Art. 8 GRC

Definition: „Der SCHUTZBEREICH ist der TATBESTAND eines Grundrechts. Dies ist der LEBENSBEREICH, den das jeweilige Grundrecht schützt. Wenn ein Verhalten einer Person unter den Schutzbereich subsumiert werden kann, ist es von dem entsprechenden Grundrecht geschützt.“

Art. 8 Absatz (1) GRC: „Jede Person hat das Recht auf Schutz der sie betreffenden personenbezogenen Daten.“

OBERSATZ: Der Schutzbereich des Art. 8 GRC ist eröffnet, wenn die Zuordnung der Subventionen zu den Namen „Volker und Markus Schecke“ PERSONENBEZOGENE DATEN sind. Personenbezogene Daten i.S.d. Art. 8 GRC sind ALLE INFORMATIONEN ÜBER EINE BESTIMMTE ODER BESTIMMBARE PERSON.

UNTERSATZ: Die Höhe der Subventionen sind Informationen über Volker und Markus Schecke und damit personenbezogene Daten.

SCHLUSSSATZ: Folglich ist der Schutzbereich des Art. 8 Absatz (1) GRC eröffnet.

✓ (2) EINGRIFF in Art. 8 GRC

Definition: „Ein GRUNDRECHTSEINGRIFF liegt vor, wenn dem Einzelnen ein Verhalten, das in den Schutzbereich fällt, DURCH DEN STAAT VERWEHRT wird.“ ★★ „Beim Recht auf Datenschutz geht es darum, dass GRUNDSÄTZLICH DER BETROFFENE BESTIMMT, wer welche personenbezogenen Daten über ihn verarbeitet. Deshalb ist JEDE VERARBEITUNG personenbezogener Daten durch grundrechtsgebundene Stellen EIN EINGRIFF in Art. 8 Absatz (1) GRC.“ ✓ Der EuGH hat den Eingriff BEJAHT.

✓ (3) RECHTFERTIGUNG — die EuGH-Prüfung

Prüfpunkt	Ergebnis
Gesetz vorhanden?	✓ „Die Veröffentlichung der Subventionsdaten beruht auf einer VERORDNUNG und somit auf einem Gesetz.“
Gesetzesvorbehalt?	✓ „Gemäß Art. 8 Absatz (2) Satz 1 GRC dürfen personenbezogene Daten AUFGRUND EINES GESETZES verarbeitet werden. Das Grundrecht des Art. 8 Abs. (1) GRC steht somit UNTER EINEM GESETZESVORBEHALT.“
Legitimer Zweck?	✓ „TRANSPARENZ über die Verwendung der finanziellen Mittel der EU.“
Geeignet?	✓ „Die Veröffentlichung der Daten im Internet ist hierfür auch geeignet.“
ERFORDERLICH?	✗ „SIE IST JEDOCH NICHT ERFORDERLICH. Denn die Transparenz kann nach Auffassung des EuGH auch durch Maßnahmen erreicht werden, die mit GERINGEREN GRUNDRECHTSEINGRIFFEN verbunden gewesen wären, und zwar einer EINGESCHRÄNKTEN NAMENTLICHEN NENNUNG. Auch wenn die Subventionsempfänger nicht namentlich benannt sind, hätten sich die EU-Bürger ein »HINREICHEND WIRKLICHKEITSGETREUES BILD« von der Verwendung der EU-Finzen machen können.“

✓ ERGEBNIS

„Deshalb ist die Veröffentlichung der Subventionsdaten von Volker und Markus Schecke im Internet UNVERHÄLTNISSMÄSSIG und GRUNDRECHTSWIDRIG. Volker und Markus Schecke sind in ihrem Grundrecht aus Art. 8 Absatz (1) GRC VERLETZT.“

20. ★★ Die datenschutzrelevanten Unionsgrundrechte

„Die Unionsgrundrechte sind geregelt in der GRUNDRECHTECHARTA (GRC) der Europäischen Union vom 07.12.2000. Seit dem VERTRAG VON LISSABON vom 19.10.2007 gilt die GRC UNMITTELBAR UND VERBINDLICH als EU-PRIMÄRRECHT (Art. 6 Abs. (1) EUV).“ Geltungsbereich (Art. 51 GRC): ① für die Organe und Einrichtungen der Union · ② für die EU-Mitgliedstaaten, bei der DURCHFÜHRUNG DES RECHTS DER UNION

Norm	Inhalt
★★★★ Art. 8 GRC	„Jede Person hat das Recht auf den SCHUTZ DER SIE BETREFFENDEN PERSONENBEZOGENEN DATEN. “ Geschützt: ① natürliche Personen („Menschen aus Fleisch und Blut“ — KEINE juristischen Personen) · ② personenbezogene Daten (alle Angaben über eine bestimmte oder bestimmbare Person)
Art. 8 Abs. (2) S. 1 GRC	★★★★ DER ERLAUBNISVORBEHALT: „Diese Daten dürfen NUR nach Treu und Glauben für festgelegte Zwecke und MIT EINWILLIGUNG der betroffenen Person ODER AUF EINER SONSTIGEN GESETZLICH GEREGLTEN LEGITIMEN GRUNDLAGE verarbeitet werden.“
Art. 16 Abs. (1) AEUV	wortidentisch mit Art. 8 Abs. (1) GRC. ⚠ „Der GESETZESVORBEHALT wurde jedoch in Art. 16 »VERGESSEN« (Redaktionsversehen), so dass hier Art. 8 Abs. (2) GRC entsprechend gilt.“
★★★★ Art. 7 GRC	„Jede Person hat das Recht auf ACHTUNG IHRES PRIVAT- UND FAMILIENLEBENS SOWIE IHRER KOMMUNIKATION. “ Verortet: der eigene Name · das Recht am eigenen Bild · die Ehre und der gute Ruf
Art. 8 EMRK i.V.m. Art. 6 Abs. (3) EUV	„Die EMRK gilt als unmittelbar anwendbares Primärrecht der EU. Art. 7 GRC ist der ÄLTEREN Bestimmung des Art. 8 EMRK NACHGEBILDET. “

★★★★ Die historische Begründung für Art. 7 GRC (Kommunikationsschutz)

„Eine geschützte **FERNKOMMUNIKATION** dient der **WÜRDE DES DENKENDEN UND FREIHEITLICH HANDELNDEN MENSCHEN. STAATSSYSTEME OHNE FREIHEITSRECHTE** (zum Beispiel **NATIONALSOZIALISMUS, DDR**) waren geprägt von einer **KONTROLLE DER FERNKOMMUNIKATION**. Die dabei gewonnenen Erkenntnisse wurden gezielt zur **BEGRENZUNG VON FREIHEITSRECHTEN** eingesetzt.“

🔑★★★★ DIE ZENTRALE NORM DES DATENSCHUTZRECHTS

„Art. 8 GRC ist somit ein Rechtssatz, der **DIE zentrale Norm im Datenschutzrecht** trägt: **DAS VERARBEITUNGSVERBOT MIT ERLAUBNISVORBEHALT.**“ Eine Datenverarbeitung ist somit nur gerechtfertigt, wenn ① entweder die betroffene Person **EINGEWILLIGT** hat ODER ② ein **GESETZ** die Verarbeitung **ERLAUBT**.

21. 📝★★★★ FALLSTUDIE VORRATSDATENSPEICHERUNG (EuGH C-793/19, C-794/19)

Worum geht es? „Die §§ 113b, 113c TKG (seit 01.12.2021: § 176 TKG) verpflichten Telekommunikationsanbieter (»Provider«), **VERKEHRSDATEN** ihrer Nutzer für die Dauer von **10 WOCHEN** zu speichern. Diese Daten dürfen an **POLIZEIBEHÖRDEN** zur Verfolgung **BESONDERS SCHWERER STRAFTATEN** oder zur Abwehr von Gefahren für Leib und Leben oder den Bestand der Bundesrepublik übermittelt werden.“ **Wer hat sich gewehrt?** „Die **DEUTSCHE TELEKOM GmbH** und ein weiterer Provider haben vor dem Verwaltungsgericht Köln geklagt. Über das Oberverwaltungs- und das Bundesverwaltungsgericht landete der Streit vor dem EuGH.“ ✓ **EuGH-Urteil vom 20.09.2022:** „Die §§ 113b und c TKG **VERSTOSSEN GEGEN EU-RECHT.**“

✓ Die EuGH-Prüfung im Detail

(1) **SCHUTZBEREICH (Art. 7 GRC), Rn 60/61:**

„Die Speicherung der Verkehrs- und Standortdaten als solche stellt einen EINGRIFF IN DIE GRUNDRECHTE auf Achtung des Privatlebens und auf den Schutz personenbezogener Daten dar; dabei SPIELT ES KEINE ROLLE, ob die betreffenden Informationen SENSIBLEN CHARAKTER haben und ob die Betroffenen durch diesen Eingriff NACHTEILE ERLITTEN haben oder ob die gespeicherten Daten in der Folge VERWENDET werden oder nicht.“

★★ „Aus der Gesamtheit dieser Daten können SEHR GENAUE SCHLÜSSE AUF DAS PRIVATLEBEN der Personen gezogen werden, etwa auf GEWOHNHEITEN DES TÄGLICHEN LEBENS, ständige oder vorübergehende AUFENTHALTSORTE, tägliche oder in anderem Rhythmus erfolgende ORTSVERÄNDERUNGEN, ausgeübte TÄTIGKEITEN, SOZIALE BEZIEHUNGEN und das SOZIALE UMFELD. Diese Daten ermöglichen insbesondere die ERSTELLUNG EINES PROFILS der Betroffenen, das im Hinblick auf das Recht auf Achtung des Privatlebens EINE EBENSO SENSIBLE INFORMATION DARSTELLT WIE DER INHALT DER KOMMUNIKATIONEN SELBST.“

(Sensible Informationen: **sexuelle Orientierung, politische Meinungen, religiöse, philosophische, gesellschaftliche oder andere Überzeugungen, Gesundheitszustand**)

(2) EINGRIFF, Rn 62:

„Die Vorratsspeicherung kann das in Art. 7 GRC verankerte Recht auf Achtung der Kommunikation beeinträchtigen und die Nutzer von der Ausübung ihrer durch **Art. 11 GRC** gewährleisteten **FREIHEIT DER MEINUNGSÄUSSERUNG ABHALTEN**; diese Wirkungen sind umso stärker, je größer die Menge und die Vielfalt der auf Vorrat gespeicherten Daten sind. Zum anderen birgt die bloße Vorratsspeicherung **GEFAHREN DES MISSBRAUCHS UND DES RECHTSWIDRIGEN ZUGANGS**.“

(3) FEHLENDE RECHTFERTIGUNG:

Art. 15 der ePrivacy-Richtlinie schreibt vor, dass der gesetzliche Eingriff nur zulässig ist, wenn er für die nationale Sicherheit oder zur Verhütung/Verfolgung von Straftaten **geeignet, erforderlich und angemessen** ist. ★ „Der Eingriff muss sich aber **»AUF DAS ABSOLUT NOTWENDIGE« BESCHRÄNKEN**.“ (Rn 67)

Die Anforderungen an nationale Gesetze (Rn 69): „Sie müssen **KLARE UND PRÄZISE REGELN** für die Tragweite und die Anwendung der betreffenden Maßnahme vorsehen und **MINDESTERFORDERNISSE** aufstellen, so dass die Personen über **AUSREICHENDE GARANTIE**n verfügen, die einen wirksamen Schutz dieser Daten vor **MISSBRAUCHSRISIKEN** ermöglichen.“

★★★★ Die Rechtsquellen-Lehre am Beispiel (KLAUSURSTRUKTUR!)

```

Art. 7 GRC                                     ← OBERSTE Rechtsquelle
| wird umgesetzt durch
▼
Art. 5, 15 ePrivacy-Richtlinie ← rangniedrigeres EU-Recht
| muss umgesetzt werden durch
▼
§§ 175-179 TKG (Deutschland) ← UNTERSTE Rechtsquelle
  
```

⚠ Da die §§ TKG die EU-Richtlinie NICHT EU-KONFORM umsetzen, sondern dagegen verstoßen, sind sie NICHT ANWENDBAR:

★ „OBER“ (ePrivacy-Richtlinie) STICHT „UNTER“ (deutsches TKG)!

BVerwG-Urteil vom 14.08.2023 – 6 C 6.22, Leitsatz 1: „Die in § 175 Abs. 1 Satz 1 i.V.m. § 176 TKG geregelte Verpflichtung der Anbieter ... zur Speicherung der Telekommunikations-Verkehrsdaten ist **IN VOLLEM UMFANG UNVEREINBAR** mit Art. 15 Abs. 1 der Richtlinie 2002/58/EG und daher **NICHT ANWENDBAR**.“

UPDATE (EuGH, 30.04.2024 – C-178/22)

„Der EuGH hat seine **STRENGE LINIE** zur Vorratsdatenspeicherung **ETWAS AUFGEWEICHT**. Im Fall ging es um die Vorratsdatenspeicherung von IP-ADRESSEN in Frankreich zur allgemeinen Kriminalitätsbekämpfung. Die IP-Adresse ist als »Verkehrsdatum« zwar von der ePrivacy-RL und Art. 7 GRC geschützt; allerdings **KANN EIN EINGRIFF ZUM ZWECK DER VERBRECHENSBEKÄMPFUNG GERECHTFERTIGT SEIN, WENN DIE GESETZLICHE REGELUNG DAZU SICHERSTELLT, DASS KEINE PROFILBILDUNG STATTFINDEN KANN.**“ Aktuelles Stichwort in Deutschland: „**QUICK FREEZE**“.

TEIL 2A — EU-SEKUNDÄRRECHT UND NATIONALE GESETZE

22. ★★★★★ **Verordnung vs. Richtlinie (DIE Grundunterscheidung!)**

	VERORDNUNG	RICHTLINIE
Rechtsgrundlage	Art. 288 Absatz (2) AEUV	Art. 288 Absatz (3) AEUV
Wirkung	★ „Gelten in ALLEN Mitgliedstaaten UNMITTELBAR UND VERBINDLICH.“	„Geben NUR DIE ZIELE innerhalb eines Regelungsbereichs vor.“
Umsetzung	KEINE Umsetzung nötig	★ „Sie benötigen in den Mitgliedstaaten in der Regel einen UMSETZUNGSAKT (zum Beispiel ein Gesetz).“
Nationale Regelungen	⚠ „Soweit in der Verordnung nicht ausdrücklich geregelt, sind nationale Regelungen (SOGAR GLEICHLAUTENDE) UNZULÄSSIG UND UNWIRKSAM.“	Der Umsetzungsakt gilt; er ist aber ★ RICHTLINIENKONFORM AUSZULEGEN.

★★★ **Für den Datenschutz bedeutet Art. 288 Abs. (2) AEUV:**

„Die DSGVO regelt den Datenschutz **UNMITTELBAR UND EINHEITLICH** für alle EU-Mitgliedstaaten. **NATIONALE VORSCHRIFTEN** im Anwendungsbereich der DSGVO sind **EUROPARECHTSWIDRIG** und dürfen **NICHT ANGEWENDET** werden (»ANWENDUNGSVORRANG« des EU-Rechts) — **SELBST DANN NICHT**, wenn sie keinen inhaltlichen Widerspruch zum EU-Recht enthalten oder **LEDIGLICH DEN WORTLAUT DER DSGVO WIEDERGEHEN**.“

23. ★★ Die vier EU-Regelungswerke des Datenschutzes

„Gemäß Art. 16 Absatz (2) AEUV sind die Organe der EU befugt, Vorschriften zu erlassen zum Schutz personenbezogener Daten.“

Regelwerk	Anwendungsbereich
★★★★ Datenschutz-Grundverordnung (DSGVO)	Die GRUNDNORMIERUNG für alle Vorgänge, bei denen personenbezogene Daten im Anwendungsbereich des EU-Rechts verarbeitet werden. Gilt für juristische Personen ÖFFENTLICHEN Rechts (Behörden, Körperschaften) und des PRIVATEN Rechts (Unternehmen). ★ „VOLLHARMONISIERUNG des Datenschutzrechts“
Verordnung (EU) 2018/1725	Datenschutz bei der Verarbeitung durch die EUROPÄISCHEN ORGANE (z.B. EU-Kommission, EU-Agenturen)
Richtlinie (EU) 2016/680 („JI-RICHTLINIE“ — Justiz und Inneres)	Datenverarbeitung zur VERHÜTUNG UND VERFOLGUNG VON STRAFTATEN und im Interesse der ÖFFENTLICHEN SICHERHEIT. Umsetzung in DE: Strafprozessordnung + §§ 45 ff. BDSG. ⚠ „Die Datenverarbeitung im Interesse der NATIONALEN SICHERHEIT, vor allem durch VERTEIDIGUNG und NACHRICHTENDIENSTE, ist von der JI-Richtlinie NICHT erfasst.“
Richtlinie 2002/58/EG („e-PRIVACY-RICHTLINIE“)	Datenschutz in der ELEKTRONISCHEN KOMMUNIKATION. Betroffen: Telekommunikationsdienstleister (Internet-Zugangsprovider, Anbieter von Sprachkommunikationsdiensten). Umsetzung in DE: TDDDG

★★★★ Die e-Privacy-Richtlinie im Detail

Norm	Inhalt
Art. 5 Abs. (1) e-Privacy-RL	★ TELEKOMMUNIKATIONSGEHEIMNIS: „Die Mitgliedstaaten müssen die VERTRAULICHKEIT der mit öffentlichen Kommunikationsnetzen übertragenen NACHRICHTEN und der damit verbundenen VERKEHRSDATEN durch nationale Regelungen sicherstellen.“ → „Bei einer elektronischen Kommunikation dürfen NUR ABSENDER UND EMPFÄNGER DEN INHALT DER NACHRICHT KENNEN.“
★★★★ Art. 5 Abs. (3) e-Privacy-RL	SCHUTZ DER ENDEINRICHTUNGEN (→ COOKIES!): „Auf Informationen auf dem ENDGERÄT eines Nutzers darf NUR MIT SEINER EINWILLIGUNG zugegriffen werden ODER wenn dies UNBEDINGT ERFORDERLICH ist, damit der Anbieter eines vom Nutzer AUSDRÜCKLICH GEWÜNSCHTEN Dienstes diesen zur Verfügung stellen kann.“

⚠ ★ Die „Cookie-RL“-Klarstellung (Klausurfalle!)

„Diese Regelung betrifft zum Beispiel sogenannte »COOKIES«, weshalb die e-Privacy-RL bisweilen auch als »COOKIE-RL« bezeichnet wird. RICHTIG IST INDES: Der Name »Cookie-RL« betrifft die RL 2009/136/EG, welche die bisherige ePrivacy-RL 2002/58/EG um den noch immer geltenden Art. 5 Abs. (3) ERGÄNZT hat. Die »Cookie-RL« ist daher NUR EIN TEIL der e-Privacy-RL.“

⚠ Das ungeklärte Verhältnis: „BIS HEUTE NICHT VOLLSTÄNDIG GEKLÄRT ist das Verhältnis zwischen der DSGVO und der e-Privacy-RL: Nach Art. 95 DSGVO sollen die Verpflichteten der e-Privacy-RL durch die DSGVO KEINE ZUSÄTZLICHEN PFLICHTEN tragen, allerdings nur, SOWEIT e-Privacy-RL und DSGVO DIESELBEN ZIELE verfolgen.“ 📄 **Aktueller Stand:** „Die EU-Kommission hatte die Novellierung durch eine VERORDNUNG geplant. Nachdem dazu KEINE POLITISCHE EINIGUNG erzielt wurde, hat die EU-Kommission die Pläne »AUF EIS GELEGT«.“

24. ★★ Das REGEL-AUSNAHME-VERHÄLTNIS (eine „Eigenart der Juristen“)

„Die DSGVO ist eine AUFFANGREGELUNG. Sie gilt GRUNDSÄTZLICH IMMER, außer, es gibt Ausnahmen.“

! ★★ AN DIESER STELLE LERNEN SIE EINE WEITERE EIGENART DER JURISTEN KENNEN:

„IMMER, wenn Juristen sagen: »GRUNDSÄTZLICH GILT ...« heißt das: »ES GILT NUR, WENN KEINE AUSNAHMEVORSCHRIFT GREIFT.« ... und es gibt ZAHLREICHE AUSNAHMEN! »Vornehm ausgedrückt« nennen die Juristen dies REGEL-AUSNAHME-VERHÄLTNIS.“

25. ★★★ SACHLICHER Anwendungsbereich der DSGVO (Art. 2)

25.1 Die REGEL — Art. 2 Absatz (1) DSGVO

„Die Verordnung gilt für die AUTOMATISIERTE Verarbeitung personenbezogener Daten sowie für die NICHT AUTOMATISIERTE Verarbeitung personenbezogener Daten, die in einem DATEISYSTEM gespeichert sind oder gespeichert werden sollen.“

★★★ DIE DREI TATBESTANDSMERKMALE (markieren!)

- ① PERSONENBEZOGENE DATEN
- ② GANZ ODER TEILWEISE AUTOMATISIERTE VERARBEITUNG
- ③ NICHTAUTOMATISIERTE VERARBEITUNG + DATEISYSTEM

25.2 ★★★ TBM ① Personenbezogene Daten (Art. 4 Nr. 1 DSGVO)

Definition: „ALLE INFORMATIONEN, DIE SICH AUF EINE IDENTIFIZIERTE ODER IDENTIFIZIERBARE PERSON BEZIEHEN.“

✓ Personenbezug (+)	✗ Personenbezug (-)
Telefonnummern und E-Mail-Adressen natürlicher Personen (z.B. deusch@hs-weingarten.de)	Daten zu einer ZENTRALEN KONTAKTSTELLE (z.B. info@hs-weingarten.de)
Fotos, Videos und Tonaufnahmen	Daten JURISTISCHER Personen (z.B. Name oder Bilanz einer GmbH — Erwägungsgrund 14 S. 2 DSGVO)
Standortdaten, ID-Nummern	Daten VERSTORBENER Personen
Identifizierungen aufgrund von COOKIES	

★ „Sofern die Daten sich auf eine Person beziehen, sind sie UNABHÄNGIG DAVON personenbezogen, ob es sich um PRIVATE oder GESCHÄFTLICHE Daten handelt oder ob sie aus einer ÖFFENTLICH ZUGÄNGLICHEN QUELLE stammen (Telefonbuch oder Impressum einer Webseite).“

★★★★ IDENTIFIZIERBARKEIT (der relative Personenbezug!)

„Ein Personenbezug besteht auch, wenn die Daten eine Person NICHT UNMITTELBAR IDENTIFIZIEREN, die Person aber IDENTIFIZIERBAR ist. Zur Identifizierbarkeit sind ALLE MITTEL zu berücksichtigen, die vom verantwortlichen Datenverarbeiter ODER EINER DRITTEN PERSON nach allgemeinem Ermessen WAHRSCHEINLICH hierfür verwendet werden können.“

(Erwägungsgrund 26 Satz 3 DSGVO)

★★ „Für den Personenbezug einer Information kommt es IMMER DARAUF AN, WER DIE IDENTIFIZIERUNG HERSTELLT bzw. herstellen kann, unter Umständen mithilfe Dritter.“ 

Beispiele: „PSEUDONYME CHATNAMEN oder E-Mail-Adressen können FÜR DEN PROVIDER personenbezogen sein, wenn er sie anhand der Anmeldedaten zuordnen kann, ebenso PIN- und TAN-Daten eines Kontoinhabers FÜR DIE BANK. FÜR AUSSENSTEHENDE DRITTE sind dies dagegen KEINE personenbezogenen Daten.“

★★★★ IP-ADRESSEN — die dreistufige Antwort (Klausurklassiker!)

Für wen?	Pers onen bezu g?	Begründung
Internet- ZUGANGS PROVIDER des Nutzers	✓ JA	„da er es der Person des Nutzers zuordnen kann“
Personen ohne Zusatzwis sen	✗ NEIN	
★ ANBIETER EINER WEBSEITE	✓ JA	„Er kann die IP-Adresse zwar nicht selbst einer Person zuordnen, aber — nach Auffassung des EuGH — DURCH RECHTLICHE MITTEL beim Internet-Zugangsprovider erwirken, dass dieser ihm die Person des Anschlussinhabers nennt. Insbesondere bei URHEBERRECHTSVERLETZUNGEN (Filesharing) kann der Verletzte den Inhaber einer IP-Adresse ermitteln, indem er einen GERICHTLICHEN BESCHLUSS gegenüber dem Zugangsprovider erwirkt oder STRAFANTRAG stellt und AKTENEINSICHT erhält.“ (EuGH NJW 2016, 3579; BGH NJW 2017, 2416)

Fallbeispiel OLAF (EuGH, 07.03.2024 – C-479/22 P)

„Das EU-Amt für Korruptionsbekämpfung (Office Européen de Lutte Anti-Fraude = OLAF) veröffentlichte eine Entscheidung über eine Person mit STAATSANGEHÖRIGKEIT, GESCHLECHT, BERUF, UNGEFÄHREM ALTER und Angaben zum Vorfall.“ **EuGH-Maßstab:** „Welche Mittel werden NACH ALLGEMEINEM ERMESSEN WAHRSCHEINLICH GENUTZT, um die betreffende Person zu identifizieren? ★ KEIN Personenbezug besteht, wenn eine Identifizierung GESETZLICH VERBOTEN oder PRAKTISCH NICHT DURCHFÜHRBAR wäre, z.B. weil sie einen UNVERHÄLTNISSMÄSSIGEN AUFWAND AN ZEIT, KOSTEN UND ARBEITSKRAFT erfordern würde, so dass das Risiko der Identifizierung DE FACTO UNBEDEUTEND erschiene.“ ✓ „Nach diesen Kriterien hat der EuGH den Personenbezug BEJAHT.“

Fallbeispiel TC String (EuGH, 07.03.2024 – C-604/22)

„Der belgische Werbeverband IAB Europe hat ein Framework erstellt, nach dem der sogenannte »TC STRING« verarbeitet wurde. Dies ist eine ZEICHENFOLGE, die die datenschutzrechtlichen PRÄFERENZEN in Bezug auf NAMENTLICH NICHT GENANNT Internetnutzer definierte und mittels Cookies zuordnet.“  „Für den EuGH ist der TC String ein **PERSONENBEZOGENES DATUM**, weil die Mitglieder des Werbeverbands den Personenbezug **HERSTELLEN** und zu einer **PROFILBILDUNG NUTZEN** können.“

★★★★ PSEUDONYMISIERUNG vs. ANONYMISIERUNG (Klausurfrage!)

	PSEUDONYMISIERUNG (Art. 4 Nr. 5 DSGVO)	ANONYMISIERUNG (ErwGrd. 26 S. 5 DSGVO)
Definition	„Daten, die einem Betroffenen NICHT MEHR OHNE ZUSÄTZLICHE INFORMATION zugeordnet werden können.“ Die »zusätzliche Information« ist die ZUORDNUNGSREGEL, durch die der Personenbezug WIEDER HERGESTELLT werden kann.	„Daten, die sich NICHT auf identifizierte oder identifizierbare Personen beziehen.“ Der Personenbezug wird so entfernt, dass er NICHT MEHR WIEDERHERGESTELLT werden kann.
Beispiele	Sozialversicherungsnummern · Personalnummern von Arbeitnehmern · Patientenummern in Krankenhäusern · VERSCHLÜSSELUNG von Daten	„SCHWÄRZEN“ eines Namens auf einer Papierliste
★★★★ DSGVO anwendbar?	 JA — „Pseudonyme Daten SIND personenbezogene Daten.“	 NEIN — „Die DSGVO findet KEINE Anwendung auf anonyme Daten.“

25.3 ★★★★★ TBM ② und ③: Verarbeitung, automatisiert, Dateisystem

Begriff	Definition
VERARBEITUNG (Art. 4 Nr. 2)	„JEDE FORM DER VERWENDUNG bzw. EINFLUSSNAHME auf personenbezogene Daten.“
AUTOMATISIERUNG	„wenn diese MITHILFE VON MASCHINEN erfolgt, insbesondere betrifft dies ALLE COMPUTERGESTÜTZTEN Verarbeitungen“
NICHTAUTOMATISIERUNG	„Vorgänge, die MANUELL bzw. »OFFLINE« ausgeführt werden.“ ★ „Fällt NUR DANN unter die DSGVO, wenn die Daten in einem DATEISYSTEM gespeichert sind oder gespeichert werden sollen.“
DATEISYSTEM (Art. 4 Nr. 6)	„JEDE STRUKTURIERTE SAMMLUNG personenbezogener Daten, die NACH BESTIMMTEN KRITERIEN ZUGÄNGLICH ist.“

☺ Das KLINGELSCHILDER-Beispiel (der berühmte Fall!)

Stellungnahme der Bundesbeauftragten für den Datenschutz (27. Tätigkeitsbericht, S. 29): „Ein besonders BIZARRES Beispiel war die Frage, ob an Mehrfamilienhäusern künftig KLINGELSCHILDER MIT NAMEN VERBOTEN seien oder nicht. Hier habe ich — ebenso wie viele meiner Kolleginnen und Kollegen in den Ländern — deutlich gemacht, dass DAS DATENSCHUTZRECHT GAR NICHT ANWENDBAR IST. Die DSGVO gilt nämlich NUR FÜR AUTOMATISIERTE DATENVERARBEITUNGEN ODER VERARBEITUNGEN IN DATEISYSTEMEN.“

26. ★★★★★ Die AUSNAHMEN — Art. 2 Absatz (2) und (3) DSGVO

Ausnahme	Norm	Inhalt
aa) Unanwendbarkeit des Unionsrechts	Art. 2 Abs. (2) lit. a)	Beispiel: „Die Erhebung von Daten über CHINESISCHE STAATSBÜRGER, die sich AUSSERHALB DER EU aufhalten, durch die chinesische Regierung.“
bb) Außen- und Sicherheitspolitik	Art. 2 Abs. (2) lit. b)	Tätigkeiten gemäß Titel V Kapitel 2 EUV
★★★★ cc) HAUSHALTSAUSNAHME („Haushaltsprivileg“)	Art. 2 Abs. (2) lit. c)	„Die DSGVO gilt NICHT für Datenverarbeitungen, die NATÜRLICHE PERSONEN AUSSCHLIESSLICH ZU PRIVATEN ODER FAMILIÄREN TÄTIGKEITEN durchführen.“
dd) Strafverfolgung und öffentliche Sicherheit	Art. 2 Abs. (2) lit. d)	„Die Datenverarbeitung durch Behörden bei der Strafverfolgung und der Aufrechterhaltung der öffentlichen Sicherheit (präventive Polizeiarbeit) unterliegt NICHT der DSGVO. Hier gelten die Regelungen der JI-RICHTLINIE.“
ee) Organe der EU / Telekommunikationsdienste	Art. 2 Abs. (3) und (4)	EU-Organe → VO (EU) 2018/1725 · Telekommunikationsdienste → e-Privacy-Richtlinie

★★★★★ Die HAUSHALTSAUSNAHME im Detail

✓ Beispiele: Urlaubsfotos · private Telefon- und Anschriftensammlungen · elektronisches Tagebuch oder elektronischer Kalender

★ „Das »Haushaltsprivileg« gilt AUCH, wenn zu privaten Zwecken SOZIALE NETZWERKE genutzt werden (Erwägungsgrund 18 DSGVO). Demgemäß ist die DSGVO NICHT anwendbar auf FACEBOOK-Aktivitäten durch Private oder auf die private Registrierung von WHATSAPP-Kontakten.“ ⚠ „FACEBOOK UND WHATSAPP DAGEGEN HANDELN NICHT ZU PRIVATEN ZWECKEN und sind AN DIE DSGVO GEBUNDEN, wenn sie Daten von EU-Bürgern oder Personen verarbeiten, die sich in der EU aufhalten.“

⚠★★★★★ KRITISCHE FÄLLE zur Haushaltsausnahme (KLAUSURFÄLLE!)

Fall	Ergebnis
ÜBERWACHUNGSKAMERA am Privathaus	✗ „Es gilt NICHT MEHR als ausschließlich private Tätigkeit und wird VON DER DSGVO ERFASST, wenn am Privathaus eine Überwachungskamera installiert wird, die nicht nur das Privatgelände, sondern AUCH TEILE DES ÖFFENTLICHEN RAUMS (STRASSE) aufnimmt.“ (EuGH NJW 2015, 464)
EHRENAMTLICHE Datenverarbeitungen	✗ „Auch ehrenamtliche Datenverarbeitungen sind NICHT PRIVAT, sondern an der DSGVO zu messen, zum Beispiel die MITGLIEDERVERWALTUNG VON VEREINEN.“ (schwierig dagegen: STAMMTISCH, der nicht als Verein eingetragen ist?)
★★ DASHCAMS	siehe unten
Videoaufnahmen durch DROHNEN	„streitig (= rechtlich ungeklärt)“

★★★★ Der DASHCAM-Fall (BGH, Urteil vom 15.05.2018)

Nachdem mehrere Oberlandesgerichte **UNTERSCHIEDLICHE** Auffassungen getroffen hatten, stellte der BGH fest:

① Erste Aussage: ★ „Die Erstellung von Videoaufnahmen durch Dashcams fällt **NICHT** unter das »HAUSHALTSPRIVILEG«." ② Zweite Aussage: ★ „Die **DAUERHAFTE AUFZEICHNUNG** des Verkehrs mittels Dashcams ist **DATENSCHUTZRECHTLICH UNZULÄSSIG**, weil der **DATENSCHUTZ DER BETROFFENEN VORGEHT**."

💡 Hinweis: Der BGH befasste sich mit § 1 Abs. (2) Nr. 3 BDSG a.F. — „Die Entscheidung ist aber auch für die Haushaltsausnahme in Art. 2 Abs. (2) lit. c) DSGVO anwendbar, da beide Normen diesbezüglich **NAHEZU IDENTISCH** sind."

27. ★★★★★ ÖFFNUNGSKLAUSELN

REGEL: „Gemäß Art. 288 Abs. (2) AEUV gilt die DSGVO unmittelbar und verbindlich in jedem EU-Mitgliedstaat. Nationale Gesetze im Anwendungsbereich der DSGVO dürfen **NICHT** angewendet werden."

AUSNAHME: „Es greift eine **ÖFFNUNGSKLAUSEL** der DSGVO."

★★★ Definition

„»**ÖFFNUNGSKLAUSELN**« sind solche Regelungen der DSGVO, die den **MITGLIEDSTAATEN RECHTE ODER PFLICHTEN ZUR KONKRETISIERUNG ODER DURCHFÜHRUNG ZUORDNEN** (quasi wie bei einer Richtlinie, die in den Mitgliedstaaten erst umgesetzt werden muss)." ★ „Aufgrund ihrer zahlreichen Öffnungsklauseln wird die DSGVO auch als »**HYBRID**« **ZWISCHEN RICHTLINIE UND VERORDNUNG** bezeichnet."

Wichtigste Öffnungsklausel: Art. 88 DSGVO — „Hiernach können die Mitgliedstaaten spezifischere Vorschriften erlassen »**IM BESCHÄFTIGTENKONTEXT**«, das heißt zur Verarbeitung personenbezogener Daten von **ARBEITNEHMERN**." ⚠ „Wenn eine Öffnungsklausel greift, findet die DSGVO **ZWAR ANWENDUNG**; **NEBEN** der DSGVO gilt jedoch **ZUSÄTZLICH** die nationale Regelung (was wegen Art. 288 Abs. (2) AEUV **UNTYPISCH** ist für EU-Verordnungen)."

28. ★★★★★ RÄUMLICHER Anwendungsbereich der DSGVO (Art. 3)

Prinzip	Norm	Inhalt
★★★ SITZLANDPRINZIP	Art. 3 Abs. (1)	„Maßgeblich ist, ob die Datenverarbeitung »IM RAHMEN DER TÄTIGKEIT DER NIEDERLASSUNG« in der EU stattfindet.“ ⚠ „UNERHEBLICH ist, WO DER SERVER STEHT, der die Daten verarbeitet.“
★★★ MARKTORTPRINZIP	Art. 3 Abs. (2) lit. a)	„Die DSGVO gilt AUCH OHNE NIEDERLASSUNG in der EU für Verarbeitungen, die im Zusammenhang mit dem ANBIETEN VON WAREN ODER DIENSTLEISTUNGEN in der EU stehen.“ Beispiel: „Ein Unternehmen, das in INDIEN niedergelassen ist, bietet online für Verbraucher in der EU verschiedene Artikel zum Kauf an.“
★★★ VERHALTENSBEOBACHTUNG	Art. 3 Abs. (2) lit. b)	„Auch bei Datenverarbeitungen, die das VERHALTEN von Personen in der EU BEOBACHTEN, gilt die DSGVO.“ Gemeint (ErwGrd. 24): WEBTRACKING, BEHAVIOURAL TRACKING (Cookies, Social Plug-Ins) und PROFILING — ★ „»Beobachten« ist aber auch JEDE GEZIELTE ERHEBUNG VON DATEN über eine Person.“
VÖLKERRECHT	Art. 3 Abs. (3)	„Datenverarbeitungen an Orten, die zwar nicht in der EU liegen, aber KRAFT VÖLKERRECHTS dem EU-Recht unterworfen sind.“ Beispiele: diplomatische und konsularische Vertretungen, Schiffe und Flugzeuge

★★★ Was ist eine „Niederlassung“?

„Eine Niederlassung setzt eine **EFFEKTIVE UND TATSÄCHLICHE AUSÜBUNG EINER TÄTIGKEIT** durch eine **FESTE EINRICHTUNG** voraus (Erwägungsgrund 22 DSGVO). **AUSREICHEND** hierfür ist bereits, wenn **EIN VERTRETER EINER GESELLSCHAFT UND EIN BANKKONTO** in einem EU-Mitgliedstaat vorhanden sind.“ (EuGH NJW 2015, 3636 – Weltimmo) ★★ „Auch die Niederlassung eines **AUFTRAGSVERARBEITERS** in der EU reicht aus. Dies trifft zum Beispiel auf **HOST-PROVIDER** zu. **DESHALB IST DIE DSGVO AUF CLOUD-ANWENDUNGEN ANWENDBAR**, in die Auftragsverarbeiter in der EU eingebunden sind.“

★★★★★ Der Fall „GOOGLE SPAIN“ (EuGH NJW 2014, 2257)

Sachverhalt: „Ein spanischer Bürger hat sich gegen für ihn **NACHTEILIGE SUCHERGEBNISSE** bei Google gewehrt. Da die Google Ltd. in **KALIFORNIEN** niedergelassen ist, wäre das EU-Datenschutzrecht nicht anwendbar. Allerdings unterhält Google eine **TOCHTERGESELLSCHAFT IN SPANIEN**, die dort **WERBEKUNDEN AKQUIRIERT** für Anzeigen in den Suchergebnissen.“ ★★ **Die Regel:** „Die Tätigkeit der Niederlassung in der EU muss einen **WIRTSCHAFTLICH ODER TECHNISCH UNTRENNBAREN ZUSAMMENHANG** mit der Datenverarbeitung aufweisen.“ ✓ „Der EuGH hat die **VERMARKTUNG DER WERBEFLÄCHE** als **UNTRENNBAR** mit der Datenverarbeitung der Suchmaschine verbunden gesehen. Aus diesem Grund war das EU-Datenschutzrecht aufgrund der Niederlassung »Google Spain« **ERÖFFNET**.“

29. ★★★★★ Grundrechte des Grundgesetzes im Datenschutz

Grundrecht	Norm	Inhalt
★★★★ Allgemeines Persönlichkeitsrecht → RECHT AUF INFORMATIONELLE SELBSTBESTIMMUNG	Art. 2 Abs. (1) i.V.m. Art. 1 Abs. (1) GG	„Kerngehalt ist das Recht, SELBST ÜBER DIE PREISGABE UND VERWENDUNG SEINER DATEN ZU BESTIMMEN. Folge davon ist, dass JEDER EINGRIFF in dieses Recht, mithin JEDE DATENVERARBEITUNG, EINER RECHTFERTIGUNG BEDARF.“ (Volkszählungsurteil)
★★★★ „IT-GRUNDRECHT“ — Recht auf VERTRAULICHKEIT UND INTEGRITÄT informationstechnischer Systeme	Art. 2 Abs. (1) i.V.m. Art. 1 Abs. (1) GG	BVerfG-Urteil vom 27.02.2008. „Vom Schutzbereich erfasst sind ALLE SYSTEME, DIE EINBLICKE IN WESENTLICHE TEILE DER LEBENSGESTALTUNG EINER PERSON GEWÄHREN. Hierzu zählen sowohl die HARDWARE eines Systems (PC, Smartphone), aber auch sämtliche VERNETZUNGEN einschließlich CLOUD-ANWENDUNGEN.“
★★ FERNMELDEGEHEIMNIS	Art. 10 GG	„schützt die elektronischen Nachrichten WÄHREND DES KOMMUNIKATIONSVORGANGS BIS ZUM ABSCHLUSS DER TELEKOMMUNIKATION“

★★★★★ Unionsgrundrechte ODER Grundrechte nach dem GG? (Klausurfrage!)

„Im ANWENDUNGSBEREICH DER DSGVO sind NICHT die Grundrechte des GG anzuwenden, sondern die UNIONSGRUNDRECHTE. Sie genießen ANWENDUNGSVORRANG, soweit die staatlichen Stellen mit der DSGVO EU-Recht anwenden.“ ★ „NACH WIE VOR gelten die Grundrechte des Grundgesetzes aber, wenn das EU-Recht NOCH KEINE »VOLLHARMONISIERUNG« bewirkt hat, sondern dem deutschen Gesetzgeber noch GESTALTUNGSSPIELRÄUME eröffnet. Dies ist typischerweise bei EU-RICHTLINIEN der Fall, die durch nationale Gesetze umgesetzt werden müssen (wie etwa der JI-Richtlinie).“

30. ★★★★★ Das Bundesdatenschutzgesetz (BDSG)

30.1 Der Aufbau (4 Teile)

Teil	§§	Inhalt
Teile 1 und 2	§§ 1–44	★ „Füllen im Anwendungsbereich der DSGVO die dortigen »ÖFFNUNGSKLAUSELN« aus.“
Teil 3	§§ 45–84	„Setzt die JI-RICHTLINIE um.“ „Gilt vornehmlich für ÖFFENTLICHE STELLEN. In der Regel NICHT anwendbar für herkömmliche Datenverarbeitungen in Unternehmen.“
Teil 4	§ 85	„Gilt für Bereiche, die WEDER durch die DSGVO NOCH die JI-Richtlinie geregelt sind.“

30.2 ★★★★★ Die besonders relevanten Regelungen der Teile 1 und 2

Norm	Inhalt	zugehörige Öffnungsklausel
§ 4 BDSG	VIDEOÜBERWACHUNG	Art. 6 Abs. (1) UAbs. 1 lit. e) DSGVO
§ 22 BDSG	„BESONDERE“ (= besonders sensible) personenbezogene Daten	Art. 9 DSGVO
★ § 26 BDSG	ARBEITNEHMER-DATENSCHUTZ	Art. 88 DSGVO
§§ 32–37 BDSG	Beschränkung von Datenschutz-RECHTEN, die die DSGVO Betroffenen einräumt	

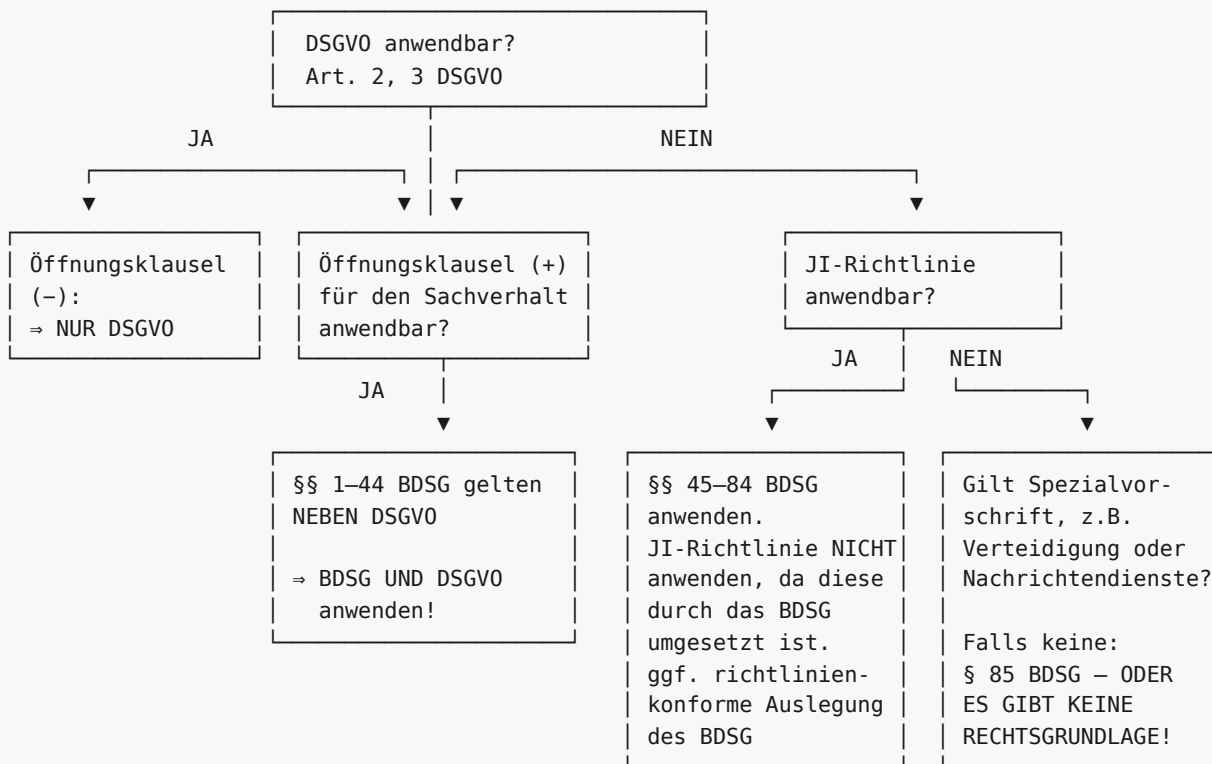
30.3 ★★ Die Anwendungsregeln des BDSG

① **Adressaten:** „Das BDSG gilt insgesamt für sogenannte »ÖFFENTLICHE STELLEN« (= Behörden) und für »NICHT-ÖFFENTLICHE STELLEN« (= Unternehmen), vgl. §§ 1, 3 BDSG." ② **Bundesrecht:** ★ „Auch für öffentliche Stellen gilt das BDSG NUR, WENN DIESE BUNDESRECHT AUSFÜHREN (§ 1 Abs. (1) BDSG)." → „Wenn Behörden der LANDESVERWALTUNG tätig werden, OHNE Bundesrecht auszuüben, gilt das BDSG NICHT, sondern das jeweilige LANDESDATENSCHUTZGESETZ oder ein SPEZIALGESETZ des Landesrechts." ③ **SUBSIDIARITÄT:** ★ „Gemäß § 1 Abs. (2) Satz 1 BDSG gilt es nur, wenn KEIN ANDERES BUNDESRECHT EINE SPEZIELLERE REGELUNG trifft." (Beispiel: § 163b StPO ist gegenüber Teil 3 BDSG die speziellere Regelung zur Identitätsfeststellung von Tatverdächtigen.)

★★★ MUSTERFALL: Die Hochschule speichert Klausurnoten

- | | |
|---------------------|--|
| ① DSGVO anwendbar? | ✓ JA (Art. 2 Abs. (1) DSGVO) |
| ② Rechtsgrundlage? | Art. 6 Abs. (1) S. 1 lit. e) DSGVO
(Wahrnehmung einer öffentlichen Aufgabe) |
| ③ Öffnungsklausel? | ✓ Art. 6 Abs. (2) DSGVO |
| ④ Wer setzt sie um? | „Aufgrund der Kompetenzregelung in § 1 Abs. (1) BDSG: die LANDESDatenschutzgesetze und das LANDESHOCHSCHULGESETZ"
→ Der Betrieb von Hochschulen ist LÄNDERSACHE, somit führt die Hochschule KEIN Bundesrecht aus! |
- ✓ **ERGEBNIS:** Art. 6 Abs. (1) S. 1 lit. e) DSGVO i.V.m. § 12 LHG BW

★★★ DAS PRÜFSHEMA (die wichtigste Grafik des Skriptums!)



31. ★★ Das TDDDG (Telekommunikation-Digitale-Dienste-Datenschutz-Gesetz)

„Das TDDDG regelt den DATENSCHUTZ IN DER TELEKOMMUNIKATION UND BEI DIGITALEN DIENSTEN (vormals als »Telemedien« bezeichnet). Es handelt sich dabei um eine UMSETZUNG DER e-PRIVACY-RL." (Ordnungsnummer 71 in der beck-dtv-Gesetzessammlung „CompR")

★★ Der Aufbau (4 Teile)

Teil	§§	Inhalt
Teil 1	§§ 1, 2	Anwendungsbereich und Begriffe („Allgemeiner Teil")
Teil 2	§§ 3–18	Datenschutz in der TELEKOMMUNIKATION und das FERNMELDEGEHEIMNIS gemäß Art. 5 Abs. (1) e-Privacy-RL. Betroffen: Telefonanbieter, Internet-Zugangsprovider, E-Mail-Provider, Chat-Dienste (WhatsApp, Threema) . ★ „Da der Schutz des Fernmeldegeheimnisses auch Art. 10 GG umsetzen muss (der im Gegensatz zu Artt. 7, 8 GRC AUCH FÜR JURISTISCHE PERSONEN gilt), können sich auch UNTERNEHMEN auf diese Regelungen berufen."
Teil 3	§§ 19–26	Datenschutz bei der Nutzung von DIGITALEN DIENSTEN
Teil 4		Straf- und Bußgeldvorschriften

★★ Die Definitionskette „digitaler Dienst" (eine „Reise durch verschiedene Gesetze"!)

§ 2 Abs. (1) TDDDG

▼ verweist auf die Begriffe des Digitale-Dienste-Gesetz (DDG), § 1 Abs. 4 Nr. 1

▼ verweist wiederum auf

Art. 1 Abs. 1 lit. b) RL (EU) 2015/1535:

„JEDE IN DER REGEL GEGEN ENTGELT ELEKTRONISCH IM FERNABSATZ UND AUF INDIVIDUELLEN ABRUF EINES EMPFÄNGERS ERBRACHTE DIENSTLEISTUNG"

→ Betrifft: Webseiten · Webshops · Plattformen (Facebook, Instagram, LinkedIn)
· Applikationen auf Endgeräten (Apps für Handys oder auch in Autos)

★★★★ MUSTERFALL: App-Anbieter verarbeitet Nutzerdaten

„Wenn der Anbieter einer Handy-App die Daten seiner Nutzer verarbeitet, muss er sich an die DSGVO halten (Art. 6 DSGVO). WENN SICH DIE NUTZERDATEN AUF DEM ENDGERÄT DES NUTZERS BEFINDEN, sind indes die SONDERVORSCHRIFTEN des Art. 5 Abs. (3) e-Privacy-RL und der §§ 25 f. TDDDG zu beachten.“

★★★★ **Der Anbieter darf nur unter folgenden Voraussetzungen speichern und zugreifen:**

(1) ENTWEDER:

- Der ALLEINIGE ZWECK besteht in der DURCHFÜHRUNG DER ÜBERTRAGUNG EINER NACHRICHT über ein öffentliches Telekommunikationsnetz
- ODER
- die Speicherung/der Zugriff ist UNBEDINGT ERFORDERLICH, damit der Anbieter einen VOM NUTZER AUSDRÜCKLICH GEWÜNSCHTEN digitalen Dienst zur Verfügung stellen kann

(2) ODER:

Der Nutzer hat hierzu seine EINWILLIGUNG erteilt.

- ★ Die Einwilligung muss die Anforderungen der Artt. 7, 8 DSGVO erfüllen.
- Webseiten holen sie oft durch sogenannte „COOKIE-BANNER“ ein.

17 **Die EINWILLIGUNGSVERORDNUNG (seit 01.04.2025!)**

„Um dem Nutzer das Verwalten erteilter Einwilligungen zu erleichtern (insbesondere um den vielen »Cookie-Bannern« Herr zu werden), hat die Bundesregierung auf der Grundlage des § 26 TDDDG die EINWILLIGUNGSVERORDNUNG verabschiedet, die SEIT DEM 01.04.2025 GILT. Auf ihrer Grundlage sollen Anbieter ihre Dienste zur Verfügung stellen können, um erteilte Einwilligungen, insbesondere zu Cookies, selbst zu verwalten.“

32. ★ Nationale Spezialvorschriften und Landesdatenschutzgesetze

„Zahlreiche nationale Spezialvorschriften regeln die Verarbeitung personenbezogener Daten BEREICHSSPEZIFISCH:“ De-Mailgesetz · Transfusionsgesetz · Gendiagnostikgesetz · Anti-Doping-Gesetz · Weingesetz · Asylgesetz · Bundeszentralregistergesetz („Polizeiliches Führungszeugnis“) · Prostituiertenschutzgesetz · Abgabenordnung · Bundeselterngeld- und Erziehungsgesetz (BEEG) · Sozialgesetzbücher I–XII · Postgesetz

★★ Landesdatenschutzgesetze

„Die Landesdatenschutzgesetze gelten IMMER, WENN ÖFFENTLICHE STELLEN DER LÄNDER LANDESRECHT AUSFÜHREN (§ 2 Abs. (1) LDSG BW).“ Beispiele: Schulen · Krankenhäuser (Universitätskliniken, Kreis- und Stadtkrankenhäuser) · Kommunalverwaltungen · Hochschulen

★ **„Da die öffentlichen Stellen der Länder EBENFALLS als »Verantwortliche« in den Anwendungsbereich der DSGVO fallen, gelten die Landesdatenschutzgesetze NUR, SOWEIT DIE DSGVO RAUM FÜR ENTSPRECHENDE REGELUNGEN lässt (Öffnungsklauseln, JI-Richtlinie o.ä.).“**

Baden-Württemberg hat sein LDSG zum 12.06.2018 reformiert und an die DSGVO angepasst.

TEIL 2B — RECHTSQUELLEN DER IT-SICHERHEIT

33. ★★★★★ Was ist das „Recht der IT-Sicherheit“?

„Im Vergleich zum Datenschutzrecht ist das Recht der IT-Sicherheit ein JUNGES Rechtsgebiet; die Rechtswissenschaft ist NOCH MIT SEINER EINORDNUNG UND STRUKTURIERUNG BEFASST.“

🔑★★★★★ DIE KURSDEFINITION

„In dieser Vorlesung soll das IT-SICHERHEITSRECHT definiert sein als ALLE RECHTSNORMEN UND RECHTSSÄTZE, DIE DIE VERFÜGBARKEIT, INTEGRITÄT UND VERTRAULICHKEIT (= SCHUTZZIELE der IT-Sicherheit) VON INFORMATIONSTECHNISCHEN SYSTEMEN (= SCHUTZOBJEKTE der IT-Sicherheit) REGELN.“

★★★★★ Die 5 Schutzziele der IT-Sicherheit

1. VERTRAULICHKEIT
2. INTEGRITÄT
3. AUTHENTIZITÄT
4. VERFÜGBARKEIT
5. NICHT-ABSTREITBARKEIT

★★★★★ Schutzobjekte — die entscheidende Abgrenzung (KLAUSURFRAGE!)

	IT-SICHERHEIT	DATENSCHUTZ
Schutzobjekte	„Die INFORMATIONSTECHNISCHEN SYSTEME, also die GERÄTE, mit denen Rechenoperationen ausgeführt werden, sowie die VERBINDUNG DIESER GERÄTE MITEINANDER.“	„Die PERSONENBEZOGENEN DATEN und das dahinterstehende PERSÖNLICHKEITSRECHT des Betroffenen.“

💡 Herleitung aus dem BVerfG-Urteil zum IT-Grundrecht: „Das INTERNET ist ein ELEKTRONISCHER VERBUND VON RECHNERNETZWERKEN. Es besteht damit aus informationstechnischen Systemen und kann zudem auch SELBST als informationstechnisches System angesehen werden.“

34. ★★★★★ Grundrechtliche Bezüge der IT-Sicherheit

⚠️★★★★ „Anders als im Datenschutz gibt es KEIN GRUNDRECHT, DAS DIE IT-SICHERHEIT AUSDRÜCKLICH REGELT — weder auf der Ebene der Unionsgrundrechte noch auf der Ebene des Grundgesetzes. Allerdings sind ZAHLREICHE GRUNDRECHTE NUR DANN EFFEKTIV AUSZUÜBEN, WENN DIE IT-SYSTEME DES GRUNDRECHTSTRÄGERS SICHER SIND.“

Das Grundbeispiel

*„U betreibt ein Unternehmen und möchte seinem Kunden K eine Rechnung stellen. Gemäß § 14 Abs. (2) S. 1 Nr. 1 Umsatzsteuergesetz muss U die Rechnung ELEKTRONISCH ausstellen und versenden. Wenn die VERFÜGBARKEIT des Computers nicht gewährleistet ist, kann er KEINE RECHNUNG ERSTELLEN. Seine Grundrechte der **BERUFSFREIHEIT (Art. 15 GRC)**, seine **UNTERNEHMERISCHE FREIHEIT (Art. 16 GRC)** und sein **EIGENTUMSRECHT (Art. 14 GRC)** sind beeinträchtigt.“*  „**INSOERN IST DIE IT-SICHERHEIT FÜR DIE AUSÜBUNG ALLER FREIHEITSRECHTE RELEVANT.**“

Die WECHSELWIRKUNG (Klausurfrage!)

„Dabei stehen die Interessen der IT-Sicherheit in WECHSELWIRKUNG mit den Interessen des Datenschutzes: EINERSEITS ist die IT-Sicherheit NOTWENDIG, UM FREIHEIT AUSZÜBEN, ANDERERSEITS können die MITTEL DER IT-SICHERHEIT, insbesondere zur KONTROLLE der informationstechnischen Systeme, MIT DEN FREIHEITSRECHTEN IN KONFLIKT TRETEN, insbesondere dem Recht auf Datenschutz und dem Persönlichkeitsrecht.“

Vier weitere Beispiele für die Grundrechtsrelevanz

Fall	Grundrechtskonflikt
„CHATKONTROLLE“	staatliche Interessen (z.B. Strafverfolgung) vs. Beseitigung der Wirkung von Verschlüsselung — Eingriff in Vertraulichkeit der Kommunikation (Art. 7 GRC)
Strafverfolgung Cybercrime	„endet oft an der Staatsgrenze“ — Eingriff in das Eigentumsrecht (Art. 14 GG) · BSI-Lagebericht 2025: „oft staatlich gesteuerte Angreifer“
Elektronische Kommunikation mit Behörden (§ 3a VwVfG)	„Anspruch auf ENDE-ZU-ENDE-VERSCHLÜSSELUNG (noch) ABGELEHNT“ — Eingriff in Art. 7 GRC . (VG Frankfurt: „TRANSPORTVERSCHLÜSSELUNG sei ausreichend“ — a.A. Deusch/Eggendorfer!)
  Straftatbestand „HACKER-PARAGRAF“ § 202a StGB	„erfasst auch REDLICH HANDELNDE SICHERHEITSFORSCHER, die Lücken entdecken und offenlegen“ — Eingriff in die Berufsfreiheit (Art. 12 GG) . „Die Reform des § 202a StGB ist ERFORDERLICH, aber zuletzt GESCHEITERT.“

35. ★★★★★ IT-GOVERNANCE und Art. 32 DSGVO

„ALLE Unternehmen und auch öffentliche Stellen müssen GRUNDLEGENDE ANFORDERUNGEN zur IT-Sicherheit beachten. Hierfür gibt es KEINE SPEZIFISCHE RECHTSGRUNDLAGE; die Verpflichtung wird aber ABGELEITET AUS DER ALLGEMEINEN SORGFALTSPFLICHT.“

Adressat	Rechtsgrundlage
Unternehmen (Unternehmensleitung)	★ § 91 Abs. (2) AktG · § 43 GmbHG
Behörden	„aus dem jeweiligen Gesetz, das der Behörde ihre Aufgabe zuweist“

★★★★ DIE BEGRÜNDUNG: „DENN MIT EINER UNSICHEREN IT LÄSST SICH KEINE AUFGABE ZUVERLÄSSIG ERFÜLLEN. Die sorgfältige Organisation der IT-Sicherheit gehört somit zu den PFLICHTEN GUTER UNTERNEHMENS- BZW. BEHÖRDENFÜHRUNG (»GOVERNANCE« bzw. »COMPLIANCE«; mit Blick auf die IT auch »IT-GOVERNANCE« bzw. »IT-COMPLIANCE« genannt).“

⚠ „Darüber hinaus gilt: ÜBERALL, wo Unternehmen oder Behörden personenbezogene Daten verarbeiten und die DSGVO beachten müssen, gilt die PFLICHT ZUR IT-SICHERHEIT GEMÄSS ART. 32 DSGVO. Verstöße hiergegen können SCHADENSERSATZPFLICHTEN oder sogar BUSSGELDER (Art. 83 DSGVO) verursachen!“

36. ★★★★★ Das GESCHÄFTSGEHEIMNISGESETZ (GeschGehG)

„Unternehmen und Behörden haben oftmals Interesse daran, bestimmte Informationen zu schützen: Der QUELLCODE einer geschlossenen Software, PREISKALKULATIONEN, KUNDENLISTEN oder BEHÖRDLICHE VERSCHLUSSSACHEN.“ (Das GeschGehG setzt die „Know-How-Richtlinie“ der EU um — RL (EU) 2016/943.)

Rechtsfolge	Norm
Unterlassungs- und Schadensersatzansprüche	§§ 6–14 GeschGehG
Freiheitsstrafe bis zu 5 Jahren	§ 23 GeschGehG

⚠ ★★★★★ DIE ENTSCHEIDENDE VORAUSSETZUNG (KLAUSURFRAGE!)

„Als Geschäftsgeheimnis gilt gemäß § 2 Nr. 1 lit. b) GeschGehG ABER NUR eine Information, die GEGENSTAND ANGEMESSENER GEHEIMHALTUNGSMASSNAHMEN durch ihren rechtmäßigen Inhaber ist.“ ★★ „WER ALSO GEHEIMHALTUNGSBEDÜRFTIGE INFORMATIONEN PER UNVERSCHLÜSSELTER E-MAIL VERSENDET, UNTERLÄSST ES, ANGEMESSENE SCHUTZMASSNAHMEN ZU TREFFEN, UND LÄUFT GEFAHR, DEN SCHUTZ DES GeschGehG FÜR DIESE INFORMATION ZU VERLIEREN.“

📝 **Der Streitfall:** „Das OLG Schleswig-Holstein hat (ENTGEGEN DER AUFFASSUNG DES VERFASSERS) die Versendung einer KUNDENLISTE per »TLS-E-Mail« als AUSREICHEND GESCHÜTZT angesehen — allerdings auch deshalb, weil es die Liste zwar als GEHEIMHALTUNGSBEDÜRFTIG, aber NICHT STRENG VERTRAULICH eingestuft hat.“ (OLG Schleswig-Holstein, 28.04.2022 – 6 U 39/21)

37. ★★ Untergesetzliche Regelungen (Standards und Normen)

„Es gibt zahlreiche untergesetzliche Regelungen zur IT-Sicherheit. Sie stammen NICHT VOM GESETZGEBER, sondern von deutschen oder ausländischen BEHÖRDEN, BERUFSVERBÄNDEN oder sonstigen SACHVERSTÄNDIGENORGANISATIONEN:“

Standard	Herkunft
BSI-GRUNDSCHUTZ	Bundesamt für Sicherheit in der Informationstechnik
ISO 27001	International Organization for Standardization
TISAX	Automobilindustrie
CoBiT	IT-Governance
ITIL	IT Service Management
VdS-Richtlinien	Versicherungswirtschaft
PCI-DSS	Kreditkartenindustrie
NIST Cybersecurity Framework	USA

★★★★ DIE RECHTLICHE EINORDNUNG (sehr klausurrelevant!)

„Diese Normen sind von ERHEBLICHER PRAKTISCHER RELEVANZ. Denn viele Unternehmen und Behörden VERLANGEN IHRE BEFOLGUNG, insbesondere von Dienstleistern. So verlangen z.B. zahlreiche Unternehmen der AUTOMOBILINDUSTRIE von ihren Lieferanten, den IT-Sicherheitsstandard TISAX zu erfüllen, ANDERNFALLS ERHÄLT DER LIEFERANT KEINEN AUFTRAG.“

⚠️★★★★ „FÜR DIE RECHTLICHE EINORDNUNG IST ABER WICHTIG: ① DIESE UNTERGESETZLICHEN NORMEN SIND KEINE GESETZE. ② Es gibt KEINE RECHTLICH BINDENDE VERPFLICHTUNG, diese Regelungen zu befolgen (AUSSER MAN SAGT ES VERTRAGLICH ZU); ein Verstoß hiergegen IST NICHT STRAFBAR. ③ Die Herausgeber dieser Normen haben — ANDERS ALS STAATLICHE ORGANE — KEINE BEFUGNIS ZUR RECHTSSETZUNG. ④ ★ GERICHTE NEIGEN IN STREITFÄLLEN ABER OFT ZU DER ANNAHME, DASS DERJENIGE, DER DIE ENTSPRECHENDEN NORMEN BEFOLGT, SEINE SORGFALTPFLICHTEN ERFÜLLT HAT, WÄHREND EIN NORMVERSTOSS OFTMALS EINE VERLETZUNG DER SORGFALTPFLICHTEN INDIZIEREN KANN.“

⚠️ „Gleichwohl ist VOR DER BLINDEN UND BUCHSTABENGETREUEN BEFOLGUNG dieser Normen ZU WARNEN. Sie können jedoch SINNSTIFTEND UND EFFEKTIV eingesetzt werden, wenn ihr ANWENDUNGSBEREICH (»SCOPE«) ERÖFFNET ist und die Regelungen IHREM SINN ENTSPRECHEND umgesetzt werden.“

TEIL 3.1 — DIE DSGVO IM DETAIL

38. ★★★★★ DIE VIER SÄULEN DES DATENSCHUTZES IN DER DSGVO (auswendig!)

① GRUNDSÄTZE UND ZULÄSSIGKEIT	② RECHTE BETROFFENE	③ PFLICHTEN Verantwort- licher / Auftrags- verarbeiter	④ AUFSICHT UND SANKTION DURCH BEHÖRDE
Art. 1 – 11, v.a. Art. 5 und Art. 6	Art. 12 – 23, Art. 82 DSGVO	Art. 24 – 43 DSGVO	Art. 51 – 59, Art. 83 DSGVO

(Säulenmodell nach Schantz/Wolff, Das neue Datenschutzrecht, Rn 815)

Die Übungsfragen zur DSGVO-Struktur

„In welchem KAPITEL der DSGVO würden Sie eine Aussage suchen ...“

Frage	Antwort
... zur Übermittlung von Daten an ein US-amerikanisches Unternehmen?	Kapitel V (Art. 44 ff. — Drittlandtransfer)
... zum Datenschutzbeauftragten?	Kapitel IV (Art. 37–39)
... zur Auftragsverarbeitung?	Kapitel IV (Art. 28)
... zur Verfügbarkeit von IT-Systemen?	Kapitel IV (Art. 32)
... zu Bußgeldern bei Verletzungen?	Kapitel VIII (Art. 83)
... zu grundsätzlichen Vorgaben für die Verarbeitung?	Kapitel II (Art. 5)
... wenn Sie eine RECHTSGRUNDLAGE bzw. BEFUGNISNORM finden möchten?	★ Kapitel II (Art. 6)
... zu Befugnissen der Aufsichtsbehörden?	Kapitel VI (Art. 58)
... wenn Sie ERLÄUTERUNGEN zu einzelnen Bestimmungen finden oder diese AUSLEGEN müssen?	★ Die 173 ERWÄGUNGSGRÜNDE

39. ★★★★★ ART. 6 DSGVO — DIE ZENTRALE RECHTSGRUNDLAGE

Merkmal	Beschreibung
Charakter	★★ „VERARBEITUNGSVERBOT MIT ERLAUBNISVORBEHALT“ (i.V.m. Art. 5 Abs. (1) lit. a) DSGVO)
Bedeutung	★★★★ „DIE zentrale Rechtsgrundlage im Datenschutz“
Adressaten	„Gilt für ÖFFENTLICHE UND NICHT ÖFFENTLICHE Verantwortliche.“
Funktionsweise	„NUR wenn MINDESTENS EIN Tatbestand lit. a) bis f) erfüllt ist, DARF der Verantwortliche die Verarbeitung vornehmen.“
Natur	★ „ABWÄGUNGSNORM: Datenschutz vs. Verarbeitung“

★★★★★ DIE SECHS GLEICHWERTIGEN TATBESTÄNDE (Art. 6 Abs. (1) S. 1)

lit.	Tatbestand	Für Unternehmen primär relevant?
a)	EINWILLIGUNG	★ JA
b)	VERTRAG (oder vorvertragliche Maßnahme)	★ JA
c)	RECHTLICHE VERPFLICHTUNG	★ JA
d)	LEBENSWICHTIGE INTERESSEN	nein
e)	ÖFFENTLICHES INTERESSE / öffentliche Gewalt	nein
f)	BERECHTIGTE INTERESSEN	★ JA

⚠ Unterabsatz 1 Buchstabe f gilt NICHT für die von BEHÖRDEN in Erfüllung ihrer Aufgaben vorgenommene Verarbeitung!

40. ★★★★★ Art. 6 Abs. (1) S. 1 lit. a) DSGVO — DIE EINWILLIGUNG

★★★★★ Die vollständige Prüfliste (KLAUSURSCHEMA!)

- ① Liegt eine EINWILLIGUNGSERKLÄRUNG vor? (Erwägungsgrund 32)
- ② Erklärender = die BETROFFENE PERSON
- ③ EINWILLIGUNGSFÄHIGKEIT (bei Kindern: Art. 8 DSGVO!)
- ④ Für EINEN ODER MEHRERE ZWECKE (Art. 5 Abs. (1) lit. a)
- ⑤ FREIWILLIG, INFORMIERT, EINDEUTIG (Art. 4 Nr. 8 DSGVO)
- ⑥ VERSTÄNDLICH, LEICHT ZUGÄNLICH, KLARE UND EINFACHE SPRACHE, UNTERSCHIEDUNG VON ANDEREN SACHVERHALTEN (Art. 7 Abs. (2) DSGVO)
- ⑦ WIDERRUFSHINWEIS (Art. 7 Abs. (3) DSGVO)
- ⑧ KOPPELUNGSVERBOT (Art. 7 Abs. (4) DSGVO)

★★★★★ ÜBUNGSFALL 1: Das vorausgefüllte Kästchen (EuGH „Planet 49“)

Fall: „Liegt eine Einwilligungserklärung vor?“

☒ Ja, ich will den Newsletter der x-GmbH erhalten. ← BEREITS ANGEKREUZT!

✓ LÖSUNG

★★★★★ „VORAUSGEFÜLLTE KÄSTCHEN SIND KEINE ERKLÄRUNGEN, DA KEINE AKTIVITÄT DES BETROFFENEN VORLIEGT“ (Erwägungsgrund 32 S. 3 DSGVO; **EuGH, 01.10.2019, C-673/17 – Planet 49**)

★★★★★ ÜBUNGSFALL 2: Die 15-jährige Tschamaia (nach BGH NJW 2014, 2282 – „Nordjob-Messe“)

Fall: „Die **15-jährige Tschamaia** nimmt auf der Oberschwabenschau an einem GEWINNSPIEL teil. Dabei kreuzt sie folgende Erklärung an: »Ich bin damit einverstanden, dass meine Kontaktdaten (Name, Adresse) zu WERBEZWECKEN verwendet werden.« Dürfen die Daten von Tschamaia verarbeitet werden?“

✓ LÖSUNG — die drei Probleme

1. INFORMIERT, EINDEUTIG? (genügt der Text den Anforderungen des Art. 4 Nr. 8 DSGVO?) **2. RECHTSFOLGE DES FEHLENDEN WIDERRUFS?** (Art. 7 Abs. (3) DSGVO — Widerrufshinweis fehlt!) **3. EINWILLIGUNGSFÄHIGKEIT:**

- ★ „Art. 8 DSGVO (–), weil KEIN »DIENST DER INFORMATIONSGESELLSCHAFT«“ (Art. 8 DSGVO gilt nur online!)
- „Mit 15 einwilligungsfähig?“ (→ Einzelfallprüfung der Einsichtsfähigkeit)

★★★★★ ÜBUNGSFALL 3: „PAY OR CONSENT“ (Meta/Facebook)

Fall: „Liegt eine Einwilligungserklärung vor, wenn der Nutzer nur die Wahl zwischen ZAHLEN oder EINWILLIGEN hat?“

✓ LÖSUNG

Stellungnahme 8/2024 des Europäischen Datenschutzausschusses (EDSA), Rn 73: ★★★★★ „FREIWILLIGKEIT DER EINWILLIGUNG NUR BEI WAHLFREIHEIT, d.h. bei einer »GLEICHWERTIGEN ALTERNATIVE« OHNE ENTGELTZAHLUNG (z.B. mit anderer Form der Werbung OHNE PERSONALISIERUNG).“

Rechtsfolge: „Mangels wirksamer Einwilligung VERSTOSS GEGEN Art. 5 Abs. (2) lit. a) und b) **DIGITAL MARKETS ACT** (VO (EU) 2022/1925)“ 💰 ★ „→ **GELDBUSSE** der EU-Kommission gegen META in Höhe von 200 MIO. € (23.04.2025).“

★★★★ Einwilligung und COOKIES — die Normenkette

Artt. 6 Abs. (1) S. 1 lit. a), 7 DSGVO
i.V.m. Art. 95 DSGVO
i.V.m. Art. 5 e-Privacy-RL
i.V.m. § 25 TDDG

★★★★ **DIE ENTSCHEIDENDE UNTERSCHIEDUNG: „COOKIES, DIE ZUR FUNKTIONSNUTZUNG NOTIG SIND ↔ NICHT FUNKTIONSRLEVANTE COOKIES (»WERBUNG«)“** (Quelle: LfDI BW, „FAQ zu Cookies und Tracking“)

41. ★★★★★ Art. 6 Abs. (1) S. 1 lit. b) DSGVO — VERTRAG / VORVERTRAGLICHE MASSNAHME

★★ Variante 1: VERTRAG — die drei TBM

- ① VERTRAG
- ② Die BETROFFENE PERSON IST VERTRAGSPARTEI
- ③ Die Verarbeitung ist ERFORDERLICH ZUR ERFÜLLUNG DES VERTRAGS

★★★★★ Beispielfall 1: WM-Eintrittskarten 2006 (LG Frankfurt, 12.06.2006 – 2-01 S 111/06)

Fall: „Beim Verkauf PERSONALISIERTER EINTRITTSKARTEN zur Fußball-WM 2006 hat der DFB die PASS- UND PERSONALAUSWEISDATEN gespeichert. Zulässig?“  „**Das Gericht: JA. Dies sei zur VERTRAGSERFÜLLUNG ERFORDERLICH, nämlich für die IDENTITÄTSPRÜFUNG BEI DER EINLASSKONTROLLE zur STÖRUNGSFREIEN DURCHFÜHRUNG der Veranstaltung.**“

★★★★★ Beispielfall 2: Widerrufs-Statistik im Online-Handel (OLG Hamburg, 25.11.2004 – 5 U 22/04)

Fall: „Ein Online-Händler speichert, WELCHE KUNDEN WIE OFT von ihrem vertraglichen Rückgabe-/Widerrufsrecht Gebrauch machen. Zulässig gemäß lit. b)?“  „**NEIN. Wenn die Rückgabe ABGESCHLOSSEN ist, ist die Speicherung NICHT MEHR »ZUR VERTRAGSERFÜLLUNG« NOTIG.**“
★★ „**ALLERDINGS kann sich die Zulässigkeit aus Art. 6 Abs. (1) S. 1 lit. f) DSGVO ergeben (BERECHTIGTE INTERESSEN), weil die Rückgabe KOSTEN für den Online-Händler verursacht und er ein berechtigtes Interesse daran hat, dies zu erfassen.**“

★★★★ Beispielfall 2.1: Die Pizza-Lieferung (mit vollständiger Subsumtion!)

Fall: „A bestellt eine Pizza bei B. B beauftragt das TAXIUNTERNEHMEN T, die Pizza zu A zu fahren, und gibt dessen Daten weiter. Zulässig?“

- TBM 1: VERTRAG: A bestellt Pizza bei B
(NICHT: der Transportauftrag an das Taxiunternehmen T!)
- TBM 2: Betroffener A ist PARTEI DES VERTRAGS ✓
- TBM 3: Die DATENWEITERGABE von B an T war ERFORDERLICH, damit B den Vertrag mit A erfüllen kann ✓
- ✓ → DATENWEITERGABE ZULÄSSIG

★★ Variante 2: VORVERTRAGLICHE MASSNAHME

- ① ANFRAGE DER BETROFFENEN PERSON
- ② Die Verarbeitung ist ERFORDERLICH zur Durchführung der vorvertraglichen Maßnahme

Fall	Ergebnis
MAKLER gibt Daten eines (Kauf-)Interessenten an den Verkäufer weiter	✓ Zulässigkeit (+)
⚠ „ERBENSUCHER“ ermittelt unbekannte Erben	✗ Zulässigkeit (–) — MANGELS ANFRAGE DES ERBEN (in Betracht kommt aber lit. f)!

42. ★★★★★ SPEZIALFALL: Beschäftigtendatenschutz (§ 26 BDSG)

„Verarbeitung im Beschäftigtenkontext ist EIGENTLICH ein Fall der Vertragserfüllung gemäß Art. 6 Abs. (1) S. 1 lit. b) DSGVO — ABER: ÖFFNUNGSKLAUSEL Art. 88 DSGVO!“ ★★★★★ „→ SPEZIALREGELUNG § 26 BDSG VERDRÄNGT Art. 6 Abs. (1) S. 1 lit. b) DSGVO.“

Art. 88 DS-GVO: ÖFFNUNGSKLAUSEL



Verarbeitung von BESCHÄFTIGTENDATEN im Beschäftigtenkontext



§ 26 BDSG: regelt das „OB“ der Verarbeitung

★ WEITERHIN GILT: was NICHT in § 26 BDSG geregelt ist:
Art. 5, 12 ff., 82 DSGVO; Art. 6 Abs. (1) S. 1 lit. f), 7 DSGVO

★★ Der Inhalt des § 26 BDSG (Absatz für Absatz)

Absatz	Inhalt
Abs. (7) und (8)	Anwendungsbereich
★ Abs. (1) S. 1	Verarbeitung „ZUR DURCHFÜHRUNG DES BESCHÄFTIGUNGSVERHÄLTNISSSES ERFORDERLICH“
★ Abs. (1) S. 2	Zur AUFDECKUNG VON STRAFTATEN nur bei ANHALTSPUNKTEN für Verdacht
Abs. (2)	Besondere Anforderungen an die EINWILLIGUNG
Abs. (3)	Verarbeitung BESONDERER personenbezogener Daten gemäß Art. 9 DSGVO
Abs. (4)	TARIFVERTRÄGE und BETRIEBSVEREINBARUNGEN
Abs. (5)	TOM (technische und organisatorische Maßnahmen)

43. ★★ Art. 6 Abs. (1) S. 1 lit. c), d), e) DSGVO

lit.	Tatbestandsmerkmale	Beispiel
c) RECHTLICHE VERPFLICHTUNG	① (öffentlich-rechtliche) VERPFLICHTUNG des Verantwortlichen · ② Verarbeitung ERFORDERLICH zur Erfüllung	★ „Steuerliche AUFBEWAHRUNGSPFLICHT von Rechnungen gemäß § 147 AO und § 257 HGB berechtigt zur Verarbeitung der darin enthaltenen personenbezogenen Daten.“
d) LEBENSWICHTIGE INTERESSEN	① Verarbeitung erforderlich, um ② lebenswichtige Interessen der betroffenen Person ODER EINES DRITTEN zu schützen	★ „Ein PHARMA-UNTERNEHMEN erhält von den Apotheken die ADRESSEN DER PATIENTEN für einen PRODUKTRÜCKRUF.“
e) ÖFFENTLICHES INTERESSE / ÖFFENTLICHE GEWALT	① Verarbeitung erforderlich für ② eine Aufgabe im öffentlichen Interesse ODER zur Ausübung öffentlicher Gewalt · ③ Aufgabe wurde dem Verantwortlichen ÜBERTRAGEN	„Alle erforderlichen Datenverarbeitungen durch die ÖFFENTLICHE HAND: EINWOHNERMELDEÄMTER, SOZIALVERSICHERUNGEN, AGENTUR FÜR ARBEIT.“

Beispiel zu lit. e): §§ 303a–303f SGB V (Gesetzliche Krankenversicherung)

„Die (GESUNDHEITS-)DATEN der Krankenversicherung erhalten der SPITZENVERBAND BUND DER KRANKENKASSEN, die BUNDES- UND LANDESVERBÄNDE der Krankenkassen und die KASSENÄRZTLICHEN BUNDESVEREINIGUNGEN zu FORSCHUNGSZWECKEN.“ ★ **Rechtfertigung: Art. 6 Abs. (1) S. 1 lit. e) i.V.m. Art. 6 Abs. (3) UND Art. 9 Abs. (2) DSGVO**

44. ★★★★★ Art. 6 Abs. (1) S. 1 lit. f) DSGVO — BERECHTIGTE INTERESSEN

★★★★ Die vier Tatbestandsmerkmale

- ① BERECHTIGTE INTERESSEN
- ② INTERESSENSTRÄGER: Verantwortlicher ODER EIN DRITTER
- ③ Verarbeitung ERFORDERLICH zur Interessenswahrung
- ④ KEIN ÜBERWIEGEN der schutzwürdigen Interessen des BETROFFENEN

★★★★ DIE ABWÄGUNG IM DREISCHRITT

- > Interessen des VERANTWORTLICHEN/DRITTEN feststellen
- > Interessen des BETROFFENEN feststellen
- > Interessen GEWICHTEN

★★★★ DIE GEWICHTUNGSKRITERIEN (KLAUSURFRAGE!)

Seite	Kriterien
BETROFFENE PERSON	☐ ART DER DATEN (sensibel?) ☐ QUELLE DER DATEN (allgemein zugänglich?)
VERANTWORTLICHER / DRITTER	☐ Entsteht ihm ein NACHTEIL ohne Verarbeitung? ☐ Welche RECHTSGÜTER sind betroffen? ☐ ALTERNATIVEN zur Verarbeitung? ☐ ÜBLICHKEIT, NACHVOLLZIEHBARKEIT, VERSTÄNDLICHKEIT der Verarbeitung
★★★★ BEI INTERESSENSGLEICHSTAND	→ VERARBEITUNG (ist zulässig!)

★★ Die Fallgruppen zu lit. f)

Fallgruppe	Fundstelle
Verarbeitung im KONZERN	Erwägungsgrund 48 DSGVO
WERBUNG (Targeting)	Erwägungsgrund 47 DSGVO
⚠️★★★★ COOKIES	„! Für Cookies gilt Art. 5 Abs. (3) ePrivacy-RL i.V.m. DSGVO (EuGH – Planet 49) und § 25 TDDDG — KEIN FALL VON ART. 6 DSGVO!“
IT-SICHERHEIT	Erwägungsgrund 49 DSGVO
IoT	
Webseiten, Suchmaschinen	

📝★★★★ Fallbeispiel ICANN / Admin-C und Tech-C (LG Bonn, Beschluss 29.05.2018)

Fall: „Die ICANN will ADRESSE UND NAME von ADMIN-C und TECH-C erheben und speichern. Zulässig?“ **Die Prüffrage:** Art. 6 Abs. (1) S. 1 lit. b) („zur Vertragserfüllung erforderlich“) ODER lit. f) („zur Wahrnehmung berechtigter Interessen erforderlich“)?

✅ Entscheidung des Gerichts

„NUR DIE DATEN DES DOMAINANMELDERS SIND ERFORDERLICH, um die hinter einer Domain stehenden Personen zu IDENTIFIZIEREN UND ZU KONTAKTIEREN — NICHT ABER Admin-C oder Tech-C.“

45. ★★★★★ Art. 6 Absatz (4) DSGVO — WEITERVERARBEITUNG

★★★★ „DURCHBRECHUNG DER ZWECKBINDUNG“ 📝 **Beispiel:** „Shop-Provider will die ARCHIVIERTEN RECHNUNGSDATEN über Online-Verkäufe ZUR VERTRIEBSOPTIMIERUNG nutzen. Zulässig?“

★★★★ Die zwei Grundaussagen der Norm

① „Bei dem Verantwortlichen **GESPEICHETER** Daten dürfen auch für einen **ANDEREN** als den ursprünglichen Erhebungszweck **verarbeitet** werden, **SOWEIT DER NEUE UND DER URSPRÜNGLICHE ZWECK MITEINANDER KOMPATIBEL SIND.**“ ② „Bei **INKOMPATIBILITÄT** der Zwecke ist eine Verarbeitung zulässig, wenn eine **EINWILLIGUNG** oder eine **ANDERE RECHTSGRUNDLAGE** dazu vorliegt.“

★★★★ Das Prüfschema zur Weiterverarbeitung

Verarbeitung zu einem **ANDEREN** Zweck als dem Zweck der Erhebung

EINWILLIGUNG	ANDERE RECHTS-GRUNDLAGE	ANDERER ZWECK KOMPATIBEL:	Art. 5 Abs. (1) lit. b):
	§ 24 BDSG n.F.: • Gefahrenabwehr • Rechtsausübung	Art. 6 Absatz (4) lit. a) bis e)	ARCHIV, FORSCHUNG, STATISTIK

★ VERARBEITUNG ZUM ANDEREN ZWECK ZULÄSSIG

(vgl. auch Artt. 23–25 BDSG)

Beispiel EuGH, Urteil vom 20.10.2022

„Datenbank von Kunden eines **UNGARISCHEN TV-ANBIETERS**. Einrichtung einer **ZWEITEN DATENBANK** zur **DURCHFÜHRUNG VON TESTS UND BEHEBUNG VON FEHLERN** aus einer bestehenden Datenbank.“

TEIL 3.2 — COMPLIANCE-PFLICHTEN IN UNTERNEHMEN UND BEHÖRDEN

46. ★★★★ DER AUSGANGSFALL: Die manipulierte PDF-Rechnung

(nach OLG Schleswig-Holstein, Urteil vom 18.12.2024 – 12 U 9/24, K&R 2025, 272 ff.)

„Die A-GmbH hat **BAULEISTUNGEN** für den Verbraucher V (natürliche Person) erbracht. Per E-Mail (**UNVERSCHLÜSSELT, UNSIGNIERT**) sendet die Mitarbeiterin M der A-GmbH die **RECHNUNG** (15.000,00 €) als PDF-DATEI. **UNBEFUGTE DRITTE MANIPULIEREN DAS PDF** durch Eintrag einer **ANDEREN BANKVERBINDUNG**. V zahlt an dieses **FALSCHES KONTO** und verlangt nun **SCHADENSERSATZ** von der A-GmbH.“

Zwei Fragen: ① Zu Recht? ② **HAFTET DER GESCHÄFTSFÜHRER** der A-GmbH für den Schaden?

47. ★★★★★ Was ist Compliance?

🔑 „COMPLIANCE = BEFOLGUNG“

„Compliance im Unternehmen: EINHALTUNG VON GESETZEN UND REGELN, die das Unternehmen betreffen.“ Die vier Zwecke: → VERMEIDUNG VON GESETZESVERSTÖßEN → SCHÄDEN VOM UNTERNEHMEN FERNHALTEN → Das Unternehmen in ÜBEREINSTIMMUNG MIT FESTGELEGTE REGELN führen, z.B. ein bestimmtes RISIKONIVEAU zu definieren und zu wahren → IT-COMPLIANCE: Umgang mit ALLEN ANGELEGENHEITEN UND PROZESSEN DER IT im Unternehmen ★ „IT-SICHERHEIT ALS BESTANDTEIL DER IT-COMPLIANCE.“

⚠️★★★★ Die 6 Compliance-Probleme im Alltag (Klausurgrafik!)

VIELE REGELN

UNKLARE REGELN

Adressat VERSTEHT
die Regeln NICHT

PLATZIERUNG der
Regel WIDERSPRICHT
ihrem SINN

SINN der Regel
wird NICHT
UMGESETZT

Adressat
AKZEPTIERT die
Regeln NICHT

48. ★★★★★ IT-Sicherheit und Datenschutz als Compliance-Elemente

UNTERNEHMERISCHE SORGFALTS-
PFLICHT:

Organisation und Führung
des Unternehmens:

- §§ 93 I 1, 92 II AktG
- § 43 GmbHG
- § 116 HGB
- § 714 BGB
- § 2 Nr. 1b GeschGehG

IT-SICHERHEITSPFLICHTEN
AUS DER DSGVO:

- Art. 5 Abs. (1) lit. f) DSGVO
- Art. 24 DSGVO
- Art. 32 DSGVO

SONDERVORSCHRIFT für digitale Dienste (z.B. Websites): § 19 TDDDG

★★★★ Die Sorgfaltspflicht nach Rechtsform (Klausurtabelle!)

Rechtsform	Norm	Wortlaut/Inhalt
AKTIENGESSELLSCHAFT	§ 93 Abs. (1) AktG	„Die Vorstandsmitglieder haben bei ihrer Geschäftsführung die SORGFALT EINES ORDENTLICHEN UND GEWISSENHAFTEN GESCHÄFTSLEITERS anzuwenden.“ ★ BUSINESS JUDGEMENT RULE: „Eine Pflichtverletzung liegt NICHT vor, wenn das Vorstandsmitglied bei einer unternehmerischen Entscheidung VERNÜNFTIGERWEISE ANNEHMEN DURFTE, AUF DER GRUNDLAGE ANGEMESSENER INFORMATION ZUM WOHL DER GESELLSCHAFT ZU HANDELN. “
AG (Haftung)	§ 93 Abs. (2) AktG	„Vorstandsmitglieder, die ihre Pflichten verletzen, sind der Gesellschaft zum ERSATZ DES SCHADENS ALS GESAMTSCHULDNER verpflichtet.“ ⚠ „Ist streitig, ob sie die Sorgfalt angewandt haben, so TRIFFT SIE DIE BEWEISLAST. “ · D&O-Versicherung: SELBSTBEHALT von mind. 10 % des Schadens
★ AG (Überwachungssystem)	§ 91 Abs. (2) AktG	„Der Vorstand hat GEEIGNETE MASSNAHMEN zu treffen, insbesondere EIN ÜBERWACHUNGSSYSTEM EINZURICHTEN , damit den FORTBESTAND DER GESELLSCHAFT GEFÄHRDENDE ENTWICKLUNGEN FRÜH ERKANNT werden.“
GmbH	§ 43 GmbHG	„(1) Die Geschäftsführer haben in den Angelegenheiten der Gesellschaft die SORGFALT EINES ORDENTLICHEN GESCHÄFTSMANNES anzuwenden. (2) Geschäftsführer, welche ihre Obliegenheiten verletzen, HAFTEN der Gesellschaft SOLIDARISCH für den entstandenen Schaden.“
GbR	§ 714 Abs. 1 BGB	„Zur Führung der Geschäfte der Gesellschaft sind alle Gesellschafter berechtigt und verpflichtet. “
oHG, KG, GmbH & Co. KG	§ 116 Abs. 1 HGB	„Zur Führung der Geschäfte der Gesellschaft sind alle Gesellschafter berechtigt und verpflichtet. “
ALLE	§ 280 i.V.m. § 276 BGB	„Die Pflicht zur Geschäftsführung ist mit der IM VERKEHR ERFORDERLICHEN SORGFALT zu erfüllen.“
BEHÖRDEN		„folgt aus der GESETZLICHEN AUFGABENZUWEISUNG “

★★★★ Inhalt, Maßstäbe und Umsetzung der Sorgfaltspflicht

INHALT: „Leitungspersonen müssen ihren Betrieb **SO FÜHREN, WIE ES DIE VERKEHRSÜBLICHE SORGFALT ERFORDERT**, um die Aufgaben der Organisation zu erfüllen. **SCHÄDEN SIND ZU VERMEIDEN.**“

LEGALITÄTSPFLICHT: Gesetzesverstöße VERMEIDEN	SORGFÄLTIGE UNTERNEHMENSFÜHRUNG: Schäden fernhalten	ÜBERWACHUNGSPFLICHT: VERTIKAL: Umsetzung von Anweisungen HORIZONTAL: Ressortaufteilung/Information
---	--	--

MASSSTAB: ★ „**VERKEHRSÜBLICHE SORGFALT; KANN (!) INDIZIERT WERDEN** durch **UNTERGESETZLICHE NORMEN, ISO 27001, BSI-GRUNDSCHUTZ usw.**“ **UMSETZUNG** durch **Unternehmenssteuerung: „BESCHLÜSSE der Unternehmensleitung, RICHTLINIEN, ARBEITSANWEISUNGEN, BERICHTSPFLICHTEN, KONTROLLEN sowie TECHNISCHE MASSNAHMEN“**

★★★★ Rechtsfolgen bei Verstoß (drei Ebenen!)

① „GESCHÄFTSLEITUNG haftet DER GESELLSCHAFT für Schadensersatz (§ 280 Abs. 1 BGB).“ ② „UNTERNEHMEN haftet gegenüber GESCHÄFTSPARTNERN, weil Verträge nicht sorgfältig erfüllt (§ 280 Abs. 1 BGB).“ ③ „UNTERNEHMEN UND GESCHÄFTSLEITUNG haften mit BUSSGELD für Gesetzesverstöße von BESCHÄFTIGTEN (§§ 130, 30 OWiG).“

✓ Die Subsumtion im Ausgangsfall (§ 43 I GmbHG)

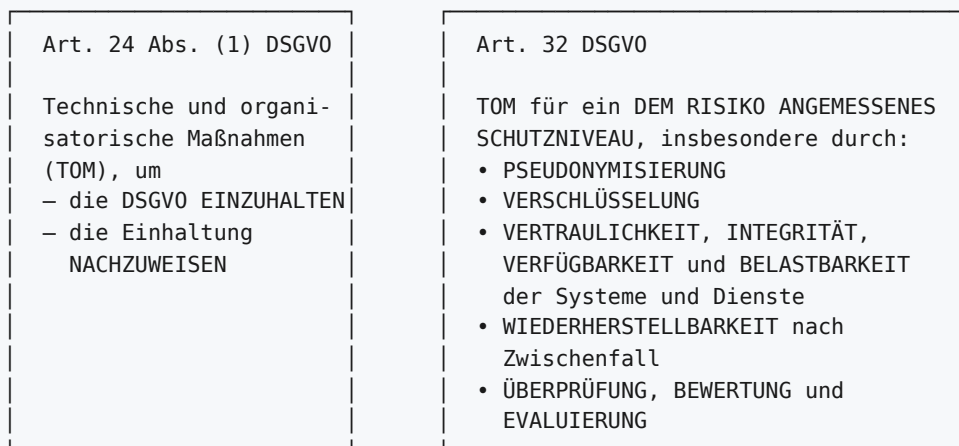
- (1) Handeln des GF in Angelegenheiten der Gesellschaft, § 43 I GmbHG:
 ⚠ M hat überwiesen, ABER: GAB ES ANORDNUNGEN DES GF ZUM E-MAIL-VERSAND?
- (2) Sorgfaltsverstoß: WELCHE PFLICHTEN GIBT ES BEIM E-MAIL-VERSAND?
- Falls Verstoß (+): GF HAFTET GEGENÜBER DER A-GmbH

49. ★★★★★ IT-SICHERHEITSPFLICHTEN AUS DER DSGVO

GRUNDSATZ: Art. 5 Abs. (1) lit. f) DSGVO
 → Wahrung von INTEGRITÄT und VERTRAULICHKEIT
 bei der Verarbeitung personenbezogener Daten

Art. 5 Abs. (2) DSGVO
 → NACHWEISPFLICHT des Verantwortlichen („Accountability“)

KONKRETISIERUNG DURCH



50. ★★★★★ TOM — Technische und organisatorische Maßnahmen

Merkmal	Beschreibung
Vorkommen	„WIEDERKEHRENDER Begriff in verschiedenen Normen des IT-Sicherheitsrechts: Artt. 24, 32 DSGVO · § 30 Abs. (1) BSIG · § 19 TDDDG“
Definition	„Erfasst ALLE HANDLUNGEN, die dazu dienen, bestimmte STANDARDS BZW. ZIELE zu erreichen (Ziele unterscheiden sich je nach Norm und Vorgabe des Unternehmens).“
★ TECHNISCHE Maßnahmen	„IT-ANLAGE und deren PROZESSE.“
★ ORGANISATORISCHE Maßnahmen	„Betreffen den BETRIEBSABLAUF (Maßnahmen der Unternehmenssteuerung).“

★★★★★ Das TOM-KONZEPT

„Lesen Sie Artt. 5 Abs. (2), 24 Abs. (1) und 30 Abs. (1) lit. g) DSGVO!“ ★★ „Die NACHWEISPFLICHT erfordert VERSCHRIFTLICHUNG/DOKUMENTATION der TOM (TOM-KONZEPT).“ Vorlagen im Kurs:
baylda.de/checkliste_tom.pdf (Bayerisches Landesamt) · sage.com/tom_mustervorlage.pdf · telekom.com/dl-tom-2-data.pdf

★★★★★ DIE RISIKOABWÄGUNG IN DREI SCHRITTEN (Artt. 24, 32 DSGVO)

1. SCHUTZBEDARF FESTSTELLEN
Welche DATEN, welche SYSTEME, welche RISIKEN?
2. RISIKOBEWERTUNG
EINTRITTSWAHRSCHEINLICHKEIT und AUSWIRKUNGEN
3. RISIKOBEHANDLUNG
AKZEPTANZ · VERMEIDUNG · VERLAGERUNG · HERABSETZUNG

✓ Die Subsumtion im Ausgangsfall (Art. 32 DSGVO)

- (1) Verarbeitung personenbezogener Daten: DURCH VERSENDUNG DER RECHNUNG?
- (2) Welche Risiken/Schäden: RECHNUNGSFÄLSCHUNG, FEHLÜBERWEISUNG
- (3) Welche Maßnahmen? RISIKOAKZEPTANZ? VERSCHLÜSSELUNG? SIGNATUR?

RECHTSFOLGE bei Verletzung:

- ★ SCHADENSERSATZ (Art. 82 Abs. (1) DSGVO)
- ★ BUSSGELD (Art. 83 Abs. (4) lit. a) DSGVO)

51. ★★★★★ DER GROSSE MUSTERFALL: „Natsionalna agentsia za prihodite“ (EuGH, 14.12.2023 – C-340/21)

Sachverhalt: „Die **NAP** ist eine **BULGARISCHE FINANZBEHÖRDE** zur Feststellung, Sicherung und Einziehung öffentlicher Forderungen. Dabei verarbeitet sie personenbezogene Daten ihrer Schuldner mit ihrem IT-System. **KRIMINELLE TÄTER** haben sich durch einen Angriff **UNBEFUGT ZUGANG** zum NAP-IT-System verschafft und Daten von **MEHR ALS 6 MIO. NATÜRLICHEN PERSONEN IM INTERNET VERÖFFENTLICHT**, darunter auch die Daten der Klägerin **VB**. *VB verlangt von der NAP Schadensersatz in Höhe von **1.000 bulgarischen Lew (etwa 510 EUR)**. Sie befürchtet, dass ihre Daten künftig **MISSBRÄUCHLICH VERWENDET** würden oder dass sie selbst **ERPRESST, ANGEGRIFFEN ODER SOGAR ENTFÜHRT** werde.“*

Frage: Hat VB Anspruch auf Schadensersatz?

✓ Schritt 1: Ist die DSGVO anwendbar? (Obersatz — Untersatz — Schlusssatz!)

OBERSATZ: Gemäß Art. 2 Abs. (1) DSGVO gilt die DSGVO für die AUTOMATISIERTE VERARBEITUNG PERSONENBEZOGENER DATEN.

UNTERSATZ: „Die NAP verarbeitet personenbezogene Daten ihrer Schuldner mit ihrem IT-System.“

SCHLUSSSATZ: Folglich ist die DSGVO ANWENDBAR.

✓ Schritt 2: Anspruchsgrundlage suchen

„Suchen Sie in der **GLIEDERUNG** und in den »SÄULEN« der DSGVO!“ → ★ Säule ② „**Rechte Betroffene**“: **Art. 82 DSGVO (Schadensersatz)**

✓ Schritt 3: TBM und Rechtsfolge des Art. 82 DSGVO

- (1) PERSON
- (2) VERSTOSS GEGEN DIESE VERORDNUNG
- (2a) DURCH DEN VERANTWORTLICHEN / AUFTRAGSVERARBEITER
- (3) SCHADEN der Person zu (1)
- (4) KAUSALITÄT zwischen (2) und (3)

RECHTSFOLGE: Verantwortlicher/Auftragsverarbeiter **HAFTET AUF SCHADENSERSATZ**

✓ Schritt 4: Die Subsumtion

TBM	Subsumtion
(1) Person	= die Klägerin VB ✓
(2a) Wer ist der Verantwortliche?	★ „Die BEHÖRDE NAP = DER BULGARISCHE STAAT“ ✓
(2) „Verstoß gegen die DSGVO“?	„Kann RECHTSWIDRIGE VERARBEITUNG oder NICHTERFÜLLUNG VON DSGVO-PFLICHTEN sein.“ → hier: Art. 32 Abs. (1) DSGVO

★★★★ DIE DREI KERNAUSSAGEN DES EUGH ZU ART. 32 ABS. (1) DSGVO

① (Rn 39): ★★ „UNBEFUGTE OFFENLEGUNG personenbezogener Daten ist NOCH NICHT AUSREICHEND FÜR EINEN VERSTOSS.“ ② (Rn 48–59): ★★★★★ „DER VERANTWORTLICHE MUSS ANORDNUNG, UMSETZUNG UND EIGNUNG DER TOM DARLEGEN UND BEWEISEN (Artt. 5 Abs. (2), 24 DSGVO); nationale Gerichte beurteilen, ob die TOM ausreichend waren.“ → ★★ „TOM DOKUMENTIEREN!“ ③ (Rn 74): ★★★★★ „KRIMINELLE HANDLUNGEN DRITTER UNTERBRECHEN DIE HAFTUNG DES VERANTWORTLICHEN FÜR UNZUREICHENDE TOM NICHT.“

★★★★ TBM (3): Worin liegt der SCHADEN von VB? — die zentrale EuGH-Aussage

„ALLEIN DER UMSTAND, DASS EINE BETROFFENE PERSON INFOLGE EINES VERSTOSSES GEGEN DIE DSGVO BEFÜRCHTET, DASS IHRE PERSONENBEZOGENEN DATEN DURCH DRITTE MISSBRÄUCHLICH VERWENDET WERDEN KÖNNTEN, KANN EINEN »IMMATERIELLEN SCHADEN« IM SINNE DIESER BESTIMMUNG DARSTELLEN.“

★★ TBM (4): Wann fehlt die KAUSALITÄT?

★★ „KAUSALITÄT (–), WENN AUSREICHENDE TOM DEN SCHADEN NICHT VERHINDERT HÄTTEN.“

✓ ERGEBNIS

„Das NATIONALE GERICHT muss klären, • OB und WELCHE TOM getroffen sind und • OB DIESE FÜR ART. 32 DSGVO AUSREICHEND WAREN.“

52. ★★ § 19 TDDDG — IT-Sicherheit in digitalen Diensten

Anbieter digitaler Dienste: „jede in der Regel gegen Entgelt elektronisch im Fernabsatz und auf individuellen Abruf eines Empfängers erbrachte Dienstleistung“ (§ 1 Abs. (4) Nr. 1 DDG; Art. 3a VO (EU) 2022/2065 = DSA) → WEBSITES · APPS · CLOUD-SERVICES usw.

Die TOM-Pflichten:

Absatz	Pflicht
§ 19 Abs. (1) TDDDG	TOM für BEENDIGUNG DER NUTZUNG; VERTRAULICHKEIT
§ 19 Abs. (4) TDDDG	★ TOM gegen UNERLAUBTEN ZUGRIFF, STÖRUNGEN UND ANGRIFFE

⚠ ★ **DIE WICHTIGE ABGRENZUNG ZUM BSIG:** „Die Regelungen des BSIG zu den Anbietern digitaler Dienste (Anlage 2 Ziffer 6 BSIG) ÜBERSCHNEIDEN SICH Z.T. MIT § 19 Abs. (4) TDDDG, der indes für ALLE DIGITALE DIENSTE GILT — UNABHÄNGIG VON DEREN GRÖSSE, somit z.B. für JEDEN WEBSEITENBETREIBER!“

TEIL 3.3 — IT-SICHERHEIT NACH BSIG UND KRITIS-DACHG

53. ★★★★★ Die Begriffe der IT-Sicherheit (BSI IT-Grundschutz-Kompendium, Glossar)

Begriff	Definition
★ BEDROHUNG („threat“)	„UMSTAND ODER EREIGNIS, DAS EINEN SCHADEN HERBEIFÜHREN KANN.“ <i>Beispiele: Angreifer, Schadsoftware, aber auch Hochwasser, Feuer, Stromausfall, Verlust von Hardware-Geräten</i>
★ GEFAHR / GEFÄHRDUNG („applied threat“)	„EINE BEDROHUNG, DIE KONKRET ÜBER EINE SCHWACHSTELLE AUF EIN OBJEKT EINWIRKT.“
★ SCHADEN	„ABWEICHUNG VOM ERWARTETEN ERGEBNIS.“
★ RISIKO	„HÄUFIGKEIT UND AUSMASS EINES SCHADENS.“

54. 📝★★★★ Der Einstiegsfall: Metzger Bruno und Metzger Clemens

Fall 1: „Metzger **BRUNO** schlachtet pro Woche **3 SCHWEINE** und versorgt damit die **3000-Einwohnergemeinde Entenhausen**.“ **Fall 2:** „Metzger **CLEMENS** schlachtet mit seinen Söhnen Robert und Maximilian pro Tag **200.000 SCHWEINE** und beliefert Supermärkte, Großküchen und Gastronomiebetriebe **IN GANZ EUROPA**.“ **Gemeinsam:** „Bruno und Clemens nutzen ein **COMPUTERGESTEUERTES KÜHLSYSTEM** für das geschlachtete Fleisch. Infolge eines **CYBERANGRIFFS** fällt der Computer und die Kühlung aus.“

💡 Die didaktische Frage

„SIE SIND GESETZGEBER. Sehen Sie im Fall 1 und 2 **HANDLUNGSBEDARF**? Falls ja, **WELCHE REGELN** stellen Sie auf? **WELCHE ZIELE** wollen Sie mit Ihren Regeln erreichen?“

55. ★★★★★ Die EU-Gesetzgebung zur IT-Sicherheit wichtiger Sektoren

Richtlinie	Inhalt	Umsetzung in Deutschland
RL (EU) 2016/1148 (NIS-RL)	„Gewährleistung eines EU-weit gemeinsamen SICHERHEITSNIVEAUS von Netz- und Informationssystemen · TOM für bestimmte Sektoren“	
★★★★ RL (EU) 2022/2555 (NIS-2-RL)	„MEHR BEFUGNISSE FÜR BEHÖRDEN · TOM für WESENTLICHE und WICHTIGE Einrichtungen“	★ BSIG + Spezialgesetze (TKG, EnWG, AtG); daneben EU-Spezialregelungen z.B. im Finanzsektor (DORA)
★★★ RL (EU) 2022/2557 (CER-RL)	„(v.a. PHYSISCHER) Schutz KRITISCHER EINRICHTUNGEN“ · ★ RESILIENZ = „Fähigkeit, Sicherheitsvorfälle zu VERHINDERN und ANGEMESSEN HIERAUF ZU REAGIEREN“ (Art. 2 Nr. 2 CER)	★ KRITIS-DachG

⚠️☆☆ „! ACHTUNG ! BSIG in der 17. Aufl. der beck-dtv-Ausgabe 5562 IST NICHT MEHR AKTUELL!" Aktuelle Fassungen: gesetze-im-internet.de/bsig_2025/ · gesetze-im-internet.de/kritisdachg/ (NIS-2-RL = Nr. 22 in beck-dtv 5562 · CER-RL = Nr. 18)

56. ☆☆☆ BSIG — Gliederung und die Rolle des BSI

Die Gliederung (9 Teile)

Teil	Inhalt
Teil 1	Allgemeine Vorschriften, BSI und BEGRIFFSBESTIMMUNGEN
Teil 2	AUFGABEN UND BEFUGNISSE des BSI, Datenverarbeitung
☆☆ Teil 3	SICHERHEIT IN DER INFORMATIONSTECHNIK VON EINRICHTUNGEN
Teil 7	AUFSICHT
Teil 8	BUSSGELDVORSCHRIFTEN

☆☆ Die beiden zentralen Behörden

Ebene	Behörde	Rechtsgrundlage
NATIONAL	☆☆ BSI — Bundesamt für Sicherheit in der Informationstechnik: „ZENTRALE STELLE für Informationssicherheit auf nationaler Ebene“	§ 1 Abs. (1) S. 2 BSIG
EU	☆☆ ENISA — European Union Agency for Cybersecurity	Art. 3 VO (EU) 2019/881 (Cyber Security Act) (= Ordnungsnummer 19 in beck-dtv 5562)

☆☆ BSIG-AUFGABEN (§ 3 BSIG)

„FÖRDERUNG DER SICHERHEIT IN DER INFORMATIONSTECHNIK“ (§ 3 Abs. 1 S. 1), insbesondere:

- GEFAHRENABWEHR
- INFORMATIONEN SAMMELN UND AUSWERTEN
- MITARBEIT IN EU-GREMIEN zur Cybersicherheit
- UNTERSTÜTZUNG DER BUNDESLÄNDER (§ 3 Abs. (2))
- EINRICHTUNGEN BERATEN UND UNTERSTÜTZEN (§ 3 Abs. (3))

☆☆ BSI-BEFUGNISSE

Befugnis	Norm
ANORDNUNG VON MASSNAHMEN bei IT-Sicherheitsvorfällen	§ 10 BSIG
WARNUNGEN	§ 13 BSIG
Maßnahmen gegenüber TK-Anbietern, Anbietern von digitalen Diensten und IKT-Produkten	§§ 16–18 BSIG
AUFSICHTSMASSNAHMEN gegenüber besonders wichtigen und wichtigen Einrichtungen	§§ 61, 62 BSIG

57. ★★★★★ WER UNTERLIEGT DEN PFLICHTEN DES BSIG? (die zentrale Klausurfrage!)

BESONDERS WICHTIGE EINRICHTUNGEN § 28 Abs. (1) BSIG	WICHTIGE EINRICHTUNGEN § 28 Abs. (2) BSIG	BETREIBER KRITISCHER ANLAGEN § 28 Abs. (8) BSIG
- BETREIBER KRITISCHER ANLAGEN - QUALIFIZIERTE Vertrauensdiensteanbieter, TOP LEVEL DOMAIN NAME REGISTRIES oder DNS-DIENSTEANBIETER - TK-Anbieter > 50 AN - ANLAGE 1: > 250 AN, Umsatz > 50 Mio. €	- VERTRAUENSDIENSTEANBIETER - TK-Anbieter < 50 AN und Umsatz < 10 Mio. € - Anlage 1 ODER 2: mind. 50 AN, Umsatz mind. 10 Mio. €	- Wer BESTIMMENDEN EINFLUSS auf eine oder mehrere kritische Anlagen ausübt - KRIT. ANLAGE → kritische Dienstleistung, § 2 Nr. 1 KRITIS-DachG - KRIT. DIENSTLEISTUNG: KRITIS-Sektoren § 2 Nr. 4 KRITIS-DachG

★★★★★ DIE KRITIS-SEKTOREN (§ 2 Nr. 4 KRITIS-DachG — auswendig!)

ENERGIE · TRANSPORT UND VERKEHR · FINANZWESEN · LEISTUNGEN DER SOZIALVERSICHERUNG SOWIE DER GRUNDSICHERUNG FÜR ARBEITSUCHENDE · GESUNDHEITSWESEN · WASSER · ERNÄHRUNG · INFORMATIONSTECHNIK UND TELEKOMMUNIKATION · WELTRAUM · SIEDLUNGSABFALLENTSORGUNG

★★★★★ Die Anlagen zum BSIG

Anlage	Sektoren
★ ANLAGE 1 (besonders wichtige UND wichtige Einrichtungen)	ENERGIE · TRANSPORT UND VERKEHR · FINANZWESEN (Sonderregelung § 28 Abs. (6) Nr. 1 BSIG → DORA) · GESUNDHEIT · WASSER · DIGITALE INFRASTRUKTUR (Internet Exchange Points, DNS-Anbieter, Anbieter von Cloud-Computing-Diensten) · WELTRAUM
★ ANLAGE 2 (nur wichtige Einrichtungen)	TRANSPORT U. VERKEHR (einschl. Post und Kurier) · ABFALLBEWIRTSCHAFTUNG · Produktion, Herstellung und Handel mit CHEMISCHEN STOFFEN (Kategorie 20 NACE Rev. 2) · Produktion, Verarbeitung und Vertrieb von LEBENSMITTELN · VERARBEITENDES GEWERBE/Herstellung von Waren: Medizin, EDV-Hardware, elektr./opt. Geräte, elektrische Ausrüstungen, Maschinenbau, Fahrzeugbau (Abschnitt C Abteilung 26–29 NACE Rev. 2) · ONLINE-MARKTPLÄTZE, SUCHMASCHINEN, SOZIALE NETZWERKE, FORSCHUNG

★★★ Der NACE-Code

„NACE ist die SYSTEMATIK DER EU ZUR KLASSIFIZIERUNG VON WIRTSCHAFTSZWEIGEN und -einheiten (z.B. Unternehmen) sowie ihrer Daten zu STATISTISCHEN ZWECKEN, insbesondere Finanzgesetzgebung und Einteilung im Handels- und Dienstleistungsstatistikgesetz, in § 341r HGB oder in der EU-TAXONOMIE.“ (Geregelt in VO (EG) 1893/2006)

★★★★ FALL 3: Rudi Rasenmäher — die PRÜFUNGSREIHENFOLGE

Fall: „*RUDI RASENMÄHER* ist *SELBSTÄNDIGER UNTERNEHMER OHNE ANGESTELLTE*. Er stellt *ELEKTROMOTOREN* für exklusive Rasenmäher her und baut sie dort ein. Gilt für ihn das BSIG?"

★★★★ DIE PRÜFUNGSREIHENFOLGE (KLAUSURSCHEMA!)

- (1) § 28 Abs. (1) BSIG – beachte SCHWELLENWERTE für Einrichtungen gemäß Nr. 2
- (2) § 28 Abs. (2) BSIG – beachte SCHWELLENWERTE für Einrichtungen gemäß Nr. 2 und 3
- (3) Falls (1) oder (2) (+) → ANLAGE BSIG → NACE-Code

→ **Lösung:** Rudi hat **KEINE** Angestellten und keinen Umsatz > 10 Mio. € ⇒ die Schwellenwerte sind **NICHT** erreicht ⇒ das BSIG gilt für ihn **NICHT**.

58. ★★★★★ DIE PFLICHTEN DER EINRICHTUNGEN NACH DEM BSIG (§§ 30 ff.)

RISIKOMANAGEMENT, § 30 BSIG	RISIKOMANAGEMENT KRITIS, § 31
MELDEPFLICHT, § 32 BSIG	REGISTRIERUNG, §§ 33 f. BSIG
UNTERRICHTUNG, § 35 BSIG	GF-PFLICHTEN, § 38 BSIG

★★★★ § 30 BSIG — Risikomanagement (der Wortlaut!)

§ 30 Abs. (1) BSIG: „Besonders wichtige Einrichtungen und wichtige Einrichtungen sind verpflichtet, **GEEIGNETE, VERHÄLTNISSMÄSSIGE UND WIRKSAME TECHNISCHE UND ORGANISATORISCHE MASSNAHMEN** zu ergreifen, um **STÖRUNGEN DER VERFÜGBARKEIT, INTEGRITÄT UND VERTRAULICHKEIT** der informationstechnischen Systeme, Komponenten und Prozesse, die sie für die Erbringung ihrer Dienste nutzen, **ZU VERMEIDEN** und Auswirkungen von Sicherheitsvorfällen **MÖGLICHST GERING ZU HALTEN**."

★★★★ Die Verhältnismäßigkeitskriterien (S. 2): „das **AUSMASS DER RISIKOEXPOSITION**, die **GRÖSSE DER EINRICHTUNG**, die **UMSETZUNGSKOSTEN** und die **EINTRITTSWAHRSCHEINLICHKEIT UND SCHWERE** von Sicherheitsvorfällen sowie ihre **GESELLSCHAFTLICHEN UND WIRTSCHAFTLICHEN AUSWIRKUNGEN**" ★ (S. 3): „Die Einhaltung der Verpflichtung ist durch die Einrichtungen **ZU DOKUMENTIEREN**."

§ 30 Abs. (2) S. 1 BSIG — die drei Maßstäbe: ① „nach dem **STAND DER TECHNIK**" · ② „**einschlägige EUROPÄISCHE UND INTERNATIONALE NORMEN**" · ③ „**GEFAHRENÜBERGREIFENDER ANSATZ**"

★★★★ DIE 10 PFLICHT-MASSNAHMEN (§ 30 Abs. (2) S. 3 BSIG — AUSWENDIG!)

#	Maßnahme
1	Konzepte in Bezug auf die RISIKOANALYSE und auf die SICHERHEIT in der Informationstechnik
2	BEWÄLTIGUNG VON SICHERHEITSVORFÄLLEN
3	AUFRECHTERHALTUNG DES BETRIEBS, wie BACKUP-MANAGEMENT und WIEDERHERSTELLUNG nach einem Notfall, und KRISENMANAGEMENT
4	★ SICHERHEIT DER LIEFERKETTE einschließlich sicherheitsbezogener Aspekte der Beziehungen zu unmittelbaren Anbietern oder Diensteanbietern
5	Sicherheitsmaßnahmen bei ERWERB, ENTWICKLUNG UND WARTUNG von IT-Systemen, einschließlich MANAGEMENT UND OFFENLEGUNG VON SCHWACHSTELLEN
6	Konzepte und Verfahren zur BEWERTUNG DER WIRKSAMKEIT von Risikomanagementmaßnahmen
7	Grundlegende SCHULUNGEN und SENSIBILISIERUNGSMASSNAHMEN
8	Konzepte und Prozesse für den Einsatz von KRYPTOGRAPHISCHEN VERFAHREN
9	Konzepte für die SICHERHEIT DES PERSONALS, die ZUGRIFFSKONTROLLE und die VERWALTUNG von IKT-Systemen, -Produkten und -Prozessen
10	★ MULTI-FAKTOR-AUTHENTIFIZIERUNG oder KONTINUIERLICHE AUTHENTIFIZIERUNG, GESICHERTE SPRACH-, VIDEO- UND TEXTKOMMUNIKATION sowie ggf. GESICHERTE NOTFALLKOMMUNIKATIONSSYSTEME

★★ § 30 Abs. (3) BSIG — Spezifische TOM für bestimmte Anbieter

„Spezifische TOM (»technische und methodische Anforderungen«) für:" DNS-Diensteanbieter · Top Level Domain Name Registries · Cloud-Computing-Dienstleister · Anbieter von Rechenzentrumsdiensten · Betreiber von Content Delivery Networks · MANAGED SERVICE PROVIDER · MANAGED SECURITY SERVICE PROVIDER · Anbieter von Online-Marktplätzen · Online-Suchmaschinen · Plattformen für Dienste sozialer Netzwerke · Vertrauensdiensteanbieter

Grundlage: Durchführungsverordnung (EU) 2024/2690 vom 17.10.2024

- **Art. 2:** TOM-Konzept gemäß Anlage zur DurchführungsVO
- **Art. 3–14:** Definition **ERHEBLICHER SICHERHEITSVORFÄLLE** gemäß Art. 23 NIS-2-RL, § 32 BSIG

★★ § 31 BSIG — Risikomanagement für KRITISCHE ANLAGEN (verschärft!)

① „STRENGERER MASSSTAB bei der Beurteilung der VERHÄLTNISMÄSSIGKEIT der TOM: Aufwand für ein HÖHERES SCHUTZNIVEAU als bei besonders wichtigen Einrichtungen GILT ALS VERHÄLTNISMÄSSIG.“ (§ 31 Abs. (1)) ② ★ „PFLICHT ZUM EINSATZ VON ANGRIFFSERKENNUNGSSYSTEMEN.“ (§ 31 Abs. (2))

★★★★ § 32 BSIG — MELDEPFLICHTEN (die Fristen auswendig!)

- Gilt für **BESONDERS WICHTIGE** und **WICHTIGE** Einrichtungen
- Erheblichen Sicherheitsvorfall beim **BSI** UND beim **BUNDESAMT FÜR KATASTROPHENSCHUTZ** melden

Frist	Meldung
★ innerhalb von 24 STUNDEN nach Kenntnis	FRÜHE ERSTMELDUNG
★ innerhalb von 72 STUNDEN nach Kenntnis	ERSTE BEWERTUNG
laufend	ZWISCHENMELDUNGEN
★ binnen EINES MONATS	ABSCHLUSSMELDUNG

(⚠ In den Vorlesungsfolien sind beide Fristen mit „72 Stunden“ angegeben; nach dem Gesetzeswortlaut gilt für die Erstmeldung die 24-Stunden-Frist.) **Spezifischere Angaben durch Betreiber KRITISCHER ANLAGEN: § 32 Abs. (3) BSIG**

★★★ § 33 BSIG — REGISTRIERUNGSPFLICHTEN

- Gilt für **BESONDERS WICHTIGE** und **WICHTIGE** Einrichtungen sowie **DOMAIN-NAME-REGISTRY-DIENSTEANBIETER** (= Domain-Registrare)
- **REGISTRIERUNG BEIM BSI**
- ★ **BINNEN 3 MONATEN NACH AUFNAHME DER TÄTIGKEIT**

★★★★ § 38 BSIG — PERSÖNLICHE PFLICHTEN DER GESCHÄFTSLEITUNGEN

① „Geschäftsleitungen besonders wichtiger und wichtiger Einrichtungen müssen **TOM UMSETZEN und ÜBERWACHEN.**“ (§ 38 Abs. (1)) ② ★ „Bei Pflichtverletzung **HAFTUNG NACH DEN REGELN DES GESELLSCHAFTSRECHTS.**“ (§ 38 Abs. (2)) ③ ★★ „**GESCHÄFTSLEITUNGEN MÜSSEN SICH REGELMÄSSIG SCHULEN.**“ (§ 38 Abs. (3)) **Parallelregelungen: Art. 5 Abs. (2) DORA (VO (EU) 2022/2554)** und geplant: **§ 20 KRITIS-DachG-Entwurf**

59. ★★ CER-RL und KRITIS-DachG

Merkmal	Inhalt
CER-RL	RL (EU) 2022/2557 = Ordnungsnummer 18 im beck-dtv 5562
Regelungsgegenstand	„Regelt EU-weit einheitliche Anforderungen an die (PHYSISCHE) IT-SICHERHEIT von Einrichtungen, deren Dienste für GESELLSCHAFTLICHE FUNKTIONEN UND WIRTSCHAFTLICHE TÄTIGKEITEN in der EU UNERLÄSSLICH sind.“
★ RESILIENZ (Art. 2 Nr. 2 CER)	„FÄHIGKEIT, SICHERHEITSVORFÄLLE ZU VERHINDERN UND ANGEMESSEN HIERAUF ZU REAGIEREN.“
Umsetzung in Deutschland	★ KRITIS-DachG

🔑★★★★ „WAS MÜSSEN WIR UNS MERKEN?" (die Zusammenfassungsfolie!)

1. „GESETZLICHE SPEZIALREGELUNGEN für bestimmte Sektoren, um den Umgang mit Bedrohungen der IT-Sicherheit EU-WEIT zu regeln"
2. „NIS-2-RL durch BSIG UMGESETZT; zudem SPEZIALGESETZE"
3. „ENISA und BSI als ZENTRALE IT-SICHERHEITSBEHÖRDEN"
4. „AUFGABEN UND BEFUGNISSE des BSI"
5. „FÜR WEN GILT DAS BSIG?"
6. „RISIKOMANAGEMENTPFLICHTEN des BSIG"
7. „PHYSISCHE SICHERHEIT für Betreiber Kritischer Anlagen durch CER-RL und KRITIS-DachG geregelt"
8. „VERZÄHNUNG zwischen BSIG und KRITIS-DachG"

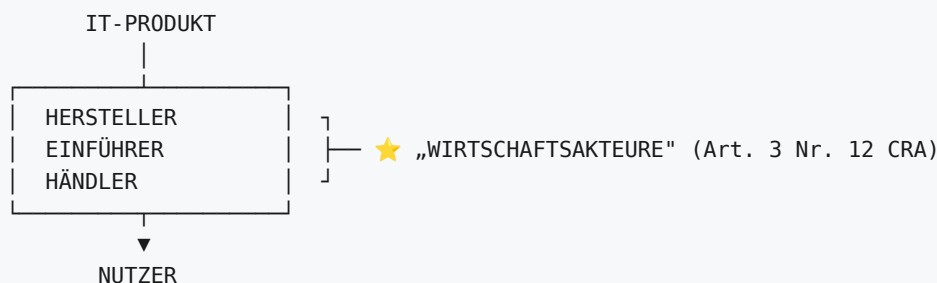
TEIL 3.4 — PRODUKTBEZOGENE RECHTSGRUNDLAGEN DER IT-SICHERHEIT

Der Perspektivwechsel: „BISLANG (Teile 1 bis 3.3): Regelungen zur IT-Sicherheit für die **ANWENDUNG** von IT-Lösungen. **JETZT:** Regelungen zur IT-Sicherheit für die **IT-PRODUKTE SELBST**: Vertrags- und Produkthaftung, Cyber Resilience Act (CRA), KI-Verordnung."

60. ★★★★★ Vom Programmierer zum Nutzer — die Wirtschaftsakteure

Definition „Produkt mit digitalen Elementen" (Art. 3 Nr. 1 CRA)

„EIN SOFTWARE- ODER HARDWAREPRODUKT UND DESSEN DATENFERNVERARBEITUNGSLÖSUNGEN, EINSCHLIESSLICH SOFTWARE- ODER HARDWAREKOMPONENTEN, DIE GETRENNT IN DEN VERKEHR GEBRACHT WERDEN."



61. ★★★★★ Die rechtliche Verantwortung: VERTRAG vs. GESETZ

VERTRAG	GESETZ
KAUFRECHT: §§ 433, 434 BGB	DELIKTSCHAFTUNG: §§ 823 ff. BGB
SCHENKUNG (Freeware): §§ 516, 521 BGB	ProdukthaftungsG / Produkthaftungs-RL (Umsetzung bis 09.12.2026)
MIETE: §§ 535, 536 BGB	CYBER RESILIENCE ACT
WERKVERTRAG: §§ 631, 633 BGB	weitere Sonderregeln

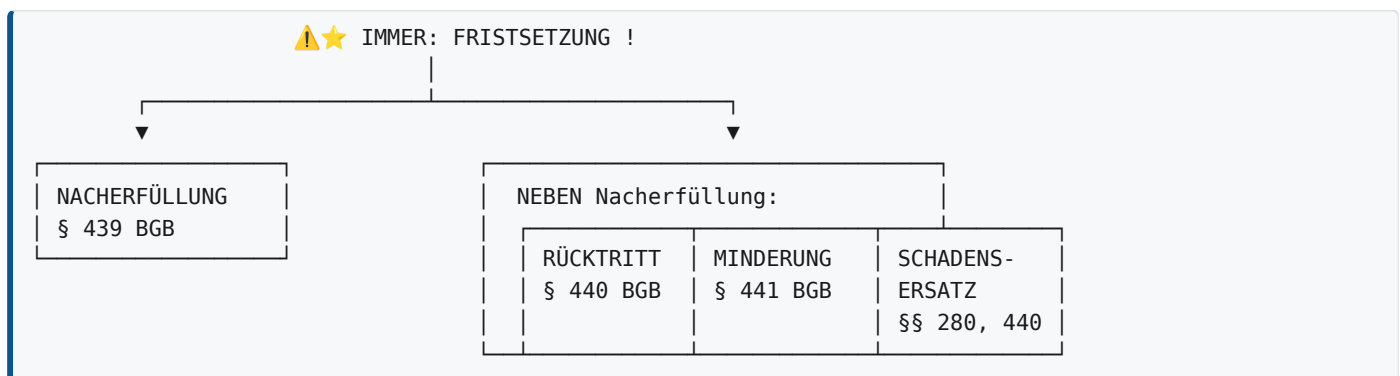
62. ★★★★★ Der Sachmangel im KAUFRECHT

Anwendungsbereich: „Kaufrecht gilt bei JEDER DAUERHAFTEN ÜBERLASSUNG von Hard- und Software MIT GEGENLEISTUNG (GELD ODER DATEN).“ **Beispiele:** Download einer kostenpflichtigen Software/App · **KOMBINierter Kauf von Hard- und Software** (Internet of Things: **WLAN-Waage, Smartwatch, Alexa**)

!★★★★ Die EULA-Klarstellung

„LASSEN SIE SICH NICHT VERWIRREN: oft verlangen Softwarehersteller ZUSÄTZLICH das Akzeptieren eines LIZENZVERTRAGS (»END USER LICENSE AGREEMENT«, EULA). Durch das EULA räumt der Verkäufer dem Käufer die URHEBERRECHTLICHEN NUTZUNGSRECHTE an der Software ein.“

★★★★ Die Rechte des Käufers bei Mängeln (§ 437 BGB)



★★ Was ist ein Sachmangel? (§ 434 Abs. (1) BGB — bei „Gefahrübergang“)

- **SUBJEKTIVE Anforderungen** (§ 434 Abs. (2) BGB)
- **OBJEKTIVE Anforderungen** (§ 434 Abs. (3) BGB) — ★★ „! § 434 Abs. (3) S. 2 BGB: »SICHERHEIT«“
- [Montageanleitung (§ 434 Abs. (4) BGB)]

63. ★★★★★ FALLBEISPIEL: Das Smartphone mit 15 Sicherheitslücken (OLG Köln, 30.10.2019 – 6 U 100/19)

Fall: „Käufer K kauft im Elektronikmarkt E ein Smartphone. Bei einem Test tritt zutage: **Das Gerät weist 15 von 28 getesteten SICHERHEITSLÜCKEN auf.** Grund ist eine **ÄLTERE VERSION DES ANDROID-BETRIEBSSYSTEMS**. Denn der Smartphone-Hersteller muss neue Versionen eines Betriebssystems **ERST ANPASSEN**, bevor er das jeweilige Modell mit dem aktuellen Betriebssystem auf den Markt bringt (»AUSROLLT«). Hat K gegen E ein Recht auf Nacherfüllung?“

✓ Die Lösungsskizze — „WER WILL WAS VON WEM WORAUS?“

Anspruch des K gegen E auf NACHERFÜLLUNG aus § 439 BGB:

- (1) KAUFVERTRAG zwischen K und E
- (2) SACHMANGEL?
- (3) BEI GEFAHRÜBERGANG

✓ (+)
← der Streitpunkt!

! ★★★★★ DER MEINUNGSSTREIT (sehr klausurrelevant!)

(noch aktuelle) RECHTSPRECHUNG — OLG Köln	KRITIK DER LITERATUR (Deutsch/Eggendorfer)
„Softwarefehler NUR DANN Sachmangel, wenn er die GEBRAUCHSTAUGLICHKEIT der Sache BEEINTRÄCHTIGT.“	★★★ „SICHERHEITSRELEVANTE SOFTWAREFEHLER SIND SACHMÄNGEL, UNABHÄNGIG VON EINER FUNKTIONSBEEINTRÄCHTIGUNG. Die damit verbundenen GEFAHREN beeinträchtigen die Gebrauchstauglichkeit des IT-Produkts.“
„Entgegen der Ansicht des Klägers beeinträchtigen die Sicherheitslücken NICHT die Verkehrsfähigkeit des Smartphones. Denn ES IST ALLGEMEIN BEKANNT, DASS JEDES BETRIEBSSYSTEM SICHERHEITSLÜCKEN HAT . Fehler, die die FUNKTIONSFÄHIGKEIT des Programms beeinflussen, sind zwar rechtlich als Mangel anzusehen. Für das Smartphone ist aber nicht vorgetragen, dass das Betriebssystem nicht dazu geeignet ist, die vorgesehenen Leistungen zu erbringen.“	★ „NUR WENN DIE IT-SICHERHEIT DER SOFTWARE DEN STAND DER TECHNIK ERFÜLLT, IST SIE MANGELFREI.“

64. ★★ Schenkungsrecht, Mietrecht, Werkvertragsrecht

★ SCHENKUNGSRECHT (Freeware)

„Wer liest das Kleingedruckte beim Download von Apps? KOSTENLOSE APPS = FREEWARE → SCHENKUNGSRECHT, §§ 516 ff. BGB → ★ HAFTUNGSBEGRENZUNG: § 521 BGB“ ! Probleme: „Apps mit Optionen zu **IN-APP-KÄUFEN**? · Zahlung für Apps mit **NUTZERDATEN**?“

★★ MIETRECHT

Anwendungsbereich: „**ZEITLICH BEGRENZTE ÜBERLASSUNG** von Software · Bereitstellung von **CLOUD-ANWENDUNGEN** · **Software as a Service (SaaS)**, **Infrastructure as a Service (IaaS)** · **HOSTING-DIENSTE** (Bereitstellung von Webspace) · weitere Providerverträge“

Rechte des Mieters bei Mängeln (§§ 536, 536a BGB):

MIETMINDERUNG (★ OHNE FRISTSETZUNG!), § 536 BGB
 +
 MANGELBESEITIGUNG durch Vermieter (§ 535 BGB)
 +
 AUFWENDUNGSERSATZ des Mieters für Mangelbeseitigung, § 536a BGB
 +
 SCHADENSERSATZ, § 536a BGB

📝★★ Der KASPERSKY-Fall (LG München I, 13.12.2023 – 29 O 1152/23)

Fall: „Klägerin zahlt an Beklagte für die Dauer von **ZWEI JAHREN IM VORAUS** Lizenzen für die Nutzung und Pflege von **KASPERSKY-VIRENSCHUTZ-SOFTWARE** zum Zweck der Überlassung an ihre Kunden. **DANACH WARNT DAS BSI VOR KASPERSKY-PRODUKTEN**. Rechte der Klägerin?“

✓ Lösung

- (1) §§ 812, 536 BGB – Rückzahlungsanspruch wegen Mangel
 Mietvertrag: ✓ (+)
 Mangel: ✗ LG München (–)
- (2) §§ 812, 313 BGB – STÖRUNG DER GESCHÄFTSGRUNDLAGE
 ★ HERABSETZUNG DER MIETE UM 50 %

★ WERKVERTRAGSRECHT

„Gilt bei **SOFTWAREENTWICKLUNGEN AUF BESTELLUNG**“ (§§ 633, 634 BGB) **Rechte des Bestellers bei Mängeln (§ 634 BGB) — ⚠ IMMER: FRISTSETZUNG!**

Recht	Norm
NACHERFÜLLUNG	§ 635 BGB
SELBSTVORNAHME	§ 637 BGB
RÜCKTRITT oder MINDERUNG	§§ 636, 638 BGB
SCHADENSERSATZ	§§ 636, 280 ff. BGB

★★ Verbraucherverträge über DIGITALE PRODUKTE (§§ 327 ff. BGB)

„Gilt für Kauf-, Miet- und Werkvertragsrecht, ABER NUR GEGENÜBER VERBRAUCHERN (§ 327 BGB).“

Sondervorschrift	Norm
★ In der NEUESTEN VERSION bereitzustellen	§ 327e Abs. (2) S. 2 BGB
★★ UPDATEPFLICHT	§ 327f BGB
Nacherfüllung, Minderung, Rücktritt, Schadensersatz	§ 327i BGB

65. ★★★★★ GESETZLICHE Verantwortung für IT-Produkte

⚠️★★ Die zwei Probleme der VERTRAGLICHEN Verantwortung

① „ggf. FEHLENDER DURCHGRIFF IN DER LIEFERKETTE (der NUTZER hat KEINEN VERTRAG MIT DEM HERSTELLER)“ ② „Haftungsverantwortung auf SACHMANGELFREIHEIT BEI GEFÄHRÜBERGANG (Übergabe) BEGRENZT (außer Mietrecht)“ → ★★ „HAFTUNGSLÜCKE bei FEHLENDEM VERTRAG und bei RISIKEN, DIE SICH NACH GEFÄHRÜBERGANG ERGEBEN.“

★★★★ § 823 Abs. (1) BGB — Deliktshaftung (Verschuldenshaftung)

„Schadensersatzpflicht gegenüber JEDEM GESCHÄDIGTEN. Erforderlich: FAHRLÄSSIGKEIT (§ 276 BGB!) des Produktherstellers bei einem Fehler in der ...“

Pflicht	Inhalt
★ KONSTRUKTIONSPFLICHT	ENTWICKLUNGSFEHLER
★ INSTRUKTIONSPFLICHT	„GEBRAUCHSANLEITUNG“
★★ PRODUKTBEOBACHTUNGSPFLICHT	„UPDATES BEI »BEKANNTEN« SICHERHEITSLÜCKEN“

⚠️ **PROBLEM:** „Schadensersatz auf die RECHTSGÜTER GEMÄSS § 823 Abs. (1) BGB BEGRENZT — **KEIN ERSATZ DES VERMÖGENSSCHADENS!**“

★★★★ § 823 Abs. (2) BGB — Schutzgesetzverletzung

① ★ „ERFASST AUCH VERMÖGENSSCHÄDEN“ ② „Setzt VERSTOSS GEGEN EIN SCHUTZGESETZ voraus“ — z.B. Produktsicherheitsgesetz · Strafgesetzbuch · Funkanlagen-Richtlinie · und wohl künftig auch der CYBER RESILIENCE ACT ③ ⚠️ „Setzt aber WIE § 823 Abs. (1) BGB VERSCHULDEN voraus (§ 276 BGB)“

★★★★ § 1 ProdukthaftungsG — VERSCHULDENSUNABHÄNGIGE Haftung

„Schadensersatzpflicht gegenüber JEDEM Geschädigten — OHNE VERSCHULDEN!“

Begriff	Definition
⚠️★ PRODUKT (§ 2 ProdHG)	„SOFTWARE NUR, WENN AUF HARDWARE GESPEICHERT“
★ PRODUKTFEHLER (§ 3 ProdHG)	„BERECHTIGTE SICHERHEITSERWARTUNGEN“ → UPDATE BEI »ERKANNTEN« SICHERHEITSLÜCKEN

★★ Die NEUE Produkthaftungsrichtlinie (RL (EU) 2024/2853)

⚠️ „Nicht im beck-dtv-Buch 5562 und deshalb NICHT KLAUSURRELEVANT, aber HÖCHST PRAXISRELEVANT.“

Neuerung	Norm
Für alle Produkte, die NACH DEM 09.12.2026 in Betrieb genommen werden	Art. 2 Abs. (1)
Verlangt ANPASSUNG des ProdukthaftungsG	
★★ Erfasst NUN AUCH SOFTWARE und digitale Elemente (Ausnahme: NICHT KOMMERZIELLE OPEN SOURCE SOFTWARE , Art. 2 Abs. (2))	Art. 4 Nr. 1
★ Schadensersatz AUCH BEI DATENBESCHÄDIGUNGEN	Art. 6
★★ ANFORDERUNGEN ZUR CYBERSICHERHEIT AUSDRÜCKLICH IN DIE FEHLERFREIHEIT EINBEZOGEN	Art. 7 Abs. (1) f)

66. ★★★★★ DER CYBER RESILIENCE ACT (CRA) — VO (EU) 2024/2847

⚠️ „Nicht im beck-dtv-Buch 5562 — bitte HERUNTERLADEN! Aber IN DEN GRUNDZÜGEN FÜR DIE KLAUSUR RELEVANT.“

Merkmal	Inhalt
Regelungsgegenstand (Art. 1)	„Der CRA stellt PRODUKTBEZOGENE ANFORDERUNGEN ZUR CYBERSICHERHEIT für ALLE PRODUKTE MIT DIGITALEN ELEMENTEN auf.“
★★ Bedeutung	„ERSTE PRODUKTBEZOGENE HORIZONTALE REGELUNG ZUR IT-SICHERHEIT“ (bislang nur VERTIKALE Regelungen für bestimmte Produkte wie Funkanlagen, Maschinen usw.)
★ Geltung	AB 11.12.2027 (Art. 71 CRA)

★★★★ Die dreistufigen Cybersicherheitsanforderungen

Stufe	Norm	Inhalt
GRUNDLEGENDE Anforderungen	Art. 6 CRA	an ALLE Produkte mit digitalen Elementen (Anhang I, Teil 1 — 💡 „bitte nicht auswendig lernen, wird in der Klausur nicht abgefragt“)
HÖHERE Anforderungen	Art. 7 CRA	an WICHTIGE Produkte mit digitalen Elementen
SPEZIELLE Anforderungen	Art. 8 CRA	Befugnis der EU zur Definition für KRITISCHE Produkte mit digitalen Elementen
Verweis auf KI-VO	Art. 12 CRA	zu HOCHRISIKO-KI-SYSTEMEN

★★★★ Pflichten der Wirtschaftsakteure (Kapitel II CRA)

Akteur	Pflicht	Norm
HERSTELLER	CYBERSICHERHEIT GEWÄHRLEISTEN	Art. 13 CRA
HERSTELLER	★★ MELDUNG VON SCHWACHSTELLEN UND SICHERHEITSVORFÄLLEN BEI DER ENISA	Art. 14 CRA
EINFÜHRER und HÄNDLER	„NUR Produkte einführen bzw. auf dem Markt bereitstellen, wenn die CYBERSICHERHEITSANFORDERUNGEN DOKUMENTIERT sind“	Art. 19, 20 CRA

★★ Durchsetzung des CRA

① „Durch die MARKTÜBERWACHUNGSBEHÖRDE (Anordnung von Maßnahmen BIS HIN ZUM VERTRIEBSVERBOT, Art. 52 ff. CRA, sowie BUSSGELD, Art. 64 CRA)" ② ⚠️ ★ „Ob der CRA AUCH EIN »SCHUTZGESETZ« GEMÄSS § 823 Abs. (2) BGB ist und Geschädigten Ersatzansprüche verschafft, ist NOCH NICHT GERICHTLICH ENTSCHIEDEN, WIRD ABER ANGENOMMEN."

67. ★★★★★ DIE KI-VERORDNUNG (VO (EU) 2024/1689)

(= **Nummer 8** in Beck-Texte dtv 5562)

📝 Der Ausgangsfall

„Mit Ihrem START-UP-Unternehmen S möchten Sie ein KI-SYSTEM anbieten, das ONLINE-SHOP-BETREIBER ALS CHATBOT zur Kommunikation mit Shop-Besuchern verwenden können. Nennen Sie die PFLICHTEN, die Sie nach der KI-Verordnung beachten müssen, und ZITIEREN SIE DIE RECHTSNORMEN, die diese Pflichten begründen!"

⚠️★★★★ Die Grundprobleme von KI-Anwendungen

① „KI IST NICHT NEUTRAL." → FEHLEINSCHÄTZUNGEN (BIAS), DISKRIMINIERUNG ② „AUTONOMIE der KI-Anwendung vs. NACHVOLLZIEHBARKEIT" → KONTROLLIERBARKEIT UND IT-SICHERHEIT → ★★★★★ MENSCHEN TRAGEN KEINE VERANTWORTUNG MEHR (VERANTWORTUNGSDIFFUSION) ③ ★ „Aus Nutzersicht: BEQUEMLICHKEIT BESIEGT WERTE."

★★★★ Was ist ein KI-System? (Art. 3 Nr. 1 KI-VO)

✓ KI	✗ KEINE KI
„MASCHINENGESTÜTZT, ANPASSUNGSFÄHIG, LEITET AB, WIE AUSGABEN DIE UMGEBUNGEN BEEINFLUSSEN" → Sprachmodelle wie ChatGPT, Copilot usw.	★ „ALGORITHMEN OHNE LERNEFFEKT (etwa bei BIG DATA)" · „ROBOTER OHNE LERNFUNKTION"

★★ Der Regulierungsansatz

Merkmal	Inhalt
Geltung	ab 02.08.2026 / 02.02.2025
Zweck (Art. 1 Abs. 1)	„FÖRDERUNG AUF MENSCHEN AUSGERICHTETER, VERTRAUENSWÜRDIGER KI"
Regelungsmechanik	○ DEFINITION UND KATEGORISIERUNG von KI ○ ★ RISIKOBASIERTER ANSATZ durch VERBOTE, REGULIERUNGEN und TRANSPARENZ ○ PFLICHTEN für ANBIETER, BETREIBER, HERSTELLER

★★★★ DER RISIKOBASIERTE ANSATZ (die zentrale Pyramide!)

VERBOTENE PRAKTIKEN, Art. 5 KI-VO → RISIKO NICHT AKZEPTABEL
HOCHRISIKO-KI-SYSTEME, Art. 6 ff. KI-VO → RISIKOMANAGEMENT durch Anbieter, Händler, Betreiber
BESTIMMTE KI-SYSTEME, Art. 50 KI-VO → TRANSPARENZ bei direkter Kommunikation mit Menschen
KI-MODELLE MIT ALLGEMEINEM VERWENDUNGSZWECK (GPAI), Artt. 51 ff. → Spezifische Pflichten (Doku und Urheberrecht), v.a. bei KI mit SYSTEMISCHEM RISIKO
★ AUSSERDEM: Sicherstellung von KI-KOMPETENZ durch Anbieter und Betreiber, Art. 4 KI-VO

★★ Art. 4 KI-VO — KI-KOMPETENZ

„Gilt für ANBIETER UND BETREIBER von KI-Systemen." ⚠ Die Dozentenmeinung zur Schulungspflicht: „MEINES ERACHTENS NICHT ZWINGEND, SOFERN DAS KONZEPT ZUR KI-NUTZUNG PASSEND DEFINIERT IST."

★★★★ Art. 5 KI-VO — VERBOTENE PRAKTIKEN

Norm	Verbot
Art. 5 Abs. (1) a)	★ „REIZE IN BILDERN ODER AUDIO-DATEIEN UNTERHALB DER MENSCHLICHEN WAHRNEHMBARKEIT, etwa in der WERBUNG" (subliminale Techniken)
Art. 5 Abs. (1) b)	AUSNUTZUNG VULNERABLER GRUPPEN
★ Art. 5 Abs. (1) c)	SOCIAL SCORING
★★ Art. 5 Abs. (1) f)	EMOTIONSERKENNUNG AM ARBEITSPLATZ

★★★★ Art. 6 KI-VO — HOCHRISIKO-KI-SYSTEME

Norm	Anwendungsbereich
Art. 6 Abs. (1) KI-VO	KI-Systeme in SICHERHEITSKOMPONENTEN gemäß Anhang I → MASCHINEN, MEDIZINPRODUKTE, FUNKANLAGEN
Art. 6 Abs. (2) KI-VO	KI-Systeme gemäß Anhang III → ★ BIOMETRIE · KRITIS (teilweise) · PERSONALMANAGEMENT · STRAFVERFOLGUNG · MIGRATION · JUSTIZ

✓ Lösung zum Ausgangsfall: „Das KI-System im Ausgangsfall (Chatbot) fällt **NICHT** unter Art. 6 KI-VO."
 ★ „Für Anbieter und Betreiber von Hochrisiko-KI-Systemen gelten **SPEZIELLE ANFORDERUNGEN**, insbesondere CYBERSICHERHEIT GEMÄSS ART. 15 KI-VO."

★★★★ Art. 50 KI-VO — TRANSPARENZPFLICHTEN

⚠ „LESEN SIE ART. 50 KI-VO GENAU: »ANBIETER / BETREIBER«!"

Absatz	Anwendungsfall	Im Ausgangsfall?
Art. 50 Abs. (1)	KI-Systeme, die für die DIREKTE INTERAKTION MIT NATÜRLICHEN PERSONEN bestimmt sind	✓ JA (Chatbot!)
Art. 50 Abs. (2)	KI-Systeme, die INHALTE ERZEUGEN	✓ JA
Art. 50 Abs. (3)	Systeme zur EMOTIONSERKENNUNG oder BIOMETRISCHEN KATEGORISIERUNG	nein
Art. 50 Abs. (4)	Systeme, die DEEPFAKES erzeugen	nein

★★★ GPAI — KI mit allgemeinem Verwendungszweck (Artt. 50, 51 ff.)

„»GENERAL PURPOSE AI« (GPAI). Beispiel: CHATGPT, MICROSOFT COPILOT" → Es gilt Art. 50 KI-VO
 → ★ Es gilt für Anbieter Art. 53 KI-VO: TECHNISCHE DOKUMENTATION · EINHALTUNG URHEBERRECHT · DOKUMENTATION DER DATENVERWENDUNG

★★★ DAS PRÜFSHEMA ZUR RECHTLICHEN PRÜFUNG VON KI-ANWENDUNGEN (KLAUSURSCHEMA!)

SCHRITT 1: Liegt ein KI-SYSTEM vor (Art. 3 Nr. 1 KI-VO)?

- NEIN: Prüfung zu Ende
- JA: weiter Schritt 2

SCHRITT 2: Ist gefragt nach ANBIETER, BETREIBER, EINFÜHRER, PRODUKTHERSTELLER, BEVOLLMÄCHTIGTEM (Art. 2 KI-VO)?

- Keine der Kategorien passt: Prüfung zu Ende
- Mindestens eine passt: weiter Schritt 3

⚠ und dabei AUF DIE NORMADRESSATEN ACHTEN!

SCHRITT 3: WELCHE ART DER KI liegt vor?

HOCH-RISIKO?	GPAI:	BESTIMMTE KI:	ALLE ANDERE KI:
Artt. 4, 5, 8 ff., ggf. 50,51,53	Artt. 4, 5, 50, 51, 53	Artt. 4, 5, 50	Artt. 4, 5

★★★ Durchsetzung der KI-VO

① „Durch BEHÖRDLICHE KONTROLLE (Kap. VII–XII KI-VO), z.B. Einrichtung EU-BÜRO und EU-GREMIUM DER KI (Artt. 64 ff.)" → Leitlinien der EU-Kommission ② „UNTERSUCHUNGEN UND ANORDNUNGEN der nationalen MARKTÜBERWACHUNGSBEHÖRDE (Art. 74 KI-VO)" → ★ „Gesetz zur Durchführung der KI-VO geplant: **BUNDESNETZAGENTUR** als zuständige Behörde" ③ ★★ „GELDBUSSEN BIS ZU 3 % DES JAHRESUMSATZES ODER 15,0 MIO. € (JE NACHDEM, WAS HÖHER IST), Art. 101 KI-VO"

TEIL 3.5 — RECHTSRAHMEN DER IT-SICHERHEITSFORSCHUNG

68. ★★ ★ DER FALL LILITH WITTMANN („CDU connect")

Der Sachverhalt: „Die IT-Sicherheitsforscherin **LILITH WITTMANN**"

1. „liest in Social Media von Datenschutzfragen zur **CDU-App »CDU connect«** (Verwendung im Wahlkampf),"
2. „erhält vom »Team um CDU connect« die Antwort, es werden **KEINE PERSONENBEZOGENEN DATEN** erhoben,"
3. „lädt sich die **FREI VERFÜGBARE APP** herunter,"
4. „untersucht den **PROXY-SERVER** der App,"
5. „erhält über den Proxy Zugang zur **UNGESICHERTEN PROGRAMMIERSCHNITTSTELLE** und damit auf Daten über Gespräche aus dem CDU-Wahlkampf,"
6. „**INFORMIERT BSI UND CDU** von der Lücke und"
7. „wird infolge einer **STRAFANZEIGE DER CDU** Beschuldigte eines **ERMITTLUNGSVERFAHRENS DES LKA BERLIN**."

→ Ist Lilith Wittmann strafbar?

69. ★★ ★ Wer forscht — und wie läuft IT-Sicherheitsforschung ab?

„IT-Sicherheitsforschung: NICHT NUR WISSENSCHAFTLICHE INFORMATIK, auch viele PRAKTIKERINNEN UND PRAKTIKER mit unterschiedlichsten Motivationen:" PROGRAMMIERER · ADMINS · BERUFLICHE PENETRATIONSTESTER · „ETHISCHE HACKER" (»WHITE HATS«) · „BUG BOUNTY"-MOTIVATION

★★★ RESPONSIBLE DISCLOSURE — der 4-Schritte-Ablauf (auswendig!)

- (1) Forscher INFORMIERT HERSTELLER/ANBIETER über den Fund einer Lücke und bittet um ANSPRECHPARTNER
 - (2) VERSCHLÜSSELTE KOMMUNIKATION mit dem Ansprechpartner über die DETAILS der Lücke
 - (3) Hersteller/Anbieter BEHEBT DIE LÜCKE, z.B. durch PATCH
 - (4) VERÖFFENTLICHUNG der Lücke, NACHDEM DIE NUTZER AUSREICHEND GELEGENHEIT ZUR INSTALLATION DES PATCHS HATTEN
- ⚠ Falls Schritt (2) oder (3) FEHLSCHLÄGT, informiert der Forscher DIE ÖFFENTLICHKEIT über die Lücke.

(Teilweise auch als „**VULNERABILITY DISCLOSURE**" bezeichnet.)

70. ★★★★★ STRAFRECHT — die einschlägigen Normen

★★★★★ § 202a StGB — Ausspähen von Daten (Nr. 4 in beck-dtv 5562)

#	Tatbestandsmerkmal
1	Täter VERSCHAFFT SICH ODER EINEM ANDEREN ZUGANG ZU DATEN
2	Daten NICHT FÜR DEN TÄTER BESTIMMT
3	★★★★★ Daten GEGEN UNBERECHTIGTEN ZUGANG BESONDERS GESICHERT
4	ÜBERWINDUNG DER ZUGANGSSICHERUNG
5	VORSATZ
6	„UNBEFUGT“ = RECHTSWIDRIG

✓★★★★★ DIE LÖSUNG IM AUSGANGSFALL

„DIESES MERKMAL [Nr. 3 — besondere Sicherung] FEHLTE IM AUSGANGSFALL, DAHER EINSTELLUNG DES VERFAHRENS.“ (Die Programmierschnittstelle war **UNGESICHERT!**)

★★★ § 202b StGB — Abfangen von Daten

#	Tatbestandsmerkmal
1	Täter VERSCHAFFT SICH oder einem anderen DATEN
2	Daten NICHT FÜR DEN TÄTER BESTIMMT
3	★ Daten aus NICHT ÖFFENTLICHER DATENÜBERMITTLUNG (oder ABSTRAHLUNG einer IT-Anlage) → ABFANGEN VON E-MAILS; DATENVERKEHR bei der Nutzung von Websites
4	VORSATZ
5	„UNBEFUGT“ = RECHTSWIDRIG

✓ Ergebnis im Ausgangsfall

„§ 202b StGB ist NICHT EINSCHLÄGIG — KEIN ABFANGEN von Daten aus einer Datenübermittlung, da ZUGANG ZU RUHENDEN DATEN AUF DEM SERVER der App.“

★★★ § 202c StGB — „Hackerparagraf“ (Vorbereiten des Ausspähens)

„HERSTELLUNG, VERSCHAFFUNG, VERKAUF, ÜBERLASSUNG, VERBREITUNG, ZUGÄNGLICHMACHUNG von ZUGANGSDATEN oder »HACKERSOFTWARE«“ ★★★★★ BVerfG-EINSCHRÄNKUNG: „HACKERSOFTWARE MUSS IN KRIMINELLER ABSICHT HERGESTELLT WORDEN SEIN.“ → ★ „In der LEGALEN IT-Sicherheitsforschung können RICHTLINIEN ZUR ENTWICKLUNG UND NUTZUNG von »Hackersoftware« DEN VORSATZ-VORWURF ENTKRÄFTEN.“

★ Weitere einschlägige Strafnormen

Norm	Tatbestand
§§ 303a, 303b StGB	Datenveränderung/Computersabotage — „wenn die FORSCHUNG DATEN ODER IT-ANLAGEN BESCHÄDIGT“
§ 269 StGB	FÄLSCHUNG BEWEISERHEBLICHER DATEN
§ 303 StGB	SACHBESCHÄDIGUNG, z.B. bei EINGRIFFEN IN IT-GESTEUERTE PRODUKTIONSPROZESSE

71. ★★★ § 34 StGB — RECHTFERTIGENDER NOTSTAND (der Ausweg?)

Der Gesetzeswortlaut: „Wer in einer **GEGENWÄRTIGEN, NICHT ANDERS ABWENDBAREN GEFahr** für Leben, Leib, Freiheit, Ehre, Eigentum oder ein anderes Rechtsgut eine Tat begeht, um die Gefahr von sich oder einem anderen abzuwenden, **HANDELT NICHT RECHTSWIDRIG**, wenn bei **ABWÄGUNG DER WIDERSTREITENDEN INTERESSEN ... das GESCHÜTZTE INTERESSE DAS BEEINTRÄCHTIGTE WESENTLICH ÜBERWIEGT**. Dies gilt jedoch nur, soweit die Tat ein **ANGEMESSENES MITTEL** ist, die Gefahr abzuwenden.“

★★★ Die Anwendung auf Responsible Disclosure

„RESPONSIBLE DISCLOSURE KANN (!) NOTSTANDSHANDLUNG SEIN:“

#	Prüfpunkt	Anwendung
1	GEGENWÄRTIGE GEFahr	★ „= DIE SICHERHEITSLÜCKE, DA SIE JEDERZEIT VON KRIMINELLEN AUSGENUTZT WERDEN KANN“
2	NOTSTANDSHANDLUNG	„»eine Tat begeht, um die Gefahr abzuwenden«: Ein AUSFORSCHEN DER LÜCKE kann eine solche »Tat« rechtfertigen (§§ 202a, 202b, 303a, 303b, 303 StGB) — ⚠ ALLERDINGS NUR BEI HINREICHENDEM VERDACHT“
3	VERHÄLTNISSMÄSSIGKEIT	„Notstandshandlung muss GEEIGNET, ERFORDERLICH UND ANGEMESSEN sein zur Beseitigung der Sicherheitslücke“
4	NOTSTANDSWILLE	„des Forschers“

⚠ ★★★ DER PRAXISTIPP

„Im Einzelfall kann der NACHWEIS dieser Rechtfertigung für die IT-Sicherheitsforschung SCHWIERIG werden, DAHER: EINZELNE MASSNAHMEN UND IHRE UMSTÄNDE DOKUMENTIEREN!“
 ⚠ „GESETZESENTWURF ZUM RESPONSIBLE DISCLOSURE GESCHEITERT.“

72. ★★★ DATENSCHUTZRECHT in der IT-Sicherheitsforschung

Frage: „Was gilt, wenn bei der IT-Sicherheitsforschung **PERSONENBEZOGENE DATEN** betroffen sind?“ ①
DSGVO ANWENDBAR — „Ausnahmen Art. 2 Abs. (2) bis (4) DSGVO greifen NICHT.“ ② ★★
SICHERHEITSFORSCHER = »VERANTWORTLICHER« i.S.d. DSGVO ③ → **VERARBEITUNGSVERBOT MIT ERLAUBNISVORBEHALT** erfordert eine **RECHTSGRUNDLAGE!**

★★★★ Die Rechtsgrundlage: Art. 6 Abs. (1) S. 1 lit. f) DSGVO

TBM	Anwendung
BERECHTIGTE INTERESSEN	„Sicherheitsforscher will LÜCKE SCHLIESSEN und BETROFFENE SCHÜTZEN“
INTERESSENSTRÄGER	„Sicherheitsforscher (eventuell Betroffene)“
KEIN ÜBERWIEGEN der schutzwürdigen Interessen	„FORSCHUNGSINTERESSE vs. DATENSCHUTZINTERESSE, auch abhängig von der VORGEHENSWEISE und eventuellen GARANTIEN des Forschers i.S.d. Art. 89 DSGVO“

! ☹️ Die Normenkette bei BESONDEREN personenbezogenen Daten

„... und GANZ ABENTEUERLICH wird es bei besonderen personenbezogenen Daten i.S.d. Art. 9 DSGVO:“

Art. 6 Abs. (1) S. 1 lit. f) DSGVO
 → Art. 9 Abs. (1) DSGVO
 → Art. 9 Abs. (2) lit. h) DSGVO
 → § 27 BDSG

📖 Quelle: Balaban et al., Whitepaper zur Rechtslage der IT-Sicherheitsforschung, sec4research.de

73. ★★★★★ URHEBERRECHT in der IT-Sicherheitsforschung

„Lesen Sie die §§ 69a, 69c und 69d UrhG (Nr. 46 in der beck-dtv-Ausgabe 5562)!“

Die Funktionsweise der Normen

① „COMPUTERPROGRAMME SIND DURCH DAS URHEBERRECHT GESCHÜTZT (§ 69a Abs. (1) UrhG).“
 ② „WER EIN COMPUTERPROGRAMM NUTZEN WILL, BENÖTIGT DIE ZUSTIMMUNG DES URHEBERS (§ 69c UrhG).“ → ★ „NUTZUNGSRECHT = LIZENZ des Urhebers oder eines vom Urheber Berechtigten; eventuell durch »BUG-BOUNTY-PROGRAMME« der Hersteller.“ ③ ★ „OHNE Zustimmung des Berechtigten: GESETZLICHE GRUNDLAGE erforderlich, zum Beispiel § 34 StGB.“

★ Folgen eines Urheberrechtsverstoßes

Ansprüche des Berechtigten auf: UNTERLASSUNG · AUSKUNFT · SCHADENSERSATZ · STRAFRECHTLICHE VERFOLGUNG (§ 106 UrhG)

✓★★★★ Die urheberrechtliche Lösung im Ausgangsfall

„Im Fall entscheidend: DIE NUTZUNGSHANDLUNG.“

Nutzungshandlung	Ergebnis
★ VERVIELFÄLTIGUNG durch DOWNLOAD der App (§ 69c Nr. 1 UrhG)	✗ „ABER: ZUSTIMMUNG DES HERSTELLERS DURCH BEREITSTELLUNG IM APP STORE / PLAY STORE“
BEARBEITUNG (§ 69c Nr. 2 UrhG)?	✗ „(-), die App selbst ist NICHT BEARBEITET worden. Auch keine Hinweise auf Bearbeitung von Programmcode auf dem Server; es wurde LEDIGLICH DIE PROGRAMMIERSCHNITTSTELLE ONLINE ANGESPROCHEN (aber nicht »bearbeitet«); selbst wenn: OB DIESE EIN »COMPUTERPROGRAMM« IST, WÄRE IM EINZELFALL ZU PRÜFEN.“

✓★★★★ DAS GESAMTERGEBNIS IM AUSGANGSFALL

① STRAFRECHT: „Verhalten bleibt STRAFLOS MANGELS SICHERUNG; Rechtfertigung durch Responsible Disclosure möglich, ABER UNSICHER.“ ② DATENSCHUTZRECHT: „erfordert ABWÄGUNG DER INTERESSEN; PROBLEMATISCH BEI SENSIBLEN DATEN.“ ③ URHEBERRECHT: „KEIN Urheberrechtsverstoß mangels Vervielfältigung oder Bearbeitung der Programmierschnittstelle.“

TEIL 3.6 — HAFTUNG IM INTERNET

74. ★★★★★ Inhalte im Internet und ihre Schutzrechte

 Das Kursbeispiel (Foto des Surfers Gabriel Medina, „Times of India“):

- → RECHT AM BILD von Gabriel Medina (*DSGVO, KunstUrhG*)
- → URHEBERRECHT des Fotografen
- → NUTZUNGSRECHTE der „Times of India“

★★★★ Die schutzfähigen Inhalte (Klausurliste!)

Inhalt	Schutzrecht
★ URHEBERRECHT: „PERSÖNLICH GEISTIGE SCHÖPFUNGEN“	SPRACHE, MUSIK, FOTO, VIDEO, SOFTWARE (§ 69a ff. UrhG)
⚠★★★★ INHALTE VON KI	✗ „(-), NICHT »PERSÖNLICH«" — KI-Erzeugnisse sind NICHT urheberrechtlich geschützt!
PERSÖNLICHKEITSRECHT, DATENSCHUTZ	
NAME	§ 12 BGB
MARKE	Markengesetz
STRAFRECHTLICH RELEVANTE INHALTE	TERROR · CHILD ABUSE · SCHADCODE
LINKS	siehe unten

★ Rechtsverletzungen — Art. 3 lit. h) DSA (VO (EU) 2022/2065)

(= Nr. 45 in beck-dtv 5562) **Beispiele: URHEBERRECHT** (Nutzung ohne Zustimmung des Inhabers) · **PERSÖNLICHKEITSRECHT, DATENSCHUTZ** (DSGVO-Verstoß) · **NAME** (z.B. fremder Name in Domain) · **strafrechtlich relevante Inhalte**

75. ★★★★★ Die Anspruchsgrundlagen bei Rechtsverletzungen

★★★★ § 823 Abs. (1) BGB — „SONSTIGES RECHT“

PERSÖNLICHKEITSRECHT · NAME · RECHT AM EINGERICHTETEN UND AUSGEÜBTEN GWERBEBETRIEB · ★ AUCH: „IT-GRUNDRECHT“ · URHEBERRECHT, MARKENRECHT, PATENTRECHT
(hier gibt es aber Sondernormen)

★★★★ § 823 Abs. (2) BGB — SCHUTZGESETZVERSTOSS

DSGVO · GESETZ GEGEN DEN UNLAUTEREN WETTBEWERB (UWG) (hier gibt es aber Sonderansprüche)
· KI-VO · CYBER RESILIENCE ACT · **STRAFRECHT: §§ 201a, 202c, 202d StGB**

★★★★ Die zivilrechtlichen Haftungsfolgen

Folge	Norm	Inhalt
★ UNTERLASSUNG	§§ 823 i.V.m. § 1004 BGB	→ EINSTELLUNG der rechtswidrigen Handlung → ZUSAGE EINER VERTRAGSSTRAFE oder Verurteilung zu ORDNUNGSGELD bei Wiederholung/Fortsetzung
AUSKUNFT		
SCHADENSERSATZ		

76. ★★★★★ PASSIVLEGITIMATION — „WER HAFTET?“ (Klausurfrage!)

① Haftung für EIGENE Inhalte

→ „WER HAT DEN INHALT »INS NETZ GESTELLT«?“

② ★★★★★ Haftung für „ZU EIGEN GEMACHTE" Inhalte von Dritten (BGH, 09.08.2022 – VI ZR 1244/20)

Die vier Kriterien: 1. „wenn sich der Inhalt des Dritten für den DURCHSCHNITTSNUTZER NICHT ERKENNBAR von den Inhalten des Webseitenbetreibers UNTERSCHIEDET," 2. „der Webseitenbetreiber die INHALTLICHE VERANTWORTUNG für den Drittinhalt ÜBERNOMMEN hat," 3. „eine auch NACH AUSSEN HERVORTRETENDE VERBUNDENHEIT des Webseitenbetreibers mit dem Dritten besteht," 4. „der Webseitenbetreiber DARAUF HINWEIST, ER HABE DIE DRITTINHALTE KONTROLLIERT."

③ ★★★★★ „STÖRERHAFTUNG" für FREMDE Inhalte (BGH, 18.06.2015 – I ZR 74/14)

„AB KENNTNIS DES RECHTSVERSTOSSES oder bei VERLETZUNG ZUMUTBARER PRÜFPFLICHTEN — abhängig vom RANG DES RECHTSGUTS, AUSMASS UND VORHERSEHBARKEIT DER VERLETZUNG."

77. 📝★★★★★ DER FALL „PLAYBOY" VOR DEM EuGH (C-160/15, 08.09.2016)

Sachverhalt:

- „**SANOMA MEDIA NETHERLANDS BV** = niederländischer Verlag des »Playboy«"
- „**BRITT DEKKER** = »Miss Dezember 2011«"
- „Fotos aber bereits im **OKTOBER 2011** abrufbar unter »www.filefactory.com«"
- „Das Internetportal **GS MEDIA BV** veröffentlichte ab Oktober 2011 **LINKS AUF SEINER WEBSEITE** zu den Fotos."

Frage: Kann Sanoma das Portal GS Media in Anspruch nehmen?

✓ Die drei Prüffragen

Frage	Antwort
Welches Recht ist verletzt?	„NUTZUNGSRECHT des Verlags Sanoma, beruhend auf Rechten des Fotografen" → URHEBERRECHT, Urheberrechtsgesetz
Welche Handlung ist relevant?	★ „SETZEN DES LINKS ohne Zustimmung von Sanoma durch GS Media BV"
Anspruchsgrundlage („wer will was von wem woraus")?	„UNTERLASSUNG DER LINKSETZUNG, § 97 UrhG (§§ 823 Abs. (1) i.V.m. 1004 BGB)"

✓ Die TBM des § 823 Abs. (1) BGB

(1) RECHTSGUTVERLETZUNG

- URHEBERRECHT: Recht der ÖFFENTLICHEN ZUGÄNLICHMACHUNG (z.B. § 69c Nr. 4 UrhG bei Software)
- ★ Kernfrage: SETZEN DES LINKS = ÖFFENTLICHE ZUGÄNLICHMACHUNG?

★★★★ DIE EuGH-ANTWORT (die „Neues-Publikum“-Doktrin!)

① „Setzen eines FREI ZUGÄNLICHEN LINKS ist NICHT OHNE WEITERES eine urheberrechtlich relevante Handlung.“ ② ★★ „ÖFFENTLICHES ZUGÄNLICHMACHEN (-), WENN DURCH DEN LINK KEIN NEUES PUBLIKUM ERREICHT WIRD.“ ③ ★★★★★ »NEUES PUBLIKUM« ABER (+), WENN:

- „VERLINKTE SEITE NUR REGISTRIERTEN NUTZERN ZUGÄNLICH“
- „VERWEIS AUF RECHTSWIDRIGE ODER NICHT VOM URHEBER AUTORISIERTE QUELLE, wenn der LINKSETZER VON DER RECHTSWIDRIGKEIT HÄTTE WISSEN MÜSSEN“
- ★★ „→ WIRD BEI LINKS MIT GEWINNERZIELUNGSABSICHT VERMUTET!“

☁ Die Anschlussfrage der Vorlesung: „Was gilt, wenn die Fotos von Frau Dekker DURCH GOOGLN ERREICHBAR sind, aber der VERLETZER DES URHEBERRECHTS NICHT ERMITTELBAR ist?“ → **Providerhaftung nach dem DSA!**

78. ★★★★★ DER DIGITAL SERVICES ACT (DSA) — Providerhaftung in der EU

Die drei Haftungsprivilegien (Artt. 4–6 DSA — auswendig!):

Providerart	Norm	Voraussetzungen der Haftungsfreistellung
★ ACCESS-PROVIDER (Durchleitung)	Art. 4 DSA	① ÜBERMITTLUNG NICHT VERANLASST ② EMPFÄNGER NICHT AUSGEWÄHLT ③ INFORMATIONEN NICHT VERÄNDERT
★ CACHING	Art. 5 DSA	① INTEGRITÄT DER INFORMATION WAHREN ② KENNTNIS von SPERRUNG oder BEHÖRDLICHER/GERICHTLICHER ANORDNUNG
★★ HOST-PROVIDER	Art. 6 DSA	★ ZÜGIGES SPERREN NACH KENNTNIS OFFENSICHTLICHER RECHTSWIDRIGKEIT

Zusätzlich geregelt: MELDE- UND ABHILFEVERFAHREN VON HOSTINGANBIETERN (Art. 16 DSA — „Notice and Action“)

☁️ ★★ Die Abschlussfrage der Vorlesung

„Ich bin URHEBER EINES VIDEOS, das OHNE MEINE ZUSTIMMUNG AUF TIKTOK zu sehen ist.“ ①
 Wie kann ich mich WEHREN? (→ Unterlassung, Auskunft, Schadensersatz nach § 97 UrhG) ② Wer ist
 mein ANSPRUCHSGEGNER? (→ Uploader als Täter; TikTok als Host-Provider erst ab Kenntnis, Art. 6 DSA)
 ③ Welche GESETZESNORMEN regeln das ABHILFEVERFAHREN? (→ Art. 16 DSA — Melde- und
 Abhilfeverfahren)

TEIL 4 — RECHTSDURCHSETZUNG DURCH BEHÖRDEN UND VOR GERICHTEN

79. ★★ Die drei MODELLE ZUR DURCHSETZUNG VON RECHT

STAATLICHE DURCHSETZUNG	INDIVIDUELLE DURCHSETZUNG	KOLLEKTIVE DURCHSETZUNG
- Durch BEHÖRDEN - VERWALTUNGSAKTE (Verfügungen, Anordnungen, Verbote) - VOLLSTRECKUNG mithilfe STAATLICHER GEWALT	- RECHTSSUBJEKTE machen ihre Rechte BILATERAL geltend, z.B.: „A verlangt von B Schadensersatz“ - Z.T. STAATLICHE UNTERSTÜTZUNG, z.B. durch POLIZEI - Durchsetzung durch KLAGE, ggf. VOLLSTRECKUNG	★ PROZESSSTANDSCHAFT: (Verbraucherschutz-) Verband klagt IM AUFTRAG eines Betroffenen → Art. 80 Abs. (1) DSGVO ★ VERBANDSKLAGE (IM EIGENEN NAMEN) → Art. 80 Abs. (2) DSGVO

80. ★★ Behörden der IT-Sicherheit

① ZENTRALE RELEVANZ: ENISA und BSI ② „Das BSI hat die AUFGABE ZUR ABWEHR VON GEFAHREN für die IT-Sicherheit (§ 3 BSIG) und das RECHT ZU STAATLICHEN EINGRIFFSMASSNAHMEN, z.B. §§ 61, 62 BSIG.“

81. ★★★★★ Die Datenschutzbehörden in Deutschland

Ebene	Behörde	Zuständigkeit
BUND	★ Bundesbeauftragte(r) für den Datenschutz und die Informationsfreiheit (BfDI) — www.bfdi.de	AUFSICHT FÜR BEHÖRDEN DES BUNDES
LÄNDER	★ 16 LANDESDATENSCHUTZBEAUFTRAGTE + das LANDESAMT FÜR DATENSCHUTZAUF SICHT IN BAYERN	★★ „AUFSICHTSBEHÖRDEN FÜR DIE ÖFFENTLICHEN STELLEN (BEHÖRDEN) UND NICHT ÖFFENTLICHEN STELLEN (UNTERNEHMEN) IN IHREN BUNDESLÄNDERN“
Baden-Württemberg	Der Landesbeauftragte für Datenschutz und Informationsfreiheit BW (LfDI BW) — baden-wuerttemberg.datenschutz.de	

Befugnisse: Art. 58 DSGVO i.V.m. §§ 40–44 BDSG n.F.

★★★★★ DIE BEFUGNISSE DER AUFSICHTSBEHÖRDE (Art. 58 DSGVO — KLAUSURTABELLE!)

UNTERSUCHUNG Art. 58 Absatz (1)	ABHILFE Art. 58 Absatz (2)	BERATUNG Art. 58 Absatz (3)
• ANWEISUNG zur BEREITSTELLUNG VON INFORMATIONEN UND UNTERLAGEN • UNTERSUCHEN, z.B. DATENVERARBEITUNGS-ANLAGEN oder PROGRAMME	• WARNUNG, VERWARNUNG • ANWEISUNG zur ERFÜLLUNG VON BETROFFENENRECHTEN und VERARBEITUNGEN • WIDERRUF von ZERTIFIZIERUNGEN • ★ BESCHRÄNKUNG UND VERBOT DER VERARBEITUNG	• BERATUNG • STELLUNGNAHMEN • GENEHMIGUNGEN (etwa bei ZERTIFIZIERUNGEN) • STANDARDKLAUSELN FESTLEGEN

82. ★★☆☆ IT-Sicherheit und Datenschutz VOR GERICHT (die Gerichtsbarkeiten)

ZIVILGERICHTE: Amtsgericht → Landgericht → Oberlandesgericht → Bundesgerichtshof; eventuell ARBEITSGERICHTE; Europäischer Gerichtshof

DSGVO: Betroffene, Wettbewerber	HAFTUNG wegen UNTERLASSENER COMPLIANCE	IT-SICHERHEITS- LÜCKEN ALS MÄNGEL	Ansprüche UrhG
---------------------------------------	--	---	----------------

STRAFGERICHTE: Amtsgericht → Landgericht → Oberlandesgericht → Bundesgerichtshof; Europäischer Gerichtshof

DSGVO-Verstöße: BUSSGELD (§ 41 BDSG)	STGB und § 106 UrhG	BUSSGELD BSIG
---	---------------------	---------------

VERWALTUNGSGERICHTE: Verwaltungsgericht → Verwaltungsgerichtshof/
Oberverwaltungsgericht → Bundesverwaltungsgericht →
Europäischer Gerichtshof

BEHÖRDLICHE MASSNAHMEN / VERWALTUNGSAKTE

83. ★★☆☆ Der VERFAHRENSGANG vor Gericht

KLAGE (Strafgericht: ANKLAGE)



ZUSTELLUNG AN BEKLAGTEN (Angeklagter)



STELLUNGEN DER VERFAHRENSBETEILIGTEN



ERFORDERLICHENFALLS BEWEISERHEBUNG



URTEIL



ÜBUNGEN ZUR UNTERSCHIEDUNG VON TATBESTAND UND RECHTSFOLGE

Die Vorlesungsübung vom 08.04.2026 („Übungen zur Unterscheidung von Tatbestand und Rechtsfolge“) arbeitet mit folgenden Normen:

§ 30 BSIG — Risikomanagementmaßnahmen (Original-Wortlaut mit TBM/RF-Markierung)

Absatz (1) — TATBESTAND: „*Besonders wichtige Einrichtungen und wichtige Einrichtungen* sind verpflichtet, geeignete, verhältnismäßige und wirksame technische und organisatorische Maßnahmen ... zu ergreifen, um Störungen der Verfügbarkeit, Integrität und Vertraulichkeit ... zu vermeiden ..."

RECHTSFOLGE: Verpflichtung zur Ergreifung der Maßnahmen; Dokumentationspflicht (S. 3).

Die Verhältnismäßigkeitskriterien (S. 2): „das **AUSMASS DER RISIKOEXPOSITION**, die **GRÖSSE DER EINRICHTUNG**, die **UMSETZUNGSKOSTEN** und die **EINTRITTSWAHRSCHEINLICHKEIT UND SCHWERE** von Sicherheitsvorfällen sowie ihre **GESELLSCHAFTLICHEN UND WIRTSCHAFTLICHEN AUSWIRKUNGEN**"

Art. 8 Abs. (1) KI-Verordnung

„**Hochrisiko-KI-Systeme** müssen die in diesem Abschnitt festgelegten Anforderungen erfüllen, wobei **IHRER ZWECKBESTIMMUNG** sowie dem **ALLGEMEIN ANERKANNTEN STAND DER TECHNIK** in Bezug auf KI und KI-bezogene Technologien Rechnung zu tragen ist. Bei der Gewährleistung der Einhaltung dieser Anforderungen wird dem in **ARTIKEL 9** genannten **RISIKOMANAGEMENTSYSTEM** Rechnung getragen.“

Art. 8 Abs. (2) KI-Verordnung

„Enthält **ein Produkt ein KI-System**, für das die Anforderungen dieser Verordnung und die Anforderungen der in Anhang I Abschnitt A aufgeführten **HARMONISIERUNGSRECHTSVORSCHRIFTEN DER UNION** gelten, so sind die **ANBIETER** dafür verantwortlich, sicherzustellen, dass ihr Produkt **ALLE GELTENDEN ANFORDERUNGEN** vollständig erfüllt. ... haben die Anbieter **DIE WAHL**, die erforderlichen Test- und Berichterstattungsverfahren, Informationen und Dokumentationen ... **IN BEREITS BESTEHENDE DOKUMENTATIONEN UND VERFAHREN ZU INTEGRIEREN.**“

SELBSTTEST — Fragen zum Abfragen

▼ Teil 1: Erste Schritte in der Jura-Welt

1. ★★ Welche Hilfsmittel sind in der Klausur zugelassen? Wie viele Unterstreichungen und Wörter pro Seite? Was gilt als „Spickzettel“?
2. Wie ist das Gesamtmodul aufgeteilt (UE, Dozenten)?
3. Was unterscheidet Art. 20 Abs. (3) GG bei „Gesetz und Recht“?
4. ★★ Grenze POSITIVES RECHT und NATURRECHT ab. Nenne je eine Stärke und eine Schwäche.
5. ⚠ Welche historischen Beispiele nennt das Skriptum für die Grenzen des positiven Rechts?
6. ★★★ Formuliere die RADBRUCH'SCHE FORMEL. Welche zwei Anwendungsfälle nennt das Skriptum?
7. Was ist die „naturrechtliche Frage“ zu Edward Snowden?
8. ★★ Nenne die 7 Kennzeichen und Funktionen des Rechts.
9. Was sind staatlich GESETZTE, was staatlich ANERKANNTE Rechtsnormen?
10. Woher kommt das Wort „norma“? Was bedeutete es ursprünglich?
11. ★★ Grenze GESETZ IM MATERIELLEN SINN und GESETZ IM FORMELLEN SINN ab.
12. ⚠ ★★★ Warum ist die DSGVO trotz der Bezeichnung „Verordnung“ ein FORMELLES Gesetz? Warum ist die StVO nur ein materielles?
13. ★★★ Nenne die 4 MERKMALE EINES GESETZES.
14. Erkläre „generell-abstrakt“ an § 223 StGB und an Art. 6 DSGVO. Was ist das Gegenbeispiel?
15. ★★★ Wie lautet das Grundprinzip des Datenschutzrechts, das aus Art. 6 DSGVO folgt?
16. ★★ Grenze SOLLENSANORDNUNG und RECHTSSATZ ab. Welche drei Arten von Sollensanordnungen gibt es?
17. Was ist eine „versteckte“ Sollensanordnung? Erkläre an Art. 1 Abs. (1) S. 1 GG.
18. ★★ Grenze VOLLSTÄNDIGE und UNVOLLSTÄNDIGE Rechtssätze ab. Was ist das „Zulieferfirma“-Bild?
19. ★★★ Was sind DEFINITIONSNORMEN? Erkläre das Zusammenspiel von Art. 6 und Art. 4 Nr. 2 DSGVO.
20. Nenne drei DSGVO-Artikel, deren Anwendbarkeit von der Definition „Verarbeitung“ abhängt.
21. Wie sind StGB und DSGVO in „Allgemeinen“ und „Besonderen“ Teil gegliedert?
22. ★★★ Wie viele ERWÄGUNGSGRÜNDE hat die DSGVO? Welche Funktion haben sie? Enthalten sie Rechtsfolgen?
23. Wie zitiert man Art. 2 Abs. (3) S. 1 DSGVO in der Kurzschreibweise?

▼ Teil 1B: Subsumtion

24. ★★★★★ Nenne die 4 ARBEITSSCHRITTE der Rechtsanwendung. Was bedeutet „hin- und herwandern“?
25. ★★ Führe den Körperverletzungsfall („mechanische Unterhaltung“) komplett durch. Warum musste P zu Schritt 1 zurück?
26. Warum ist § 224 StGB im Fall NICHT einschlägig? Was ist die Rolle von § 230 StGB?
27. ★★★★★ Führe den Softwareunternehmen-Fall durch. Welche vier Normen sind einschlägig?
28. ★★ Wie lautet die Merkformel für „natürliche Personen“? Wer ist NICHT erfasst?
29. ★★★★★ Definiere SUBSUMTION, TATBESTAND und TATBESTANDSMERKMAL.
30. ⚠ Wie lautet die „goldene Regel“ zum Sachverhalt?
31. ★★★★★ Zerlege § 223 Abs. (1) StGB in seine 4 TBM. Was ist bei TBM 3 die Besonderheit?
32. ★★ Zerlege Art. 7 Abs. (1) DSGVO in seine 3 TBM und nenne die Rechtsfolge.
33. ★★★★★ Nenne die 3 Teil-Schritte der Subsumtion. Führe TBM 3 („körperlich misshandelt“) komplett aus — inkl. der BGH-Definition.
34. 🖨 Schreibe die Subsumtion des § 223 StGB als if-Anweisung in Pseudocode.

▼ Teil 1C und 2A: Rechtsquellen und Grundrechte

35. ★★ Grenze RECHTSNORM und RECHTSQUELLE ab. Nenne zwei Beispiele.
36. ★★★ Nenne die RANGFOLGE DER RECHTSQUELLEN (alle 9 Stufen). Wie lautet die Merkformel?
37. Aus welchen drei Grundsätzen ergibt sich die Rangfolge?
38. Erkläre den Fall Vorratsdatenspeicherung/Bundesnetzagentur als Beispiel für Normenkollision.
39. ★★★ Nenne die 4 zentralen MERKMALE VON GRUNDRECHTEN.
40. ★★ Grenze UNMITTELBARE und MITTELBARE Grundrechtsbindung ab (mit Normen und je einem Beispiel).
41. ★★ Erkläre den Parabolantennen-Fall. Welche zwei Grundrechte standen sich gegenüber?
42. ★★★ Erkläre die Interessenabwägung bei Werbung (Art. 6 Abs. (1) S. 1 lit. f) DSGVO). Wie lautet die Abwägungsregel?
43. ⚠ Was halten die Datenschutzbehörden von Behavioral Targeting und Profiling?
44. ★★★ Wie lautet der Kernsatz „Wer über meine Daten verfügt...“?
45. ★★★ Zitiere das VOLKSZÄHLUNGSRURTEIL (BVerfGE 65, 1). Was war der Sachverhalt? Welche Norm ist die Grundlage?
46. ★★ Nenne die zwei wegweisenden BVerfG-Entscheidungen von H.-J. Papier mit Datum und Inhalt.
47. ★★★ Nenne die 3 SCHRITTE der Grundrechtsprüfung.
48. ★★★ Nenne die 3 Prüfpunkte der verfassungsmäßigen Rechtfertigung.
49. ★★★ Führe den Fall „Volker und Markus Schecke“ komplett durch (Schutzbereich mit Obersatz/Untersatz/Schlusssatz, Eingriff, Rechtfertigung).
50. ⚠★ Woran scheiterte im Schecke-Fall die Rechtfertigung? Was wäre das mildere Mittel gewesen?
51. ★★ Nenne die vier datenschutzrelevanten Unionsgrundrechte mit Norm und Inhalt.
52. ⚠ Welches „Redaktionsversehen“ enthält Art. 16 AEUV?
53. ★★ Was wird im Schutzbereich des Art. 7 GRC verortet? Was ist die historische Begründung für den Kommunikationsschutz?
54. ★★★ Führe die EuGH-Prüfung zur Vorratsdatenspeicherung durch (Schutzbereich, Eingriff, fehlende Rechtfertigung).
55. ★★ Welche Schlüsse auf das Privatleben ermöglichen Verkehrs- und Standortdaten laut EuGH?
56. ★★★ Zeichne die Rechtsquellen-Kette Art. 7 GRC → ePrivacy-RL → TKG. Warum sind die §§ TKG nicht anwendbar?
57. Was hat der EuGH am 30.04.2024 zur IP-Adressen-Speicherung entschieden? Was bedeutet „Quick Freeze“?

▼ Teil 2A: DSGVO-Anwendungsbereich

58. ★★★★★ Grenze VERORDNUNG und RICHTLINIE ab (Norm, Wirkung, Umsetzung, nationale Regelungen).
59. ⚠️★★★★ Warum sind nationale Vorschriften im Anwendungsbereich der DSGVO auch dann unzulässig, wenn sie den DSGVO-Wortlaut wiederholen?
60. ★★ Nenne die 4 EU-Regelungswerke des Datenschutzes mit Anwendungsbereich.
61. ★★★★★ Was regeln Art. 5 Abs. (1) und Art. 5 Abs. (3) e-Privacy-RL?
62. ⚠️ Was ist die „Cookie-RL“ wirklich? Wie ist das Verhältnis DSGVO ↔ ePrivacy-RL (Art. 95 DSGVO)?
63. ★★ Was bedeutet es, wenn Juristen sagen „grundsätzlich gilt“?
64. ★★★★★ Nenne die 3 TATBESTANDSMERKMALE des Art. 2 Abs. (1) DSGVO.
65. ★★★★★ Definiere „personenbezogene Daten“. Nenne je 4 Beispiele für Personenbezug (+) und (-).
66. ★★★★★ Erkläre die IDENTIFIZIERBARKEIT und die drei IP-Adressen-Fälle.
67. Erkläre die Fälle OLAF und TC String.
68. ★★★★★ Grenze PSEUDONYMISIERUNG und ANONYMISIERUNG ab. Bei welcher gilt die DSGVO?
69. ★★ Definiere Verarbeitung, „automatisiert“, „nichtautomatisiert“ und „Dateisystem“.
70. ☹️ Warum sind Klingelschilder nicht von der DSGVO erfasst?
71. ★★★★★ Nenne alle 5 Ausnahmen des Art. 2 Abs. (2) und (3) DSGVO.
72. ★★★★★ Was ist die HAUSHALTS AUSNAHME? Nenne 4 Beispiele. Gilt sie für Facebook/WhatsApp?
73. ⚠️★★★★ Nenne die 4 kritischen Fälle zur Haushaltsausnahme. Was gilt für Überwachungskameras und Vereine?
74. ★★★★★ Nenne die zwei Kernaussagen des BGH zu DASHCAMS.
75. ★★★★★ Was sind ÖFFNUNGSKLAUSELN? Warum ist die DSGVO ein „Hybrid“? Nenne die wichtigste.
76. ★★★★★ Nenne die 4 Prinzipien des räumlichen Anwendungsbereichs (Art. 3 DSGVO) mit je einem Beispiel.
77. ★★ Was ist eine „Niederlassung“? Was reicht dafür schon aus (Weltimmo)?
78. ★★★★★ Erkläre den Fall GOOGLE SPAIN. Wie lautet die Regel zum „untrennbaren Zusammenhang“?
79. ★★★★★ Nenne die drei datenschutzrelevanten GG-Grundrechte mit Norm und Inhalt.
80. ★★ Wann gelten die Unionsgrundrechte, wann die des GG?
81. ★★★★★ Beschreibe den Aufbau des BDSG (4 Teile) und die 4 wichtigsten Regelungen der Teile 1/2.
82. ★★ Nenne die 3 Anwendungsregeln des BDSG (Adressaten, Bundesrecht, Subsidiarität).
83. ★★★★★ Führe den Fall „Hochschule speichert Klausurnoten“ komplett durch (4 Schritte).
84. ★★★★★ Zeichne das PRÜFSHEMA DSGVO → Öffnungsklausel → BDSG → JI-Richtlinie → Spezialvorschrift.
85. ★★ Beschreibe den Aufbau des TDDDG (4 Teile). Warum können sich auch Unternehmen auf Teil 2 berufen?
86. ★★ Zeichne die Definitionskette „digitaler Dienst“ (TDDDG → DDG → RL 2015/1535).
87. ★★★★★ Unter welchen Voraussetzungen darf ein App-Anbieter auf dem Endgerät speichern/zugreifen?
88. Was regelt die EINWILLIGUNGSVERORDNUNG seit dem 01.04.2025?

89. Nenne 6 nationale Spezialvorschriften. Wann gelten die Landesdatenschutzgesetze?

▼ Teil 2B und 3.2/3.3: IT-Sicherheitsrecht

90. ★★★★★ Definiere „IT-Sicherheitsrecht“ (Kursdefinition). Nenne die 5 Schutzziele.
91. ★★★★★ Grenze die SCHUTZOBJEKTE der IT-Sicherheit und des Datenschutzes ab.
92. ⚠★★★★ Gibt es ein Grundrecht auf IT-Sicherheit? Erkläre am Rechnungsbeispiel, warum sie trotzdem grundrechtsrelevant ist.
93. ★★ Erkläre die WECHSELWIRKUNG zwischen IT-Sicherheit und Datenschutz.
94. Nenne die 4 Beispiele zur Grundrechtsrelevanz (Chatkontrolle, Cybercrime, § 3a VwVfG, § 202a StGB).
95. ★★★★★ Woraus folgt die IT-Governance-Pflicht für Unternehmen und Behörden? Wie lautet die Kernbegründung?
96. ★★★★★ Was schützt das GeschGehG? Was ist die entscheidende Voraussetzung des § 2 Nr. 1 lit. b)? Welche Folge hat unverschlüsselter E-Mail-Versand?
97. ★★ Nenne 6 untergesetzliche Standards. Was ist ihre rechtliche Einordnung (4 Punkte)?
98. ★★★★★ Nenne die VIER SÄULEN der DSGVO mit den zugehörigen Artikeln.
99. ★★ Was ist COMPLIANCE? Nenne die 4 Zwecke und die 6 Alltagsprobleme.
100. ★★★★★ Nenne die Sorgfaltspflicht-Normen für AG, GmbH, GbR, oHG/KG und alle.
101. ★★ Was ist die BUSINESS JUDGEMENT RULE (§ 93 Abs. (1) S. 2 AktG)? Wen trifft die Beweislast?
102. ★★ Was verlangt § 91 Abs. (2) AktG?
103. ★★ Nenne die 3 Rechtsfolgen bei Verstoß gegen die Sorgfaltspflicht.
104. ★★★★★ Zeichne die Normenkette Art. 5 Abs. (1) lit. f) → Art. 5 Abs. (2) → Art. 24 → Art. 32 DSGVO.
105. ★★★★★ Was sind TOM? Grenze technische und organisatorische Maßnahmen ab. Warum ein TOM-KONZEPT?
106. ★★★★★ Nenne die 3 Schritte der Risikoabwägung (Artt. 24, 32 DSGVO).
107. ★★★★★ Führe den Fall NAP (EuGH C-340/21) komplett durch: DSGVO anwendbar? Anspruchsgrundlage? Alle 5 TBM des Art. 82?
108. ★★★★★ Nenne die 3 Kernaussagen des EuGH zu Art. 32 Abs. (1) DSGVO.
109. ★★★★★ Was ist laut EuGH ein „immaterieller Schaden“? Wann fehlt die Kausalität?
110. Was regelt § 19 TDDDG? Warum gilt er für JEDEN Webseitenbetreiber?
111. ★★★★★ Definiere BEDROHUNG, GEFAHR/GEFÄHRDUNG, SCHADEN und RISIKO (BSI-Glossar).
112. ★★ Nenne die drei EU-Richtlinien zur IT-Sicherheit mit deutscher Umsetzung. Was bedeutet RESILIENZ?
113. ★★ Nenne die Aufgaben (§ 3) und 4 Befugnisse des BSI. Was ist ENISA?
114. ★★★★★ Wer unterliegt dem BSIG? Nenne die Kategorien mit Schwellenwerten.
115. ★★★★★ Nenne die 10 KRITIS-SEKTOREN.
116. ★★ Was steht in Anlage 1, was in Anlage 2 zum BSIG?
117. ★★★★★ Nenne die PRÜFUNGSREIHENFOLGE für „Gilt das BSIG?“ (3 Schritte).
118. ★★★★★ Nenne die 10 Pflicht-Maßnahmen des § 30 Abs. (2) S. 3 BSIG.
119. ★★ Nenne die 3 Maßstäbe des § 30 Abs. (2) S. 1 und die 5 Verhältnismäßigkeitskriterien des Abs. (1) S. 2.
120. ★★ Was ist bei § 31 BSIG (kritische Anlagen) verschärft?
121. ★★★★★ Nenne die MELDEFRISTEN des § 32 BSIG. An wen wird gemeldet?
122. ★★ Was regelt § 33 BSIG (Frist!)? Was regelt § 38 BSIG (3 Punkte)?

▼ Teil 3.4–4: Produkte, KI, Forschung, Haftung, Durchsetzung

123. ★★ Definiere „Produkt mit digitalen Elementen“ (Art. 3 Nr. 1 CRA). Wer sind die „Wirtschaftsakteure“?
124. ★★★★★ Ordne zu: Kauf, Schenkung, Miete, Werkvertrag — mit Normen und je einem IT-Beispiel.
125. ★★ Nenne die Rechte des Käufers (§ 437 BGB). Was gilt IMMER?
126. ★★★★★ Führe den Smartphone-Fall (OLG Köln) durch. Stelle Rechtsprechung und Literaturkritik gegenüber.
127. Was gilt bei Freeware? Was ist § 521 BGB?
128. ★★ Nenne die Rechte des Mieters. Was ist der Unterschied zur Nacherfüllung im Kaufrecht?
129. ★★ Erkläre den KASPERSKY-Fall (LG München I). Welche zwei Anspruchsgrundlagen wurden geprüft?
130. ★★ Welche 3 Sondervorschriften gelten bei Verbraucherverträgen über digitale Produkte?
131. ⚠★★★★ Nenne die 2 Probleme der vertraglichen Verantwortung. Was ist die „Haftungslücke“?
132. ★★★★★ Nenne die 3 Verkehrspflichten des § 823 Abs. (1) BGB. Was ist das Problem dieser Norm?
133. ★★ Was leistet § 823 Abs. (2) BGB zusätzlich? Nenne 4 Schutzgesetze.
134. ★★★★★ Was ist die Besonderheit des ProdHG? Wann ist Software ein „Produkt“?
135. ★★ Nenne die 5 Neuerungen der Produkthaftungsrichtlinie (EU) 2024/2853.
136. ★★★★★ Was ist der CRA? Ab wann gilt er? Warum ist er die „erste HORIZONTALE Regelung“?
137. ★★ Nenne die 3 Stufen der Cybersicherheitsanforderungen (Artt. 6, 7, 8 CRA).
138. ★★ Nenne die Pflichten von Herstellern (Art. 13, 14) und Einführern/Händlern (Art. 19, 20).
139. ★★ Definiere „KI-System“ (Art. 3 Nr. 1 KI-VO). Was ist KEINE KI?
140. ⚠★★★★ Nenne die 3 Grundprobleme von KI-Anwendungen. Was ist „Verantwortungsdiffusion“?
141. ★★★★★ Zeichne den RISIKOBASIERTEN ANSATZ der KI-VO (4 Stufen + Art. 4).
142. ★★★★★ Nenne 4 verbotene Praktiken (Art. 5 KI-VO).
143. ★★ Was sind Hochrisiko-KI-Systeme (Art. 6 Abs. (1) und (2))?
144. ★★★★★ Nenne die 4 Transparenzpflichten des Art. 50 KI-VO. Welche gelten für den Chatbot-Ausgangsfall?
145. ★★ Was ist GPAI? Welche Pflichten treffen Anbieter nach Art. 53?
146. ★★★★★ Nenne das 3-SCHRITTE-PRÜFSHEMA für KI-Anwendungen.
147. ★★ Wie hoch sind die Bußgelder nach Art. 101 KI-VO? Welche Behörde ist in DE geplant?
148. ★★★★★ Beschreibe den Fall LILITH WITTMANN in 7 Schritten.
149. ★★★★★ Nenne die 4 Schritte des RESPONSIBLE DISCLOSURE.
150. ★★★★★ Nenne die 6 TBM des § 202a StGB. Welches fehlte im Ausgangsfall?
151. ★★ Nenne die TBM des § 202b StGB. Warum ist er im Ausgangsfall nicht einschlägig?
152. ★★ Was regelt § 202c StGB? Welche Einschränkung hat das BVerfG gemacht?
153. ★★★★★ Erkläre § 34 StGB (rechtfertigender Notstand) und seine 4 Prüfpunkte bei Responsible Disclosure. Was ist die „gegenwärtige Gefahr“?
154. ⚠ Welchen Praxistipp gibt das Skriptum zur Dokumentation?
155. ★★ Welche Rechtsgrundlage gilt für den Sicherheitsforscher im Datenschutz? Wie lautet die Normenkette bei Art.-9-Daten?
156. ★★ Erkläre die urheberrechtliche Prüfung im Ausgangsfall (§§ 69a, 69c UrhG). Warum kein Verstoß?

157. ★★ Nenne das Gesamtergebnis im Fall Wittmann (3 Ebenen).
158. ⚠★★ Sind KI-erzeugte Inhalte urheberrechtlich geschützt? Warum (nicht)?
159. ★★★ Nenne die 3 Passivlegitimations-Kategorien. Nenne die 4 Kriterien für „zu eigen gemachte“ Inhalte.
160. ★★★ Führe den PLAYBOY-Fall (EuGH C-160/15) durch. Wann liegt ein „NEUES PUBLIKUM“ vor? Was wird bei Gewinnerzielungsabsicht vermutet?
161. ★★★ Nenne die 3 Providerprivilegien des DSA (Artt. 4, 5, 6) mit ihren Voraussetzungen.
162. ★★★ Nenne die 3 Modelle der Rechtsdurchsetzung. Was ist der Unterschied zwischen Art. 80 Abs. (1) und (2) DSGVO?
163. ★★ Welche Datenschutzbehörden gibt es in Deutschland und wofür sind sie zuständig?
164. ★★★ Nenne die 3 Befugnisgruppen des Art. 58 DSGVO mit je 2 Beispielen.
165. ★★ Ordne die Streitigkeiten den 3 Gerichtsbarkeiten zu. Nenne den Instanzenzug.
166. Beschreibe den Verfahrensgang vor Gericht (5 Schritte).

KLAUSUR-SPICKZETTEL

RECHTSQUELLEN-RANGFOLGE („OBER STICHT UNTER“)

EU-Recht → GG → Völkerrecht (Art. 25 GG) → Bundesgesetze →
RVO/Satzungen Bund → Landesverfassungen → Landesgesetze →
RVO/Satzungen Länder → kollektive Normen des Arbeitsrechts

DIE 4 ARBEITSSCHRITTE

① Sachverhalt feststellen ② Normen suchen ③ Subsumieren ④ Urteil
(„hin- und herwandern“ zwischen ① und ②!)

DIE 4 GESETZESMERKMALE

generell-abstrakt · bedingt (Tatbestand) · Sollensanordnung · Rechtsfolge

SUBSUMTION

OBERSATZ (abstrakte Regel) → UNTERSATZ (Sachverhalt) → SCHLUSSSATZ

GRUNDRECHTSPRÜFUNG (3 Schritte)

① Schutzbereich ② Eingriff ③ Verfassungsmäßige Rechtfertigung
→ Gesetz? · Gesetzesvorbehalt? · legitimer Zweck + geeignet/
erforderlich/angemessen (Verhältnismäßigkeit)

DATENSCHUTZ-GRUNDPRINZIP

★ VERARBEITUNGSVERBOT MIT ERLAUBNISVORBEHALT
(Art. 8 GRG · Art. 6 DSGVO)

DSGVO ANWENDBAR? (Art. 2, 3)

SACHLICH: personenbez. Daten + (automatisiert ODER
nichtautomatisiert + Dateisystem)
AUSNAHMEN: Unionsrecht (-) · Außen-/Sicherheitspolitik ·
HAUSHALTSANNAHME · Strafverfolgung (JI-RL) ·
EU-Organen (VO 2018/1725) · TK-Dienste (ePrivacy)
RÄUMLICH: Sitzlandprinzip · Markortprinzip · Verhaltens-
beobachtung · Völkerrecht

ART. 6 ABS. (1) S. 1 DSGVO – die 6 Tatbestände

a) Einwilligung b) Vertrag c) rechtliche Verpflichtung
d) lebenswichtige Interessen e) öffentl. Interesse/Gewalt
f) berechnete Interessen (⚠ nicht für Behörden!)

EINWILLIGUNG (lit. a) – Prüfliste

Erklärung? · betroffene Person? · Einwilligungsfähigkeit (Art. 8!)
· Zweck(e) · freiwillig/informiert/eindeutig (Art. 4 Nr. 8)
· verständlich/klar (Art. 7 II) · Widerrufshinweis (Art. 7 III)
· KOPPELUNGSVERBOT (Art. 7 IV)

⚠ VORAUSGEFÜLLTE KÄSTCHEN = KEINE EINWILLIGUNG (Planet 49)

BERECHTIGTE INTERESSEN (lit. f) – Abwägung im Dreischritt

① Interessen Verantwortlicher/Dritter ② Interessen Betroffener
③ gewichten ★ Bei GLEICHSTAND: Verarbeitung zulässig!

BDSG-PRÜFSHEMA

DSGVO anwendbar? → Öffnungsklausel? → §§ 1–44 BDSG neben DSGVO
→ JI-RL? → §§ 45–84 BDSG
→ sonst: Spezialvorschrift oder § 85 BDSG

IT-SICHERHEITSRECHT

Schutzziele: Vertraulichkeit · Integrität · Authentizität ·
Verfügbarkeit · Nicht-Abstreitbarkeit
Schutzobjekte: informationstechnische SYSTEME
(Datenschutz: personenbezogene DATEN)
IT-Governance: § 91 II AktG · § 43 GmbHG · Art. 32 DSGVO

TOM-Risikoabwägung: Schutzbedarf → Risikobewertung → Risikobehandlung

BSIG

Besonders wichtige Einrichtungen (§ 28 I) · Wichtige (§ 28 II) ·
 Betreiber kritischer Anlagen (§ 28 VIII)
 Pflichten: § 30 Risikomanagement (10 Maßnahmen!) · § 31 KRITIS ·
 § 32 Meldung (24 h / 72 h / 1 Monat) · § 33 Registrierung
 (3 Monate) · § 38 GF-Pflichten (umsetzen, überwachen,
 SCHULEN)
 Behörden: BSI (national) · ENISA (EU)

PRODUKTHAFTUNG

Vertrag: §§ 433/434 (Kauf) · 516/521 (Schenkung) ·
 535/536 (Miete) · 631/633 (Werkvertrag)
 Gesetz: § 823 I (Konstruktion/Instruktion/Produktbeobachtung) ·
 § 823 II (Schutzgesetz, auch Vermögensschaden) ·
 § 1 ProdHG (VERSCHULDENSUNABHÄNGIG)
 CRA (VO 2024/2847): ab 11.12.2027 · Artt. 6/7/8 · Meldung an ENISA

KI-VO (VO 2024/1689)

Risikostufen: verboten (Art. 5) · Hochrisiko (Art. 6 ff.) ·
 bestimmte KI (Art. 50) · GPAI (Artt. 51 ff.)
 + KI-Kompetenz (Art. 4)
 Bußgeld: bis 3 % Jahresumsatz ODER 15 Mio. € (Art. 101)

IT-SICHERHEITSFORSCHUNG

§ 202a StGB: Zugang · nicht bestimmt · BESONDERS GESICHERT ·
 Überwindung · Vorsatz · unbefugt
 § 34 StGB: gegenwärtige Gefahr (= die Lücke!) · Notstandshandlung ·
 geeignet/erforderlich/angemessen · Notstandswille
 DSGVO: Art. 6 I 1 f) · UrhG: §§ 69a, 69c, 69d

HAFTUNG IM INTERNET

Eigene Inhalte · zu eigen gemachte (4 Kriterien) · Störerhaftung
 Links: „NEUES PUBLIKUM“-Doktrin (EuGH Playboy);
 bei GEWINNERZIELUNGSABSICHT wird Kenntnis VERMUTET
 DSA: Art. 4 Access · Art. 5 Caching · Art. 6 Hosting

RECHTSDURCHSETZUNG

staatlich (Behörden/VA) · individuell (Klage) ·
 kollektiv (Art. 80 I Prozessstandschaft / Art. 80 II Verbandsklage)
 Art. 58 DSGVO: Untersuchung (I) · Abhilfe (II) · Beratung (III)

Zentrale Literatur der Vorlesung

Werk	Bedeutung
★★★★ Deusch/Eggendorfer: „Beauftragte für IT-Sicherheit und Informationssicherheit“, 2024	PFLICHTLEKTÜRE (eBook in der Hochschulbibliothek)
★ beck-dtv-Ausgabe 5562 „IT- und Computerrecht“ (CompR)	Die Gesetzessammlung für die Klausur
Rüthers/Fischer/Birk: Rechtstheorie, 12. Aufl. 2022	Grundlagen Teil 1
Bringewat: Methodik der juristischen Fallbearbeitung, 5. Aufl. 2024	Subsumtion
Schantz/Wolff: Das neue Datenschutzrecht, 2017	DSGVO-Systematik („Vier Säulen“)
Gola/Heckmann: DS-GVO/BDSG Kommentar, 3. Aufl. 2022	
Plath: DSGVO/BDSG/TTDSG Kommentar, 5. Aufl. 2025	
Taeger/Pohle: Computerrechts-Handbuch	Kap. 50.1 (Deusch/Eggendorfer) — IT-Sicherheitsrecht
Kingreen/Poscher: Grundrechte, Staatsrecht II, 41. Aufl. 2025	Grundrechtsprüfung
Streinz: Europarecht, 12. Aufl. 2023	Verordnung/Richtlinie



Fachaufsätze im Moodle-Kurs (Deusch/Eggendorfer in K&R)

Fundstelle	Thema
K&R 2025, 150–157	§ 202a StGB / Responsible Disclosure (gescheiterte Reform)
K&R 2025, 221–226	Der Ausgangsfall zur manipulierten PDF-Rechnung (OLG Schleswig-Holstein)
K&R 2026, 297–303	Wer unterliegt den Pflichten des BSIG?
K&R 2024, 169 ff.	NIS-2-RL und NACE-Systematik
jurisPR-ITR 21/2024 Anm. 6 (Ziegler/Schröder)	SW-Mangel